Data Privacy & Protection ��? Exam Notes

- START HERE — Data Privacy & Protection exam pack
- UNIT 1A — PRIVACY THEORY (Warren & Brandeis · Roessler · Solove)
- UNIT 1B — INDIA: PUTTASWAMY → SRIKRISHNA → JPC → DPDP 2022 → DPDP ACT 2023
- UNIT 2 — PRIVACY, CONSENT & GDPR: THE 15 READINGS (condensed)
- UNIT 2 — PART 2: R4 (Pilot) · R5 (Scoping review) · R6 (Najdi) · R7 (DPC contracts guide)
- UNIT 2 — PART 3: R8 (McDonald & Cranor) · R9 (PIAs in the Wild) · R10 (PIA/PRA methodologies) · R11 (Custers & Vrabec) · R12 (Lindegren et al.)
- UNIT 2 — PART 4: R13 (Dove & Chen) · R14 (Medzini & Epstein) · R15 (Kay & Terry) · SYNTHESIS & EXAM TOOLKIT
- SYNTHESIS & EXAM TOOLKIT FOR UNIT 2
- UNIT 3 — CONTROLLERS, PROCESSORS & JOINT CONTROLLERS (condensed from your 5 readings C1–C5)
- UNIT 3 EXAM TOOLKIT

START HERE — Data Privacy & Protection exam pack

What's in /notes (read in this order)

File	What	Approx. study time
`UNIT1A_privacy_theory.md`	Warren & Brandeis · Roessler · Solove (16 harms)	60–75 min
`UNIT1B_india_data_protection.md`	Puttaswamy → Srikrishna → JPC → DPDP 2022 → DPDP Act 2023 + master GDPR comparison	75–90 min
`UNIT2_part1_readings.md`	*Planet49*, Santos (cookie banners), Pałka (LLMs & policies)	45 min
`UNIT2_part2_readings.md`	Pilot, scoping review, Najdi, DPC Art 28 guide	45 min
`UNIT2_part3_readings.md`	McDonald & Cranor, PIAs (Iwaya, Wairimu), Custers & Vrabec, Lindegren	60 min
`UNIT2_part4_readings_and_synthesis.md`	Dove & Chen, Medzini & Epstein, Kay & Terry + **master debate, connection map, 11 essay skeletons**	60 min
`UNIT3_controllers_processors.md`	EDPB 07/2020, Cimina, Opinion 22/2024, Compliance Gap, CJEU cases, DPDP s 8	75–90 min

Each file ends with exam questions, cheat-sheet numbers and "common traps". Bold = highest-yield. † = outside the readings.

Suggested plan (tonight → tomorrow)

- **Tonight:** U1A → U1B → U3 → U2 (parts 1–4). U1B and U3 are the most "memorise-and-apply" (sections, case names, tables); U2 is the most "argue" (debate).
- **After each file:** close it and write 5 lines from memory — the thesis, 3 key cases/numbers, 1 critique, 1 link to another reading.
- **Tomorrow morning:** reread each file's *exam questions* + *cheat sheet* + *traps*, then U2 Part 4 synthesis, then U1B §7 comparison table.
- **Last 30 minutes:** only the "Last-look sheet" below.

Last-look sheet (read this before walking in)

Unit 1

- **Three theories:** W&B = "right to be let alone"/**inviolate personality** (tort; 6 limitations; **truth & malice no defence**) · Roessler = **autonomy**, **decisional/informational/local**, "dimensions not spaces", democracy · Solove = **16 harms/4 groups**, **family resemblance**, **secrecy paradigm**, **dignitary vs architectural**.
- **Traps:** W&B were lawyers not justices; "let alone" is Cooley's; Prosser made 4 torts; blackmail = power; exposure ≠ disclosure.
- **Puttaswamy:** 24 Aug 2017, 9 judges; Art 21 + Part III; overruled M.P. Sharma/Kharak Singh; **legality, legitimate aim, proportionality (+ procedural safeguards)**; Kaul: State **and non-State**.
- **India timeline:** Srikrishna (Jul 2018, fiduciary, 4 non-consent grounds) → JPC (16 Dec 2021, NPD, 72h, localisation) → 2022 (30 sections, **deemed consent**, whitelist, High Court, ₹500 cr, **duties on**

principals) → 2023 (44 clauses, **legitimate uses**, **blacklist**, **TDSAT**, **17(2)(a)/17(5)**, **s 36/37**, **RTI**, public data excluded).
- **Always argue:** State exemptions vs Puttaswamy proportionality; no SPD; weak/captured Board; consent-centric despite "fiduciary" label.

Unit 2

- **Thesis for the big essay:** notice-and-consent survives only if self-management cost falls and controllers are constrained *after* consent; **law + design + technology complementary, Art 25 GDPR the bridge.**
- ***Planet49*:** pre-ticked box ≠ consent; applies to non-personal data (device integrity); tell **duration + third-party access**; **bundling not decided**; critique "regulates the click".
- **Santos:** 3 of 10 Nielsen heuristics → 10 design choices; "Not yet" / right to be ambivalent; DPAs conflict on colours. **Pałka:** longer complete policies + LLMs; real policies answer 2/9; GPT-4 33/45. **Pilot:** formal policy language + SPIN. **Najdi:** don't hand data over; 9/10 rights; IR10 fails. **DPC:** Art 28(3).
- **McDonald & Cranor:** 244 h, $3,534, $781 bn. **Iwaya/Wairimu:** PIAs perfunctory; **validated ≠ evaluated**; 9/39 evaluated. **C&V:** rights don't reach inferences; only Arts 21–22. **Lindegren:** DAD +36 s, SUS 81, recall n.s. **Dove & Chen:** consent misconception; "South Africa+". **Medzini:** polycentric; DPO + educators. **Kay & Terry:** 7 s → 37 s; summaries displace reading.

Unit 3

- **Test:** purposes + **essential means** (data type, duration, recipients, data subjects) = controller; non-essential means (software, security detail) may be processor's. **Functional not contractual.** Processor beyond instructions → **Art 28(10)** = controller.
- **Joint control:** common or **converging decisions**, "inextricably linked"; **no access needed; joint ≠ equal; only jointly determined phases** (*Wirtschaftsakademie* C-210/16, *Jehovah's Witnesses* C-25/17, *Fashion ID* C-40/17; *Google Spain* C-131/12). **Art 26(3):** rights against each. Mere commercial benefit ≠ joint control.
- **Art 28(3):** 8 clauses (a)–(h). **Sub-processors:** specific authorisation (silence = denied) vs general (silence = ok); Art 28(4) same obligations; initial processor liable.
- **Opinion 22/2024:** know the whole chain; verify (risk changes extent not existence); no duty to *systematically* collect sub-contracts; "practical difficulties don't exonerate"; "unless required by law" wording recommended not required, broad wording ≠ instruction.
- **Compliance gap (Baquero):** back-end blind spot; 4 defects (dispersed, static, convoluted, legalistic); Atos documents; Symboleo/nuXmv/Hyperledger; limit "garbage in, garbage out". ⚠ **paper says "Art 7"; correct = Art 5(2)/24.**
- **India:** DPDP s 2(i)/(k); **s 8(1)** single accountability; **s 8(2)** valid contract (not s 8(6)); Rule 6(1)(f) only content rule; **no direct processor duties, no Art 28(10), no Art 26, no compensation**; *Dedalus* fine impossible; RBI NBFC outsourcing direction fills gap.

Honest caveats

- These notes are condensed from your own summary PDFs, so they will look familiar — the value is the tighter structure, tables and exam skeletons. Where your PDFs flagged errors in sources (Roessler on W&B, Cimina purposes/means wording, Compliance Gap "Art 7", Notes on Clauses cls 36/37, McDonald & Cranor 201 vs 244 h) I kept the flags.

- I haven't seen your lecture slides, so check any "†" item against them before relying on it.
- If your exam is closed-book essays, **learn the skeletons and tables, not the prose.**

UNIT 1A — PRIVACY THEORY (Warren & Brandeis · Roessler · Solove)

(† = general knowledge your notes flagged as outside the readings.)

0. The 3 readings side by side

	Warren & Brandeis (1890)	Roessler (2018)	Solove (2006)
Field	Law (common law/torts)	Philosophy	Pragmatic legal theory
Core idea	**"Right to be let alone"**, based on **"inviolate personality"**	Privacy protects **autonomy** in **3 dimensions**: decisional, informational, local	**No single essence**; **family resemblance** of **16 harms** in 4 groups
Method	Cases (property, contract, confidence) → general principle	Conceptual analysis	Bottom-up classification of recognised problems
Threat	Press gossip + instant photography	Big Data, surveillance, patriarchal family	Information-Age databases, govt surveillance
Harm	**Dignitary**	Loss of autonomy; threat to democracy	**Dignitary + architectural**
Public/private	Assumes "sacred" home (but admits person-relative)	**"Dimensions, not realms or spaces"**	Attacks **secrecy paradigm**
Remedy	New **tort**	None (conceptual)	Framework to **identify and balance** problems
Individual vs social	Mainly individual; gossip degrades society	Autonomy AND democracy	**Constitutive of society**

Essay-intro story: W&B invented the legal right → **Prosser (1960)** carved **4 torts** → **Solove** says too narrow/outdated, offers 16 harms → **Roessler** supplies the "why" (autonomy) + feminist critique + democracy. **Timeline:** 1890 W&B · 1902 *Roberson* · 1905 *Pavesich* · 1928 *Olmstead* dissent · 1960 Prosser · 1965 *Griswold* · 1967 Westin/*Katz* · 1973 *Roe*, HEW FIPs · 1983 BVerfG Census · 2006 Solove · 2013 Snowden · 2016 GDPR · 2017 Puttaswamy · 2018 Roessler.

---

1. WARREN & BRANDEIS, "The Right to Privacy" (1890)

4 Harv. L. Rev. 193 (15 Dec 1890). Epigraph: Willes J. in *Millar v Taylor* → judges can recognise new rights without legislation.

Bottom line: common law already has a right **"to be let alone"** (**Cooley's** phrase), protected "in disguise" via property/contract/confidence. True basis = **"inviolate personality"**, not property. New tech (**instantaneous photos**) + **gossip press** → recognise as **tort**. Limited by public interest, privilege, consent. Remedies: **damages**, limited **injunction**; criminal law needs legislation.

Context: Kodak/instant photos (surreptitious); "what is whispered in the closet shall be proclaimed from the house-tops"; yellow press; E.L. Godkin; NY portraits case (fn 13). Backstory (Warren annoyed at press; "daughter's wedding" story doubtful†). ⚠ **Roessler wrongly calls them "Justices" — in 1890 they were Boston law partners; Brandeis joined SC in 1916.**

Argument step by step

1. **Common law grows:** physical (trespass) → "spiritual nature, feelings, intellect"; life → "right to enjoy life, **the right to be let alone**"; property → "every form of possession, **intangible**". Judges protect emotions "**without the interposition of the legislature**."
2. **The need:** photos + newspapers "invaded the **sacred precincts of private and domestic life**"; **gossip has become a trade**; mental harm > physical. **Social harm:** "**Triviality destroys at once robustness of thought and delicacy of feeling.**"
3. **Why defamation doesn't fit:** defamation = injury to **reputation** (external); no remedy for hurt feelings (*damnum absque injuria*).
4. **IP is really privacy:** each person decides "**to what extent his thoughts, sentiments, emotions shall be communicated to others**"; lost only on publication by author; independent of method/value (casual letter/diary = "most valuable poem").
5. **"Property" can't explain cases:** diary (protected = "not the intellectual product, but the **domestic occurrence**"); ***Prince Albert v Strange* (1849)** (royal etchings; even a catalogue restrained; Cottenham: "**privacy is the right invaded**"); ***Wyatt v Wilson* (1820)**; gems-catalogue example.
6. **CONCLUSION KEY QUOTE:** *"not the principle of private property, but that of an **inviolate personality**."*
7. **All forms of expression:** "writing, conduct, conversation, attitudes, or facial expression"; labour/deliberateness/value/intent-to-publish all abandoned.
8. **Contract & confidence inadequate:** | Case | Facts | Basis | |---|---|---| | *Abernethy v Hutchinson* 1825 | Surgeon's lectures in *The Lancet* | Breach of **confidence** | | *Prince Albert v Strange* 1849 | Royal etchings | Property + trust/confidence/contract | | *Tuck v Priester* 1887 | Extra copies of picture | Breach of **contract** | | *Pollard v Photographic Co* 1888 | Photographer sold lady's photo | **Implied contract + confidence**; "taken on the sly"? | | *Yovatt v Winyard* 1820 | Employee copied recipes | Breach of trust; no distinction from **stranger** | **Tech point:** photography once needed "sitting" → contract/trust; **surreptitious photography → "contract and trust are inadequate" → "law of tort." Stranger problem** → rights **"as against the world" (in rem)**.

6 limitations | # | Limitation | Detail | |---|---|---| | 1 | Public/general interest | "modest and retiring individual" vs "would-be congressman"; **no legitimate connection to fitness for public office** | | 2 | Privileged communications | courts, legislatures, reports | | 3 | Oral publication | probably no redress w/o special damage | | 4 | Ceases on publication by/with consent | private/restricted circulation ≠ publication (early *contextual integrity*) | | 5 | **Truth no defence** | injury to privacy not character | | 6 | **Absence of malice no defence** | like trespass | **Remedies:** damages (all cases); injunction (limited); criminal needs legislation. Closing: "front entrance… back door to idle or prurient curiosity."

Key concepts: right to be let alone (Cooley) · inviolate personality · *damnum absque injuria* · rights *in rem* · control over communication (→ Westin). **Legacy†:** *Roberson* (NY 1902, rejected; led to Civil Rights Law §§50–51) · *Pavesich* (Ga 1905, first to recognise) · **Prosser 1960: intrusion, public disclosure, false light, appropriation** (§652) · Brandeis' *Olmstead* dissent → *Katz* · India: Puttaswamy; *R. Rajagopal* 1994. **Critiques:** vague/broad · too narrow (press/disclosure; ignores aggregation, secondary use, surveillance) · free speech · elitist/class-based · gendered ("a woman's face") · individualistic (no structural regulation) · public/private dichotomy · only **dignitary** harm. **Strengths:** tech-sensitive; non-pecuniary harm; anti-commodification; social harm of gossip.

---

2. ROESSLER, "Three Dimensions of Privacy" (2018)

Handbook of Privacy Studies, pp. 137–141. Philosopher, Amsterdam. **Bottom line:** privacy = **autonomy/freedom**; **decisional, informational, local** — "**dimensions, not realms or spaces**". Social/democratic value: **"Threats to privacy, therefore, are always also threats to democracy."** Autonomy = "(part-)author of her own biography."

Decisional (privacy of actions): protects decisions about **how to live**; origin ***Roe v Wade* 410 US 113 (1973)** (Blackmun: privacy "broad enough to encompass a woman's decision whether or not to terminate her pregnancy"). Feminist theory: sexual self-determination; **privacy of the body** (Gatens); **harassment**; **sexual orientation**. Intimate decisions = "authentic identity". **Extends to public space:** others owe "**restraint, inattention, reserve, and indifference**" ("none of your business"), subject to renegotiation. India: *Navtej Johar*, *X v Principal Secretary*†. Caveat: *Dobbs* overruled *Roe*†; MacKinnon†.

Informational: from W&B; threat = Big Data/state surveillance; **control over self-presentation**; people regulate **relationships and roles**; **"If everyone knew everything about everyone else, differentiated relations and self-presentations would no longer be possible, and nor would autonomy." BVerfG Census judgment 1983 (BVerfGE 65, 1 [43]) → informational self-determination**. **Relational privacy:** Fried 1968, Rachels 1975. Snowden used PETs. Links: GDPR control model, Puttaswamy, Goffman†, Nissenbaum.

Local: home, "own four walls"; **not natural** but constructed from liberal idea of **withdrawal**. (a) **solitude/being-for-oneself**, body (Woolf, Orwell†); (b) **family relationships** ("take a break from roles"). **Feminist critique:** division of labour, **domestic violence**, "pre-political space". **Response:** privacy of home justified **only insofar as it secures equal autonomy** (Honneth, Rawls, Okin†).

Conclusion: Snowden → "constitutive relevance for democracy"; Simitis 1987; post-9/11; **presumption of innocence** endangered: mass surveillance → "every democratic subject into a potentially guilty object". Final line: "Democracy relies upon citizens who value their autonomy, both in public and in private."

Evaluation: + unifies; escapes public/private; takes feminism seriously; individual+social. − **autonomy-centrism**; control theory poor for Big Data (Nissenbaum: appropriate flows); overlaps with liberty (Thomson); **factual slips** (W&B "Justices", "constitutional"); Western liberal framing; thin on remedies.

---

3. SOLOVE, "A Taxonomy of Privacy" (2006), 154 U. Pa. L. Rev. 477

Bottom line: "**Privacy is a concept in disarray.**" Map **activities** causing problems: **16 harms, 4 groups**. **Family resemblance** (Wittgenstein). Law's **secrecy paradigm** → "**no balancing ever takes place**." Aim: identify problems so they can be balanced — **not** that privacy always wins.

Vagueness quotes: Borges; McCarthy; BeVier ("chameleon-like"); A. Miller; Gerety ("protean"); Scheppele; J.J. Thomson. Six unlike examples: rape victim's name (*Florida Star*), reporters in home (*Dietemann*), X-ray devices, thermal imaging (*Kyllo*), list of 5m elderly incontinent women, GeoCities sold data.

Why not Prosser? tort-only; outdated; catalogues existing law. Others: Westin (solitude/intimacy/anonymity/reserve), Gormley (areas of law), Kang (space/choice/info flow), DeCew.

Method (8 points): (1) privacy is **social** — "relief from a range of kinds of **social friction**"; (2) focus on **activities** (privacy equation = harmful activity + private matter; he covers only first half); (3) **consent** (but Cohen/Schwartz: boilerplate = "legal fiction"); (4) not normative about outcome; (5) **family resemblance**;

(6) **dignitary vs architectural harm** — *dignitary* = injury to feelings/reputation (disclosure, exposure, distortion); *architectural* = structural **risk** "like pollution" (↑ risk of harm; upsets power balance → **chilling effect**, *Laird v Tatum*); (7) not merely individual — **constitutive privacy** (Dewey, Post "rules of civility", Cohen, Schwartz, Gavison); (8) model: collect → process → disseminate; invasions go *toward* individual.

THE TAXONOMY

Group	Harm	Definition
A. Collection	1 Surveillance	watching/listening/recording
	2 Interrogation	pressuring to divulge
B. Processing	3 Aggregation	combining data
	4 Identification	linking info to individuals
	5 Insecurity	carelessness protecting stored info
	6 Secondary use	new purpose without consent
	7 Exclusion	no notice/input on records
C. Dissemination	8 Breach of confidentiality	breaking promise
	9 Disclosure	true info affecting judgment of character
	10 Exposure	nudity, grief, bodily functions
	11 Increased accessibility	amplifying access
	12 Blackmail	threat to disclose
	13 Appropriation	using identity for another's aims
	14 Distortion	false/misleading info
D. Invasion	15 Intrusion	disturbs tranquility/solitude
	16 Decisional interference	govt interference in private decisions

Mnemonic: Collect (S,I) → Process **AIISE** → Disseminate **B D E I B A D** → Invade (I,D).

A. Collection

Surveillance: history (Peeping Tom; wiretap law: *Olmstead* 1928 → *Katz* 1967 → Title III 1968 → ECPA 1986). Harms: self-censorship/**chilling**; social control (CCTV "friendly eye in the sky"); Cohen: choices "toward the bland and mainstream"; **Benn** (covert = wrong; **Solove rejects**: "awareness" affects freedom); **Panopticon** (Bentham/Foucault); even covert = **architectural** (FBI & **MLK**). **Law's failure = where not effects:** protected private places (*Kyllo*, *Karo*, *Hamberger*) vs public places not (*Florida v Riley*, *Dow*, *US v Knotts*) = **secrecy paradigm**; partial exception ***Nader v GM***. Westin; Douglas J.: "Monitoring… kills free discourse." **Interrogation:** pressure; **5th Am.**; census outcry; harms: **coercion**, chills association (HUAC, *Barenblatt*), **distortion** (Brooks, Dostoevsky); unlike surveillance occurs with awareness. Protections unsystematic (*Shelton*, *Baird*, ADA, evidentiary privileges); 5th narrow (use immunity; *Ullmann*; no parent–child privilege — Lewinsky).

B. Processing

Aggregation: "the whole becomes greater than the parts" (**portrait**); 1965 Federal Data Center/1974 FEDNET scrapped. Harms: upsets expectations (dignitary); **dossier / "digital person"** (architectural); distortion (reductive; → profiling/ADM). Law: ***Reporters Committee* 1989** (rap sheets; **practical obscurity**); but Megan's Law cases (*Russell*, *Paul P.*) = no justification offered, "no balancing took place".

Identification: HEW 1973 (SUI/SSN). Benefits: fraud ↓, accountability. **Not inherently demeaning**; harms: "**informational baggage**" (*B v France*; *Gattaca*), expressive identification (stigma), ↑ govt power (Soviet passports), **destroys anonymity** (Publius; *Talley*; *McIntyre*), *Hiibel* (Stevens: "A name can provide the key"). Harm = **linking marker to data stream**. India: Aadhaar. **Insecurity:** identity theft (≈2 yrs/200 hrs); law: *Whalen v Roe*, FIPs, statutes, liquidated damages (but *Doe v Chao*); courts reluctant (*Earls*). "**Insecurity is the injury of being placed in a weakened state.**" Links: GDPR Art 32/82; DPDP s 8(5) ₹250 cr. **Secondary use:** 1977 computer matching; HEW FIPs → **purpose specification**. Harms: thwarts expectations; resembles breach of confidentiality; Schwartz "asymmetry of knowledge"; fear/powerlessness; **architectural** (data out of context). Links: GDPR Art 5(1)(b); DPDP s 6(1), s 7(b) maternity illustration. **Exclusion:** FIPs (no secret systems; access; correct) → transparency & participation. **Architectural** (↓ accountability); "powerlessness and frustration". Law: fiduciary analogy (*Meinhard v Salmon*; *Moore*); GLBA opt-out fails. Links: GDPR Arts 13–16; **Srikrishna fiduciary**; DPDP s 11(2).

C. Dissemination

Breach of confidentiality: *McCormick v England*; no "highly offensive" requirement (disclosure tort = content; breach = **source/relationship**); "**victim has been betrayed**"; *Simonsen*, *Tarasoff*. **Third-party doctrine** (*Miller* 1976, *Smith* 1979) rests on secrecy paradigm; England's **breach of confidence** (*Campbell*†); India: *Carpenter*†. **Disclosure:** §652D; critics Volokh (censorship), Posner (concealment); Solove's justifications (autonomy, democracy, **security** — *Remsburg v Docusearch* [Amy Boyer murdered], distorts judgment, **"prisoner of recorded past"** → RTBF). Secrecy-paradigm cases: *Cefalu*, *Penwell*, ***Sipple*** (outed), *Duran*; contrast *Times Mirror*. **Strahilevitz:** harm = "spreading information **beyond expected boundaries**". **Exposure:** *DeMay v Roberts*, *NARA v Favish*; deeply primordial attributes; **not character**; dignity "ability to transcend one's animal nature" (Elias, Miller); no separate tort; *Graham* (dress) protected, *McNamara* (soccer player) not. **Increased accessibility:** "difference in quantity becomes difference in quality"; *Walls*; *Reporters Committee*. Link: **DPDP s 3(c)(ii)** public-data exclusion; *Google Spain*†. **Blackmail:** history; theories table (Posner, Anderson & Block, Brown, Epstein, Gordon [Kantian], McAdams) vs **Solove: POWER/domination** ("not in the disclosure… but in the control"); analogy to assault; *Hedda Gabler*. **Appropriation:** *Roberson* (Abigail, 25,000 flour ads) → NY §§50–51; §652C; rationales **dignity** (Bloustein) vs **property** (Prosser/right of publicity); **Solove: freedom & self-presentation** — *Pavesich* ("a slave"), Gray J. "unwanted notoriety", "**authorship of her self-narrative**", better word "**exploitation**". Links: deepfakes; Bachchan/Kapoor†. **Distortion:** defamation, **false light** (§652E), accuracy rights (FIPs, OECD, EU Directive Art 6). Reputation = "**currency through which we interact**" (Post); Iago in *Othello*.

D. Invasion

Intrusion: castle (*Semayne*), Cooley 1868, §652B; *Galella v Onassis*; spam/telemarketing; solitude critique (Aristotle) vs reply (Arendt, Thoreau, Montaigne); personal space in public (Altman, Goffman "territories of the self"; *Shulman*, *Stressman*, *Sanders v ABC*). **Decisional interference:** *Griswold*, *Eisenstadt*, *Roe*, *Pierce*; objection (Tribe/Henkin: autonomy); Solove: linked to disclosure (*Whalen*), insecurity, exposure, **intrusion** (*Botsford*, *Stanley*, *Lawrence*: "Freedom extends beyond spatial bounds"), blackmail. India: Puttaswamy, *Navtej Johar*, *Suchita Srivastava*†.

Conclusion: Prosser "far too narrow… out-of-date"; no common denominator; **privacy problems like pollution** (by-products); courts' pitfalls (public domain, public monitoring, public place, no intimate details, no new data); regulate **activities of people/businesses/govt** not technology. **Evaluation:** + pragmatic,

exposes secrecy paradigm, architectural harm fits GDPR, maps onto DP law (collection=minimisation; aggregation/ID=profiling; insecurity=security+breach; secondary use=purpose limitation; exclusion=transparency/access; distortion=accuracy; disclosure=RTBF). − no unifying theory; over-inclusive; "private matters" under-theorised; US-centric; consent; overlaps; dated; individual-harm framing.

---

4. Comparison, debates, exam skeletons

Mapping: Roessler *decisional* ↔ Solove decisional interference; *informational* ↔ collection/processing/dissemination; *local* ↔ intrusion/surveillance in private places; *democracy* ↔ architectural harm/constitutive privacy. **Debates:** (1) essence — unitary (W&B, Westin, Gavison, Roessler) vs reductionist (Thomson; Tribe/Henkin) vs pluralist (Solove) → **combine Solove (what) + Roessler (why) + proportionality**; (2) public/private; (3) privacy vs free speech; (4) dignity vs property vs liberty (Whitman's two cultures†); (5) individual vs social; (6) feminist critiques; (7) technology & law (AI lessons). **Applying Solove (technique):** Collection? Processing? Dissemination? Invasion? For each: dignitary/architectural? secrecy paradigm? balance. **Worked example:** Indian welfare app links Aadhaar to health/benefits data, shares with police → identification, aggregation, secondary use (DPDP s 7(b)–(c)), exclusion (s 11(2)), insecurity, decisional interference (chilling, *Whalen*), architectural → Roessler → Puttaswamy proportionality. **Likely Qs:** (1) "Concept in disarray" · (2) W&B inviolate personality vs property · (3) Solove taxonomy useful without theory? · (4) secrecy paradigm · (5) Roessler autonomy · (6) surveillance harmful even if covert/public? · (7) disclosure vs exposure vs breach · (8) value beyond individual. **Traps:** W&B not judges; "let alone" is Cooley's; **Prosser** made 4 torts; Solove = activities not "private things"; Solove **rejects Benn**; identification not inherently demeaning; **exposure ≠ disclosure**; blackmail = **power**; appropriation = freedom/self-presentation ("exploitation").

UNIT 1B — INDIA: PUTTASWAMY → SRIKRISHNA → JPC → DPDP 2022 → DPDP ACT 2023

(† = general knowledge, not in readings.)

0. Big picture

Date	Event
2000/2011	IT Act **s 43A** + **SPDI Rules 2011**†
Aug 2017	**Srikrishna Committee** constituted (MeitY memo 31 Jul 2017)
24 Aug 2017	***Puttaswamy***: 9-judge bench, **privacy fundamental right**
27 Jul 2018	Srikrishna report **"A Free and Fair Digital Economy"** + Draft PDP Bill 2018
Dec 2019	PDP Bill 2019 → JPC†
16 Dec 2021	**JPC report** → DP Bill 2021
Aug 2022	2021 Bill withdrawn†
18 Nov 2022	Draft DPDP Bill 2022†
3 Aug 2023	DPDP Bill 2023 (No. 113)†; Act assent **11 Aug 2023** (No. 22)†
Nov 2025	DPDP Rules 2025†; substantive duties from 13 May 2027 (per Unit 3 notes)

One-sentence story: *Puttaswamy* → State must build a DP law. **2018**: rights-heavy GDPR-like **fiduciary** model + strong regulator. **2021 JPC**: sovereignty/national security. **2022**: slim, business-friendly, **executive-controlled**. **2023**: tidier (legitimate uses, statutory Board, blacklist) but **broad State exemptions**, **RTI diluted**. **4 themes:** (1) who's protected against whom (State exemptions: 2018 s 42 → cl 35 → 2022 s 18 → 2023 s 17); (2) basis for processing (consent → non-consent grounds → deemed consent → legitimate uses); (3) enforcer (independent DPA → govt Board); (4) data flows (mirroring → whitelist → blacklist). **Terminology:** Data Principal = data subject · Fiduciary = controller · Processor · SDF (risk-based duties) · DPA/Board = supervisory authority · Consent Manager (none) · Sensitive/critical data = Art 9.

1. PUTTASWAMY (2017) 10 SCC 1 — 24 Aug 2017, 9 judges

Khehar CJ, Chelameswar, Bobde, Agrawal, Nariman, Sapre, **Chandrachud**, Kaul, Nazeer. **Bottom line:** unanimous: privacy = fundamental right, intrinsic to **Art 21** + **Part III**. *M.P. Sharma* (1954) and *Kharak Singh* (1964) majority **overruled**. Covers **informational privacy**; **State and non-State actors** (Kaul); **not absolute** — **legality, legitimate aim, proportionality**. **Reference:** began as **Aadhaar** challenge; 3-judge bench doubted (M.P. Sharma 8 judges, Kharak Singh 6); referring order 11 Aug 2015 ("denuded of vigour and vitality"). Chandrachud: "left alone in a core which is inviolable"; liberty "in an interconnected world". **Arguments:** Union (larger benches bind); **Haryana** (right "conceptually unsound"; only **DP legislation** can address); Centre for Civil Society (undefinable); **Petitioners**: "left alone" under-inclusive; inner sphere vs State and non-State; **4-part ECtHR test: sanctioned by law; necessary in democratic society for legitimate aim; proportionate; procedural guarantees** (= ancestor of proportionality in *Puttaswamy II* 2018 and *Anuradha Bhasin* 2020). **Irony:** State conceded DP law needed. **Six opinions:**

- **Chandrachud (plurality, + Khehar, Agrawal, Nazeer):** Gopalan "silos" overruled by *R.C. Cooper*/*Maneka Gandhi*; liberty and dignity; effect not object. **Para 66 (seven *Canara Bank***

points): privacy from Arts 19+21; grounded in *Kharak Singh*, *Gobind*, UDHR/ICCPR; **attaches to the person**; safeguards vs arbitrary search; Collector can't delegate; **reasonable expectation info used only for purpose** (purpose limitation); State may need data but no private entity access. † three-fold test (legality, legitimate aim, proportionality); overruled *ADM Jabalpur*.

- **Chelameswar:** tiered scrutiny — **repose, sanctuary, intimate decision**; "Definitional uncertainty is no reason…"; para 45 compelling State interest for strictest claims, else **just, fair and reasonable**.
- **Bobde:** precondition of freedoms; para 34 Arts 19(1), 20(3), 25, 28, 29; **future technology**; para 47 inalienable, Part III; Art 12.
- **Nariman:** 121 pages; para 54 three intrusions (**body, information, choices**); critique of *US v Miller*; Tribe "informational autonomy"; Right to Financial Privacy Act 1978; 2013 Necessary & Proportionate Principles; para 94.
- **Sapre†:** natural right, dignity, fraternity.
- **Kaul (technology):** para 12 "qua State and non-State actors"; para 13 profiling (GDPR Art 4(4)), Snowden; paras 16–19 **Uber/Facebook/Alibaba/Airbnb**, passive data, **"Knowledge about a person gives a power over that person"**, stultifying effect on dissent; para 20 BlackBerry; para 22 Orwell; para 69 RTBF; para 75 "**So there is hope!**" (Srikrishna); **para 77** inner sphere. **Holding†:** M.P. Sharma overruled; Kharak Singh majority overruled; privacy = Art 21 + Part III; *Gobind*, *Canara Bank* correct. **Why it matters:** foundation for all bills; purpose limitation & proportionality as benchmarks for State exemptions; horizontal reach; India has no separate DP right (privacy does the work).

2. SRIKRISHNA COMMITTEE (PRS summary, 1 Aug 2018)

Fiduciary relationship (individual depends → fair, authorised purposes). Duties: **fair and reasonable** processing; **notice**. **Sensitive data** (caste, religion, sexual orientation) → **explicit consent**. **Consent** precondition, informed; extra for children. **4 non-consensual grounds:** State welfare; law/court orders; prompt action; employment. **3 participation rights groups:** access/confirmation/correction; object/ADM/direct marketing + portability; RTBF. Independent **DPA**; **SDFs**. Law sets minimum standards; amend Aadhaar Act. (Draft Bill omitted general object/ADM rights.) **Why "fiduciary":** relationship of trust (Balkin†); consent central but limited; label survived into 2023, **substantive duties of loyalty did not**.

3. DRAFT PDP BILL 2018 (112 sections, 15 chapters)

Bottom line: GDPR-style; principles; **six grounds**; sensitive data; children; rights; accountability (**data trust scores**); **localisation**; DPA + adjudication wing; **4% fines**; compensation; **criminal offences**; State exemptions need **law + necessity + proportionality**.

- **Scope s 2:** extraterritorial (business in India / offering goods/services / **profiling**); anonymised excluded. **Definitions:** fiduciary incl. **State**; **child <18**; **Harm s 3(21) — 10 heads** (bodily/mental; identity; financial; reputation; employment; **discrimination**; blackmail; denial from **evaluative decision**; **fear of being observed**; **unexpected surveillance**); **SPD s 3(35) — 13 heads** (passwords, financial, health, official ID/Aadhaar, sex life, orientation, biometric, genetic, transgender, intersex, caste/tribe, religious/political belief, Authority-specified).
- **Obligations:** s 4 fair & reasonable · s 5 purpose limitation · s 6 collection limitation · s 7 lawful · s 8 notice (~12 items incl. **trust score**) · s 9 quality · s 10 storage · s 11 accountability.
- **Grounds:** consent s 12 (free/informed/specific/clear/withdrawable; **no conditionality** s 12(3); **burden on fiduciary**); State functions s 13; law/court s 14; prompt action s 15; employment s 16;

reasonable purposes s 17 (Authority-specified: fraud, whistle-blowing, M&A, security, credit scoring, debt recovery, public data).

- **SPD (ss 18–22): explicit consent**; State functions only "**strictly necessary**" (services/benefits, **not** licences); prompt action limited.
- **Children s 23:** under 18; age verification + parental consent; **guardian data fiduciaries** barred from profiling/tracking/targeted ads.
- **Rights:** access (summary) · correction · **portability** (incl. profiles) · **RTBF = restrict disclosure** via Adjudicating Officer (weigh free speech) · **no general object/ADM/erasure**.
- **Accountability:** privacy by design; transparency; security; **breach → Authority if likely harm** (Authority decides whether to tell users); **DPIA**; records (State too); **annual audits**; **DPO**; processors via valid contract; **SDFs**; grievance 30 days.
- **Cross-border:** s 40(1) **mirror copy** in India; s 40(2) **critical data only in India**; s 41 SCCs/adequacy/necessity (+ explicit consent for SPD).
- **Exemptions:** security of State s 42 (**Parliamentary law + necessary + proportionate**); crime s 43; legal proceedings s 44; research s 45; domestic s 46; **journalism s 47**; small entities s 48 (≤₹20 lakh; ≤100 principals/day).
- **DPA:** chair + 6; **CJI-led selection**; 5-year term, no reappointment, 2-year cooling-off; codes of practice; actions incl. suspend business/cross-border flows; **Adjudicating Officers**.
- **Penalties: ₹5 cr/2%** and **₹15 cr/4%** worldwide turnover; **compensation s 75** (class complaints; joint & several); Appellate Tribunal → SC. **Offences:** 3 yrs/₹2 lakh; SPD 5 yrs/₹3 lakh; re-identification; cognizable, non-bailable.
- **Misc: s 98** binding policy directions (independence concern); **s 43A deleted**; **RTI s 8(1)(j)** amended keeping harm-vs-public-interest.
- **Strengths/weaknesses:** comprehensive, Puttaswamy-style limits vs broad State function ground, no object/erasure/ADM, localisation cost, s 98.

4. JPC REPORT & DP BILL 2021

JPC chair **P.P. Chaudhary**; tabled **16 Dec 2021**; >2 yrs. Frame: **data as national asset** (AatmaNirbhar), national security; GDPR-compatibility. Primer: report "sets context and offers justification" for amendments. **Recs: 1** one law for **personal + non-personal** (can't separate); **2** 24-month phase; **5** non-intermediary social media = **publishers**; **8** IoT certification; **10 mirror copy** of SPD/critical data held abroad; **11** localisation policy (infrastructure, payment systems, start-ups, **tax data flows**, local AI); **38 72-hour breach**. **Changes 2019→2021: digital-only** (para 2.12); NPD in scope; **criminal penalties** (≤3 yrs/₹2 lakh; only on Authority's complaint; directors only if knowledge); localisation (SPD stored in India; **critical only in India**; DPA approval); accountability (**FAT of algorithms**, DPOs, PbD); social media (verify users; parent office in India; statutory media regulator); 24 months; no localisation timeline. **Critique:** scope creep; digital-only narrower than GDPR; sovereignty/protectionism; criminalisation (dropped later); social media mixes content regulation; **cl 35 exemption retained** (dissent: Ramesh, O'Brien, Tewari†). Positives: 72h, DPO, PbD, FAT.

5. DPDP BILL 2022 (30 sections, 6 chapters, 1 Schedule)

Bottom line: radical slim-down. **Drops** SPD, critical data, localisation, NPD, criminal offences, independent DPA, portability, RTBF, harm architecture. **Introduces deemed consent**, **duties of Data Principals**, govt-designed **Board**, **whitelist**, **civil penalties ≤₹500 cr**, "her/she", digital-by-design Board. Heavy delegation + broad State exemptions. **Purpose:** balance right vs need to process.

- **Definitions:** harm only **4 heads**; person incl. State; personal data "identifiable by or in relation to"; breach (CIA); processing = automated, digital; **public interest** incl. "**false statements of fact**" (novel/controversial). **s 3:** Rules = Act; 22 languages; "her/she". **s 4:** digital data (online / offline-digitised); extraterritorial **offering or profiling**; excluded: non-automated, offline, domestic, **≥100-year records**.
- **s 5:** "lawful purpose" = **not expressly forbidden**; only **consent** or **deemed consent**. **s 6 notice:** itemised **data + purpose only** (thin vs 2018).
- **s 7 consent:** free/specific/informed/unambiguous; invalid parts void; withdraw any time **as easy**, "consequences borne by principal"; processors stop; **Consent Managers** (DEPA/AA); **no bundling** (concluded contract); burden on fiduciary.
- **s 8 DEEMED CONSENT (9 situations):** voluntary + reasonably expected; **State functions "any function under any law"**; judgments/orders; medical emergency; epidemic; disaster; **employment** (incl. biometric attendance); "**public interest**" (fraud, M&A, security, **credit scoring**, search engines, public data, debt recovery); **fair & reasonable prescribed purposes** (≈ legit interests). **Critique:** legal fiction; consent rights confusion; too broad for State; no balancing.
- **s 9:** accountability **"irrespective of any agreement"**; accuracy (reasonable efforts); security **₹250 cr**; **breach to Board AND each principal, no threshold/timeline** ₹200 cr; storage limit (**"legal or business purposes" loophole**); valid contract/sub-processors.
- **s 10 children:** verifiable parental consent; no harm; **no tracking/behavioural monitoring/targeted ads**; ₹200 cr.
- **s 11 SDF:** Central Govt notifies; factors incl. electoral democracy; DPO in India, auditor, DPIA; ₹150 cr.
- **Rights ss 12–16:** information ("in one place"), correction & **erasure** (new), grievance (7 days, exhaust first), **nomination**, **s 16 DUTIES** (₹10,000; costs on complainants) — **inverts rights framework**. **Absent:** portability, RTBF, object, ADM, restriction.
- **s 17 transfer = WHITELIST**; no criteria; no localisation. **s 18 exemptions:** (1) legal claims/courts/**crime ("any contravention of any law")**/outsourcing (security s 9(4) kept); (2) **Central Govt notification** exempts State instrumentalities from **any/all** provisions (no law, no proportionality) vs 2018 s 42; (3) classes (start-ups); (4) **State exempt from storage limitation**. **No journalism exemption.**
- **Board ss 19–25:** by Central Govt notification; composition by Rules; **adjudicatory only**; no suo motu; can't seize equipment affecting day-to-day business; appeal **High Court 60 days**; ADR; **voluntary undertaking** (bars proceedings); **₹500 cr per instance**, **no compensation**; Schedule: ₹250/200/200/150 cr, ₹10,000, ₹50 cr.
- **Misc:** Rules; Schedule cap 2×; removal of difficulties **5 yrs**; **s 43A omitted**; **RTI 8(1)(j)** override + proviso deleted.
- **Criticisms (12):** deemed consent; executive dominance (~20+ "as may be prescribed"); State exemptions; no SPD; reduced rights + duties; no compensation; RTI; narrow harm; breach notification fatigue; "false statements" censorship; weak transfer criteria; no independent regulator.

6. DPDP BILL 2023 → ACT (44 clauses, 9 chapters)

Bottom line: keeps 2022 skeleton; **legitimate uses** replace deemed consent (public interest & "fair and reasonable" dropped; some become exemptions); **blacklist**; **public data excluded** (s 3(c)(ii)); statutory Board (govt-appointed, **2-yr** terms); appeals to **TDSAT**; **blocking (s 37)** + **call for information (s 36)**; "verifiably safe" age relaxation (s 9(5)); start-up exemption (17(3)); **5-yr exempt-anyone (17(5))**; **RTI gutted**. Introduced by **Ashwini Vaishnaw**; passed by **voice vote, no committee**†.

- **Definitions:** TDSAT; Consent Manager **registered with Board**; principal incl. **guardian of person with disability**; processing "wholly or partly" automated; State = Art 12; **"harm" & "public interest" removed**. **Cl 3:** extraterritorial **goods/services only** ("profiling" dropped); excludes **personal/domestic** and **publicly available data** (by principal or legal obligation) → **scraping/AI training**.
- **Cl 4–6:** consent or legitimate uses. **Cl 5 notice** + how to exercise rights/complain; **legacy consent continues until withdrawal**. **Cl 6 consent:** "free, specific, informed, **unconditional**, unambiguous"; **limited to necessary data** (telemedicine illustration); consequences borne by principal (e-commerce illustration).
- **Cl 7 LEGITIMATE USES:** (a) voluntary + no objection; (b) State benefits (prior consent or notified database; maternity illustration = **purpose creep**); (c) State functions/sovereignty; (d) legal disclosure to State; (e) judgments (incl. **foreign civil**); (f) medical emergency; (g) epidemic; (h) disaster/public order; (i) employment. **No general legitimate-interests ground.**
- **Cl 8:** accountability; valid contract; accuracy; **security ₹250 cr**; **breach intimation ₹200 cr** (no threshold/timeline); **erasure on withdrawal / purpose served unless law** (business loophole removed; **inactivity lapse**).
- **Cl 9:** parent/guardian consent; "detrimental effect on well-being"; **no tracking/targeted ads**; **(5) "verifiably safe" age relaxation**; ₹200 cr. **Cl 10 SDF:** ₹150 cr.
- **Rights: Cl 11 access** (summary + recipients **and processors**) **only vs consent-based processing**; law-enforcement sharing hidden. **Cl 12** correction/erasure (State exempt). **Cl 13** grievance (exhaust first). **Cl 14** nominate. **Cl 15** duties ₹10,000.
- **Cl 16 BLACKLIST** (default open); **sectoral localisation survives (RBI)**.
- **Cl 17:** (1) adds **regulators**, **M&A schemes**, **loan defaulters**; **(2)(a) Act does not apply at all** to notified State instrumentalities (and Centre's processing of their data); (3) start-ups; (4) State exempt from erasure; **(5) 5-yr power to exempt any fiduciary from any provision**.
- **Board cls 18–28:** Chair + members as Centre notifies; **appointed by Centre**; ≥1 legal expert; **2 years, re-appointable**; removal by Centre ("moral turpitude in opinion of Central Government"); 1-yr cooling-off; staff need approval; adjudicatory only.
- **Cl 29 TDSAT** 60 days / 6 months → SC; **cl 32** undertaking; **cl 33–34** penalties to Consolidated Fund, **no compensation**; Schedule (₹250/200/200/150 cr; ₹10,000; undertaking breach; ₹50 cr); cl 42 cap 2×.
- **Cl 35–44:** immunity; **36 call for information** (Notes on Clauses misdescribe); **37 blocking** after penalties in **2+ instances** (≈ IT Act 69A); 39 civil courts barred; **40: 26 rule-making matters**; removal of difficulties **3 yrs**; **44(2) s 43A omitted**; **44(3) RTI s 8(1)(j) → "information which relates to personal information"**. Budget **₹25 cr + ₹10 cr/yr**.

2022 → 2023 (high-yield)

Issue	2022	2023
Non-consent	Deemed consent	**Legitimate uses**; public interest/"fair & reasonable" dropped
Public data	Inside (deemed consent)	**Outside Act**
Extraterritorial	Goods/services **or profiling**	**Goods/services only**
Harm / public interest defs	Present	**Removed**
Notice	Data + purpose	+ how to exercise rights/complain

Issue	2022	2023
Consent	Free, specific, informed, unambiguous	+ **unconditional**, **necessary data**
Retention	Legal **or business**	**Legal only**; inactivity lapse
Children	<18	+ **verifiably safe** relaxation; disability
Info right	Confirmation, summary, recipients	Summary + recipients/processors; **consent-based only**
Transfer	**Whitelist**	**Blacklist**
Exemptions	Notification	+ regulators/M&A/defaulters; **17(5)**
Board	Rules	Statutory, govt-appointed, 2-yr
Appeal	**High Court**	**TDSAT**
Penalty	₹500 cr per instance	Schedule only
Govt powers	—	**s 36, s 37**
RTI	Override deleted	**Replaced**
Removal of difficulties	5 yrs	3 yrs

FOR: SARAL; Puttaswamy mandate; GDPR-like consent; Consent Managers; child protection; high penalties; pro-innovation; honest relabelling; Art 19(2) grounds, judicial review. **AGAINST:** executive overreach; fails proportionality; weak rights/duties on individuals; no SPD; public data excluded; RTI/journalism; weak Board/TDSAT/budget; no harm approach; children age-gating; no compensation; process (no JPC, voice vote); extraterritorial gap.

7. MASTER COMPARISON (2018 | 2021 | 2022 | 2023 | GDPR)

Issue	2018	2021†	2022	2023	GDPR
Framing	fundamental right; fiduciary	national asset	balance	same	fundamental right + free flow
Data	incl. manual	PD+NPD, digital only	digital	digital; public excluded	automated or filing system
SPD	**Yes**	Yes	**No**	**No**	Art 9
Harm	10 heads	—	4	removed	risk-based
Grounds	consent + 5	similar	consent + deemed	consent + legit uses	6 bases
Notice	~12 items	—	data+purpose	+rights/complaint	Arts 13–14
Children	<18	—	<18	+ safe relaxation	13–16
Duties on individuals	No	—	**Yes**	**Yes**	No
Breach	to DPA if harm	**72h**	Board + all	same	72h/risk
SDF by	**DPA**	—	**Govt**	Govt	n/a
Transfer	mirror/critical; contracts	stronger	**whitelist**	**blacklist**	adequacy/SCCs
State exemption	**law + necessity + proportionality**	cl 35	notification	notification + 17(5)	Art 23 legislative
Journalism	yes	—	no	no	Art 85
Regulator	DPA, CJI-led, 5 yr	—	Board (Rules)	Board govt-appointed 2 yr	independent (Art 52)
Appeal	Tribunal→SC	—	**High Court**	**TDSAT**	courts

Issue	2018	2021†	2022	2023	GDPR
Penalties	₹5cr/2%, ₹15cr/4%	same	≤₹500 cr/instance	≤₹250 cr	€10m/2%, €20m/4%
Compensation	**Yes**	Yes	**No**	**No**	Art 82
Criminal	Yes	**Yes**	No	No	Art 84
RTI 8(1)(j)	harm vs interest kept	—	override deleted	**replaced**	n/a
Extraterritorial	business/profiling	—	goods/services or profiling	goods/services only	goods/services or monitoring

The arc: rights-based (2018) → sovereignist (2019–21) → minimalist (2022) → pragmatic consolidation (2023); constant = **broad State exemptions** vs proportionality. **13 DPDP vs GDPR differences:** legal bases; SPD; rights only consent-based/no portability, objection, restriction, ADM; **duties on individuals**; regulator independence (Art 52); penalties fixed vs %; compensation; public data; transfers (blacklist vs adequacy); State exemptions (legislation+proportionality vs notification); children (18, flat ban on ads/tracking); breach (all vs risk-based); Consent Managers.

8. Debates, exam Qs, cheat sheet

Debates: (1) consent vs fiduciary accountability; (2) State as fiduciary (Puttaswamy: legality, legitimate aim, proportionality, procedural safeguards; govt: Art 19(2), judicial review, IT Act s 69/Telegraph s 5; against: no surveillance reform, State largest processor, **s 7(b)–(c)** asymmetry); (3) localisation (for: MLATs, security, economy, sovereignty; against: cost, trade friction, splinternet, surveillance); (4) regulator independence; (5) delegated legislation; (6) RTI/free speech/no journalism exemption; (7) children (18 vs evolving capacities); (8) consent in India; (9) NPD. **Likely Qs:** Puttaswamy→2023 · deemed consent vs legitimate uses · State exemptions vs Puttaswamy · 2018 vs 2023 regulators · localisation · DPDP vs GDPR · fiduciary vs notice-and-consent · children · Puttaswamy sources/limits · duties on individuals. | Item | Value | |---|---| | Puttaswamy | 24 Aug 2017; 9 judges; 6 opinions | | Srikrishna | Aug 2017; report 27 Jul 2018; 4 non-consent grounds; 3 rights groups | | 2018 DPA | chair + 6; ≥10 yrs | | JPC | P.P. Chaudhary; 16 Dec 2021; recs 1,2,5,8,10,11,38 | | 2022 | 30 sections, 6 chapters; ₹500 cr; High Court; 7 days | | 2023 | Bill 113; 44 clauses, 9 chapters; Schedule ₹250/200/200/150 cr, ₹10,000, ₹50 cr; Board 2-yr, 1-yr cooling-off; TDSAT 60 days/6 months; ₹25 cr + ₹10 cr; 17(5) 5 yrs; s 37 two instances | **Traps:** 2022 = sections/deemed consent/whitelist/High Court; 2023 = clauses/legitimate uses/blacklist/TDSAT; SDF by DPA (2018) vs Centre (2022/23); JPC 72h didn't survive; criminal only 2018 & 2021; erasure right only 2022/23; public data inside (2022) vs outside (2023); Notes on Clauses misdescribe cls 36/37; 2022 Schedule items 2&3 both ₹200 cr.

UNIT 2 — PRIVACY, CONSENT & GDPR: THE 15 READINGS (condensed)

Source: your "Readings — essay-ready summaries" PDF (R1–R15). R1–R7 = mandatory (Part A), R8–R11 = recommended (Part B), R12–R15 = further (Part C). Each reading below: what it is → argument → method/numbers → key concepts → criticisms → links. This file is Part 1 (R1–R3). Parts 2–4 are in the other UNIT2 files.

THE BIG DEBATE THAT TIES UNIT 2 TOGETHER

Can notice-and-consent be saved? Three camps appear across the readings: | Camp | Position | Readings | |---|---|---| | **Fix the form** | Enforce consent that's active, specific, informed; design banners fairly | *Planet49*, Santos et al., Lindegren et al. | | **Fix the content / reader** | Make policies fully comprehensive; let LLMs/tools do the reading | Pałka et al., Pardo & Le Métayer (Pilot) | | **Change the architecture** | Don't hand data over at all; computation goes to the data | Najdi et al. | | **Law + design + tech are complementary** | Art. 25 GDPR (data protection by design & default) is the bridge | Exam-winning conclusion | Counterweights: McDonald & Cranor (reading costs too high → self-regulation fails), Dove & Chen (consent isn't always the right lawful basis), Custers & Vrabec (rights don't reach inferences).

R1. *PLANET49* (C-673/17) — CJEU Grand Chamber, 1 Oct 2019

One sentence: consent to cookies via a **pre-ticked checkbox is not valid**; applies whether or not the cookie data is personal; users must be told **how long cookies operate** and **whether third parties can access them**.

Procedure: preliminary reference under **Art. 267 TFEU** from the German Federal Court of Justice (*Bundesgerichtshof*). Advocate General **Szpunar** (Court followed him on key points). ECLI:EU:C:2019:801.

Facts: Claimant = **Bundesverband der Verbraucherzentralen** (German consumer federation). Defendant = **Planet49 GmbH**, online gaming company. 24 Sept 2013 promotional lottery on dein-macbook.de. Users entered postcode, name and address, then saw **two checkboxes**:

1. **Not pre-ticked** — consent to sponsors/cooperation partners contacting by post/phone/email/SMS. Link opened list of **57 companies** each with "Unsubscribe"; if not unsubscribed from enough, Planet49 would pick up to **30 partners** itself. **Ticking was a condition of entering the lottery.**
2. **Pre-ticked** — consent to web analytics service **Remintrex**: cookies on device to track surfing/advertising partners' sites for interest-based advertising. Cookie held a **random ID linked to name and address** → personal data. Federation sued in Frankfurt (injunction + EUR 214). Regional court upheld in part; **Higher Regional Court (OLG) said pre-ticked claim unfounded** (user could untick; text clear). Federation appealed on point of law (*Revision*) → BGH referred to CJEU.

Legal framework:

- **Art. 5(3) ePrivacy Directive 2002/58** (as amended 2009/136): storing/accessing info in "terminal equipment" only if user has given consent after "clear and comprehensive information". Exceptions: technical storage solely for transmission; strictly necessary for a service the user **explicitly requested**.
- ePrivacy doesn't define consent → **Art. 2(f)** points to old **Directive 95/46 Art. 2(h)**: "freely given specific and informed indication of his wishes". **Art. 7(a)**: "unambiguously". **Art. 10**: info "at least" (identity, purposes, recipients).
- **GDPR Art. 4(11):** "freely given, specific, informed and unambiguous… by a statement or by a **clear affirmative action**". Art. 6(1)(a) consent as lawful basis. **Art. 7(4):** "utmost account" of whether service conditional on unnecessary consent. **Recital 32:** consent by clear affirmative act, e.g. ticking a box; "**silence, pre-ticked boxes or inactivity should not constitute consent**".
- **Questions:** (1) Does a pre-ticked box the user must deselect give valid consent (and does it matter if data is personal)? (2) What "clear and comprehensive information" is required, incl. **cookie duration** and **third-party access**?
- **Temporal point:** GDPR applied from **25 May 2018** (after reference), but injunction concerns future conduct → GDPR applies *ratione temporis*; Art. 94 GDPR repeals Directive 95/46, references read as to GDPR. Court answered under **both**.

Reasoning on pre-ticked boxes:

- **Autonomous and uniform interpretation** of EU terms (*SM Algerian kafala*, *Tarola*), in light of wording, objectives, context, origins (*Wightman*).
- **Wording:** Art. 5(3) requires user "has given" consent → action needed; Recital 17 mentions "ticking a box when visiting a website".
- **Context:** Art. 2(h) "**indication**" implies **active not passive** behaviour (AG Szpunar). A pre-ticked box involves no active behaviour. **Art. 7(a) "unambiguously"** — Art. 7 is **exhaustive** list of lawful grounds (*ASNEF*, *Breyer*) so only active behaviour qualifies.
- **Evidential argument:** impossible to know objectively whether user who didn't untick actually consented or was informed (may not have read text or noticed box) → passive behaviour is ambiguous.
- **Legislative history:** original Art. 5(3) gave a "**right to refuse**" (opt-out); Directive 2009/136 replaced with "has given consent" → no more presumption.
- **"Specific":** must relate to the processing in question, not inferred from wishes for another purpose → clicking to enter the lottery ≠ consent to cookies.
- ***A fortiori* under GDPR:** Art. 4(11) "even more stringent"; Recital 32 expressly rules out pre-ticked boxes.
- **What the Court did NOT decide:** whether making consent to advertising a **precondition of entering the lottery** (first checkbox) is compatible with "freely given" under Art. 7(4) — **the coupling/bundling issue** (not referred). **Strong exam point.**

Personal data or not? On facts it was personal data, but Court answered anyway: Art. 5(3) refers to "storing of information" and "gaining access to information already stored" — **not limited to personal data**. Protects user's **private sphere** (Recital 24: terminal equipment is part of private sphere protected by ECHR; spyware, web bugs, hidden identifiers). ePrivacy protects **integrity and privacy of the device** — broader than data protection.

Information required: "clear and comprehensive" = info allowing user to **easily determine consequences of any consent** and ensuring it's well informed; clear, detailed enough to understand how

cookies function. For advertising cookies: **duration** (Art. 10 "at least" → non-exhaustive; long/unlimited duration = lots of info on surfing/visit frequency; GDPR Art. 13(2)(a) storage period) and **third-party access** (= "recipients or categories" under Art. 10(c)/Art. 13(1)(e)).

Three rulings: (1) Consent under Art. 2(f)/5(3) ePrivacy read with Art. 2(h) Dir 95/46 and Arts 4(11), 6(1)(a) GDPR is **not validly constituted by a pre-checked box** the user must deselect. (2) No difference whether data is personal or not. (3) Information must include **duration of cookies** and **whether third parties may have access**.

Why it matters / links: sets the **legal floor** — consent must be **opt-in, active, specific, informed**. Santos et al. cite it for "unambiguous indication through clear affirmative action" (unmarked "X" is ambiguous) and "informed of consequences" (careful: Court said "consequences of any consent he or she might give", not "consequences of refusing"). Links to **Pałka** (individuals rational; costs of self-management > expected losses → collective bodies like the Federation), Pilot, scoping review. **Critique:** "***Planet49* regulates the click, not the choice architecture around it.**" Users can still click "Accept" without reading; dark patterns satisfy it formally; bundling left open; says nothing about design manipulation. Conclusion: cookie consent in EU is **formally stronger but practically weak** without design rules and enforcement; **browser-level consent** one fix. Law works *after the event* and depends on detection and proof → **law, design, technology are complementary**.

R2. SANTOS, GRAY, BIELOVA & AHUJA (2026) — "Usable and lawful: can consent be both?"

Argument: lawful **and** usable consent is achievable when **design improves understandability and ease without unjustifiably steering users or breaking their trust**. Uses **heuristic evaluation** to link legal requirements to usability.

Problem:

- GDPR + ePrivacy: any website must get valid consent from EU users before tracking: **freely given, specific, informed, unambiguous, revocable, "readable and accessible"** (Arts 4(11), 7).
- Cookie banners are often built with **dark patterns**: design choices that "supplant user value… in favor of shareholder value" by psychological/behavioural/perceptual tricks (Gray et al.; Mathur et al.). Codified in EU law 2023 by the **Digital Services Act Art. 25 + Recital 67**.
- **Usability** (ISO 9241-11:2018) = "extent to which a system can be used by specified users to achieve specified goals with **effectiveness, efficiency and satisfaction** in a specified context of use". No universal standard for consent UI. Law has usability-like demands: **Art. 12 GDPR** ("concise, transparent, intelligible and easily accessible form, using clear and plain language"); **Art. 7(2) + Recital 42** ("readable and accessible").
- **Gap:** EDPB mentions usability only for icons/dashboards; UK ICO warns desktop banner may be unusable on mobile; Johansen derived 30 usable privacy goals from GDPR (not about consent); Habib/Cranor proposed 7 requirements for usable consent but didn't align with EU law or apply inspection methods. **Nobody had systematically used an HCI usability-evaluation method to argue for consent that is both usable and lawful.**

Method: heuristic evaluation (Nielsen & Molich 1990) = experts check interface against principles to find usability "bugs". Used **evaluatively** (find defects in existing designs) **and generatively** (imagine new ones) — **bi-directional**: usability → law (map each heuristic to consent requirements and banner designs)

and law → usability (start from doctrine, case law, DPA decisions, guidelines to anticipate undeployed designs). Uses EDPB concept of **UX / user journey**. Only **3 of Nielsen's 10 heuristics** (richest outcomes; limitation): **A match between system and real world; B visibility of system status; C user control and freedom.** Legal materials: binding (GDPR, ePrivacy, case law, DPA decisions) and non-binding (recitals, EDPB/WP29 guidelines, user studies). Interdisciplinary team (law, CS, design, HCI) discussed a shared spreadsheet over months. Result: **10 design choices (3 under A, 4 under B, 3 under C)**.

Heuristic A — match with real world ("speak the users' language")

- **A.1 The box with an "X"** ("**Unmarked X**", Soe et al.). "X" usually means close, not consent/refuse. Low-level requirement: **affirmative action design**. Three lines: (1) UI must unambiguously indicate acceptance — *Planet49*, WP29 Opinion 15/2011, EDPB Guidelines 05/2020; Recital 32 allows "another statement or conduct which clearly indicates acceptance", WP208 "no limits as to the form consent can take" provided clear. (2) **DPAs: "X" OK if explained** — Spanish AEPD (explain less obvious actions); French CNIL (closing window can signal refusal if clearly indicated); Italian Garante (top-right "X" should close banner without consent, keep defaults, with warning); Latvian DPA ("X" = visual sign of closing). (3) **Authors' own: "X" is ambiguous and should mean "Not yet"** — neither accept nor reject. Bouma-Sims et al.: UK/US users who closed banner with "X": **24.0%** expected no cookies, **17.2%** expected some or all enabled. *Evaluatively:* unmarked X ≠ unambiguous consent. *Generatively:* make "Not yet"; if used as rejection, wording/framing must be tested.
- **A.2 Colours of accept/reject.** Accept bright, reject dull (Facebook blue "Accept everything" vs grey essential-only). **Traffic-light bias** (green go, red stop; UK House of Lords recommended traffic-light privacy policies); brand colours push **path of least resistance**. Legal hook: unambiguity + low-level "**balanced choices**" (fairness, transparency, protection by default: Arts 5(1)(a), 25(2)) → accept/reject equal in size, tone, location, contrast. EDPB Cookie Banner Taskforce (17 Jan 2023): can't impose colour standards; checks case by case. Dark pattern: "**Hidden in Plain Sight**". **Conflicting DPA decisions:** Danish DPA 2022 (*JP/Politikens Hus*): green "Accept all", red "Only necessary", grey "Customize" = "guiding", incompatible with Art 5(1)(a); Belgian DPA 113/2024 (*Mediahuis*): prominent "agree and close" vs light-grey alternatives "undoubtedly lead"; but Belgian 161/2023: controller decides, could make "refuse all" more attractive; Spanish DPA 2023/2024 colours misleading; **German court LG Passau (9 Apr 2024): blue "Allow all cookies" does NOT breach Art 25(2)** (common visual highlight, not default); **Austrian DPA (Oct 2024): buttons must be equivalent in colour, size, contrast, placement, emphasis.** Empirics: Gray "**aesthetic manipulation**"; **Utz et al. 57.4%** of banners steered users to accept by highlighting accept; ad-funded sites more often "concealed" reject by matching branding; Bravo-Lillo: salient fields help only if they match mental models.
- **A.3 Match between UI and what site does.** Users expect browser to store exactly what they chose, nothing if nothing chosen. **Matte et al.:** consent stored before the user chose on **141 of 1,426** websites; "accept" stored after user **rejected** on **27 of 560**; **Bollinger et al.:** trackers set despite refusal. Non-necessary trackers (Google Analytics) declared "necessary" (Mejtoft; Bollinger) = dark pattern "**sneak into basket**". Legal hook: "**correct consent registration**" (**Art 7(1)** — controller must demonstrate consent). Violations: (i) consent not registered on first visit → pressure on later visits (CNIL: keep choices; Italian DPA: repeated banners after refusal = "**nagging**"; ask again only if can't know choice stored e.g. cookies deleted, and ≥**6 months** passed); (ii) banner says "necessary" but non-necessary processing happens (Spanish DPA v *Vueling*). **CMPs (consent management platforms)** store consent → errors from site or CMP; hard to tell mistake from

deliberate. *Generatively:* **consent in the browser interface** (errors sit with a few tens of browser vendors not millions of sites; **draft ePrivacy Regulation Art. 10**). Risk groups: low tech literacy, lower socioeconomic status, children.

Heuristic B — visibility of system status ("keep users informed… What can I do? What happened when I interacted?")

- **B.1 Visibility of the consent request** — at extreme a **consent wall** (blocks site until accept/refuse). Engages "readable and accessible" (Art 7(2)) and "freely given" (7(4)); request must be clearly distinguishable (7(1)–(2)), may interrupt but **not unnecessarily disruptive (Recital 32)**. Gray et al.: consent walls = dark patterns "**forced action**" and "**obstruction**"; Leenes: request may need to interrupt to be effective. Danish DPA: "right balance"; Italian DPA: banner big enough to perceptibly interrupt browsing. Behavioural research split: disruption obstructs freedom of choice (Sunstein) vs reflective patterns and **friction** (deliberate obstacles slowing users) help reason (Terpstra); Habib: without a full wall many keep browsing without deciding. **Synthesis: friction is a necessary, not excessive, burden of informed consent**; mobile worse.
- **B.2 Visibility of choice status.** Users get no feedback after choosing (Kulyk: want confirmation). Hook: accessibility within "readable and accessible" (EDPB: data subject shouldn't have to seek out settings); teleological reading extends to visibility of choices already made; EDPB best practice "**Data Protection Onboarding**"; Feng et al.: systems treat consent as one-time/sequential but decisions are dynamic. *Generatively:* record, update, give feedback over time (on demand, periodic, just-in-time, at setup) without **privacy fatigue**; dashboard = high "fixing effort" but big market impact; some CMPs have persistent revocation icon.
- **B.3 Visibility of tracking status.** Users want to see which identifiers are set, by whom, purpose, duration; "**feedforward**". Extensions (**Disconnect, Ghostery**) count trackers but miss many; server-side tracking harder. Link to informed consent only tangential (Recital 60, Art 13, WP29 distinguish necessary info vs further info for fair processing; tracking status = latter). **Four challenges:** interfaces not usable; flawed mental models; more technical knowledge confuses users and worsens threat appraisal (Strycharz); tracker purposes rarely map onto legal purposes. Preconditions: trackers grouped into meaningful categories and blocked per category not per company; users can install/configure/use tool with persistent indicators.
- **B.4 Visibility of consequences. Bielova et al. large-scale experiment:** highlighting negative consequences of accepting **increased refusal up to 3 times**, high satisfaction. Two kinds: broken/less desirable experience after refusing; scope and risks of collection. Links: informed consent/transparency (Art 5(1)(a)), **Recital 39** (awareness of risks), *Planet49*, ***CNIL v Google* (2019)** (users must understand specific consequences so not caught off guard); EDPB best practice "Explaining Consequences" neutrally. **Counter-arguments:** information overload; Leiser: little evidence transparency reduces agreement, raises transaction costs; Bielova: banner text doesn't affect decisions; Weatherill: disclosure in flawed bargaining environment may legitimise pernicious practice; Strycharz: legal knowledge empowers but lowers threat appraisal — "**control paradox**" (more control → more sharing); Borberg: users dismiss notices as annoyance. Synthesis: critical of law and design — both assume informed, rational, deliberate user; need choice-architecture cues without cognitive load (extra consequence text opens room for dark patterns like over-choice, long policies). Heuristic B rests on "more knowledgeable consumers are more empowered" but puts onus on data subject.

Heuristic C — user control and freedom ("clearly marked emergency exit", easy undo)

- **C.1 Yes / No / "Not yet"** triad. Hook: **revocability — Art 7(3)** (withdrawal as easy as giving), **Recital 42** (consent not free if person can't refuse/withdraw without detriment); Italian DPA supports "X" with warning defaults remain. Risk: **choice overload** (Iyengar & Lepper) → demotivation/postponement. Caveat: "Not yet" must not allow sites/CMPs to ask on every revisit → regulators set timeframe or number of visits. *Generatively:* add "Not yet" to consent walls with reminders or standard navigation element.
- **C.2 Dashboards and icons.** Dashboards manage preferences after first choice (UK ICO); icons convey info quickly across languages/cultures. No high-level requirement; low-level: configurable banner with granular options incl. rejection. EDPB: just-in-time notices, hover text, dashboards, icons; **Irish DPC**: easy tool (radio button) to vary consent anytime; **Italian DPA**: footer link "Change your mind on cookies" + contest producing free CC BY 4.0 icon sets; **Art 12(7) GDPR** standardised icons; **CNIL**: "cookie" icon bottom left on every page. Icons should sit outside main reading flow but stay visible with text (Habib).
- **C.3 User-focused language.** Facebook negative example: "accept everything" (what's "everything"?) vs "manage data definitions" (meaningless). Hook: "readable and accessible" → request must be intelligible to "**average member of the intended audience**" (WP29, Spanish DPA), purposes with "**shared common understanding**" (WP29 Op 03/2013); clear plain language = concrete definitive wording without ambiguous terms/legalese (EDPB); ***CNIL v Google* (2019)** meaningful choice given info architecture. Imprecise language can manipulate: dark pattern "**false hierarchy**", "aesthetic manipulation"; yet "**there is no such thing as a neutral design**" (Acquisti et al.), manipulation is context-dependent (Rudinow; Raz). *Generatively:* familiar accessible language, but fully neutral state may be impossible.
- **Paper's most striking legal idea:** "Not yet" implies a new potential legal **"right to be ambivalent"** — users have only had right to accept or reject with same ease; they should also be free "**to decide, or not to decide**".

Results: 3 groups of the 10 design choices

- **Opportunities** (usability + law aligned): "X" reinterpreted as "Not yet" (A.1), consent in browser (A.3), visibility/management of choices over time (B.2), "Not yet" option (C.1), dashboards & icons (C.2).
- **Challenges** (aligned but hard for users): tracking status (B.3), consequences (B.4) — technical capacity, overload, "one size fits all" doubts; user-focused language (C.3) — content-based dark patterns.
- **Tensions** (misaligned): **colours (A.2)** — traffic light is usable real-world convention but conditions automatic acceptance, vs balanced choices/fairness; **visibility of consent request (B.1)** — heuristic followed but friction meaningful or obstructive vs "freely given".
- **Friction:** Guggenberger's *Consent as Friction* — friction preserves consent's warning function, enables deliberation, undermines economics of surveillance advertising → DPAs may insist. Macro fix: banners are a secondary task (Cranor) → system-wide automated consent via **browser settings** reduces requests and eases "freely given" tension while keeping visibility.
- **Usability vs dark patterns overlap:** colour steering (A.2) = "hidden in plain sight", "aesthetic manipulation", "visual prominence"; UI-behaviour mismatch (A.3) = "sneak into basket". Poor

usability often intentional but a usable design can still be a dark pattern (e.g. confirmshaming in user-focused language).
- **5 evaluative stances and 7 generative identifications** across the ten choices. Addressed to scholars, regulators, banner designers, CMPs.

Strengths: genuinely interdisciplinary; turns vague standards ("intelligible", "balanced") into **inspectable design properties**; generative as well as critical. **Limits (some admitted):** only 3 of 10 heuristics; expert reasoning over months, **no new user testing**; no concrete **validated** designs; relies on DPA decisions that **contradict each other** (esp. colours); heuristic evaluation inherently subjective; leans on others' user studies. **Deeper critique:** assumes a **rational, informed user**, undermined by its own sources (**privacy paradox**, **control paradox**) → links to Pałka: real problem = **cost of self-management**, to be reduced or shifted to collective bodies like consumer associations. **Links:** *Planet49* — banner design routinely falls below the floor it sets (judgment regulates click, not choice architecture). Santos = "**fix the form**" camp. Provides evidence for **both sides of friction debate**; offers "Not yet", browser-level consent, regulator-set re-ask intervals. **No neutral design + dark patterns persist → design alone not enough; law, design and technology complementary, with Art. 25 GDPR as bridge.**

R3. PAŁKA, LAGIOIA, LIEPINA, LIPPI & SARTOR (2025) — "Make privacy policies longer and appoint LLM readers"

Reversal: scholars (Calo, Waldman, Emami-Naeini, Yerby & Vaughn) prioritised **comprehensibility** (simplify!). Authors say insist on **full comprehensiveness even if policies become much longer**, because simplifying/extracting answers can now be **automated with LLMs (GPT-4)**. **Core claim: the trade-off between comprehensiveness and comprehensibility exists only while humans are the sole readers.** Not expecting consumers to paste policies into ChatGPT; **automated warnings, specialised chatbots and collective bodies (consumer associations)** could use LLMs. Counterfactual hypothesis: *if* policies were fully comprehensive, *then* LLMs could adequately answer consumers' questions.

Motivating example: ask your phone which corporations know you listened to *Frankly, Mr. Shankly* (The Smiths) and ordered baked tofu, and why. Policies use vague catch-alls ("we collect data about your use of our service") and open-ended lists ("such as", "including", "for example") → even a hypothetical expert with unlimited resources couldn't answer. Matters because of the **inference economy** (Solow-Niederman): ML draws sensitive conclusions (food/music → race/political convictions).

Theory: rational non-reading. People don't read policies (Bakos; Obar & Oeldorf-Hirsch), misunderstand them (Reidenberg), would need hundreds of hours/year (McDonald & Cranor 2008). Usual remedies: shorter/simpler policies or "**privacy nutrition labels**" (Kelley; Emami-Naeini). But **Ben-Shahar & Chilton (2016)**: even simplified disclosures have **close-to-zero effect** → problem is **content** not just form. Authors' earlier work (Pałka 2023): vague categories/purposes let firms do things consumers can't predict → **not reading may be rational: nothing to learn. Reframes the privacy paradox:** gap between stated preferences (care) and revealed (click "agree"). Solove 2021, Waldman 2020 blame cognitive biases, bad design, deliberate obstacles. **Authors: people care but rationally judge cost of managing privacy > expected loss** (severity × probability). Evidence: stated preferences, public uproar after breaches, market reality (firms mostly use data for profit while keeping it secure → detrimental *use* more common than unwanted *disclosure*). **Fix = cost reduction in two prongs:** require fully comprehensive policies; let users

query via LLMs. Not every consumer must; enough if some consumers and collective bodies expose bad practices.

NLP/law context: value of a policy depends on who/what reads it. **CLAUDETTE** (automated unfair-clause detection, Lippi 2019) gave less convincing results on GDPR policies (complex, incomplete, vague — Contissa 2018; Liepina 2019). LLMs (transformer architecture; Vaswani 2017) pass bar exams; **PolicyGPT** (Tang 2023) improved extraction → blurs machine-readable vs human-readable.

EU vs US: EU: policy = **mandated disclosure / information obligation** under **Arts 12–14 GDPR**, never itself source of right to process (that's Art 6 basis e.g. consent/contract); horizontal GDPR binds public & private controllers; enforcement by DPAs' administrative fines. US: no federal statute, state laws from **CalOPPA**, body of **FTC decisions** ("common law of privacy" — Solove & Hartzog) — failing to publish = deceptive omission; scholars debate whether policy = boilerplate contract (Davis & Marotta-Wurgler yes; Solove & Schwartz no); if contract: *Carnival Cruise Lines v Shute* (forum selection), *AT&T Mobility v Concepcion*, *American Express v Italian Colors* (arbitration). US model = "**notice and choice**"; EU has no equivalent name. Paper treats policies solely as information obligations (reduce information asymmetry).

Legal tension & authors' standard: California AG Kamala Harris 2014: "comprehensive overview" AND "plain, straightforward language… short sentences". EU: Arts 13–14 detail vs **Art 12(1)** "concise, transparent, intelligible and easily accessible form, clear and plain language" — "obvious tension". Unit of disclosure = single act of processing (**Art 4(2)**); for each: categories of data, purpose per category, legal basis (Art 6(1); name the interest if legitimate interests so proportionality can be assessed), storage period/criteria, recipients with role (controller/processor), purpose of sharing and its legal basis. **WP29 Transparency Guidelines** (EDPB-endorsed): "We may use your personal data to develop new services" = bad; "We will retain your shopping history and use details of products you previously purchased to make suggestions…" = good. Authors: "good" example looks fine alone but **scales badly and still omits legal basis/storage period** Art 13 requires — "At what point does the short and easy-to-read privacy policy become devoid of meaning?" **Their standard: policy should contain enough to answer ALL REASONABLE CONSUMER QUESTIONS** (fits GDPR **informational self-determination** and US law).

Study design — 9 questions about fictional "Orderoo" (food delivery chosen: banal data correlates with race/politics, interests health insurers, competitive market, wide-but-manageable catalogue): Q1 what data? Q2 purposes for email? Q3 who gets geolocation? Q4 data processed on consent + purposes? Q5 data shared with Facebook? Q6 shared with insurers? Q7 categories collected automatically? Q8 how to contact to exercise rights? Q9 how long keep delivery address? **Scenario 1 (real policies):** two legal experts read **Deliveroo, DoorDash, Glovo, Just Eat, Wolt** (downloaded 10 Jan 2024; **4,379 words (Deliveroo) to 13,765 (Glovo)**), no time limit, marking each answer clear/ambiguous. **100% agreement. Only 2 of 9 answerable: Q6 (insurers, clear in 4 of 5 — not DoorDash) and Q8 (contact, clear in all 5).** Causes: vague language ("personal data", "may", "as necessary", examples instead of exhaustive lists — Wolt's "for example, to… market", Deliveroo's "as long as reasonably necessary", DoorDash's "including, without limitation"), failure to give purposes and retention per data type (DoorDash: retention "may vary"). **Not one policy fully GDPR-compliant; quality not linked to length.** Second check (7 Oct 2024): **Amazon, AliExpress, eBay, Shein, Zalando** (4,533–20,512 words): same result, 100% agreement, only Q6 and Q8 answerable — confirms Contissa et al. 2018. **Proposal — fully comprehensive format:** law should require fully comprehensive policies, ideally **standardised**, relax comprehensibility requirement, leave **automated tools to tailor content**. Organised **by data category, one paragraph per type**, specific categories ("amount of time you spend in the app from opening to order", not "usage information"). **Non-ambiguity test:** if a reader could reasonably ask "but what do you

mean by category X?", split or define exhaustively; **"such as" and "for example" banned**. Each paragraph: category, source, purpose + explanation, legal basis + explanation, storage period; if shared: recipient, role (processor/controller), purpose, legal basis. **Written first for human experts so humans can always verify what an LLM says.** Mock Orderoo policy = **6,880 words**: email used for account access (contractual necessity), receipts (legal obligation), marketing (legitimate interest), profiling; shared with named processors (Cloud711, Microsoft); kept until account deletion + 3 months; geolocation shared with Facebook and Google as controllers for ad delivery on candid basis "legitimate interest: to make profit of available data". **Scenario 2 (LLMs on mock policy):** Q1,2,3,8 = simple retrieval; Q4,5,7 spread across document; **Q6 needs negative answer (no insurers) → tests hallucination**. **Prompt 1** (Jan 2024: rely solely on text, mention everything, don't simplify); **Prompt 2** (Oct 2024: adds "Please reason step by step" = **chain-of-thought**). Only **GPT-4 (closed; 128k-token window)** coped with long text; compared with **Llama2-7B (open)**, no fine-tuning; each run **5 times**; legal experts checked every answer; GPT-4 cost < $3 total. Metrics: **precision** (share of items given that are correct), **recall** (share of correct items found). **GPT-4 Prompt 1: 6 of 9 questions flawless on every run, 33 of 45 fully correct, never hallucinated; weakest Q7 (recall 78.2)** — missed "contact list details" and "call recordings" but answered correctly as yes/no (**prompt sensitivity**). **Chain-of-thought: flawless on only 5 of 9, 29 of 45 correct; Q4 recall fell 92→72; new errors (inference "to determine trends in purchase behavior"), repetitions → no advantage, could reduce performance. Llama2-7B** too messy for standard metrics → error types: Prompt 1 only **1 of 45 correct, 91% missing info, 62% hallucination**; CoT: skipped 9 questions, 2 right, hallucinated **64%**, called document "fictional"; invented "according to the document" that address kept "18 months after last order" and contact "123 Main St, Anytown". **Scenario 3 (Prompt 1 on real food-delivery policies):** of 45 answers each: **GPT-4 9 correct, Llama 1.** GPT-4 **0% hallucination, but 47% missed information, 33% contained inferences**; Llama hallucinated 38%, irrelevant info 58%; Llama said DoorDash would *not* share data in a merger (contradicting policy — "extremely dangerous"); mentioned "payment information" in 20 of 45 answers but correct in only 8 (relied on training-data typical policies). **Key inference: errors occurred where policies lacked clear/comprehensive info — "due to the poor drafting of the analyzed policies"; on such policies LLMs can mislead consumers.**

Conclusions: with LLMs both comprehensiveness and comprehensibility can be achieved; old trade-off no longer justifies "settling"; fully comprehensive policies are pro-consumer *provided automated Q&A available*. Needs more CS (linking answers to source text, automated quality control) and rethinking by lawmakers — "**promising, albeit still heterodox, direction**". **Strengths:** concrete legal proposal backed by experiments; clever counterfactual (mock vs real policies); shows bottleneck = **content** not reader capacity. **Objections:** Scenario 2 rests on **one mock policy written by the authors** (may be LLM-friendly), only **9 questions in one sector**, 5 runs of stochastic models whose versions date fast; shifts burden to consumers (**digital divide**); open who is liable if LLM wrong; corporate resistance (trade secrets, flexibility); can't reveal **mismatch between what a policy says and what a firm does**; longer policies may **entrench notice-and-consent** (firms disclose, individuals choose) rather than substantive limits on processing (contrast Najdi, Santos). Typo: calls the consent question "Q6" at one point though it's Q4. **Debate position:** fix lies in **content of policies and who reads them** — unlike *Planet49*/Santos (fix form), Pardo & Le Métayer (automate user's side), Najdi (change architecture). Rational-user reframing points to **collective bodies** (consumer associations — the kind that brought *Planet49*). On Art 12 vs Arts 13–14 tension: leads "longer and complete" camp vs simplifiers; middle path = **layered design** with complete, machine-queryable base layer beneath summaries, icons, LLM answers.

(R4 begins in Part 2.)

UNIT 2 — PART 2: R4 (Pilot) · R5 (Scoping review) · R6 (Najdi) · R7 (DPC contracts guide)

R4. PARDO & LE MÉTAYER (2019) — "Analysis of Privacy Policies to Enhance Informed Consent" (the Pilot language)

Problem — consent "on the fly": most common justification for collecting data = people consented or could have objected. Legal systems differ: **CCPA — opt-out counts as consent; GDPR requires opt-in.** Authors: in practice consent is given **"on the fly"** at the moment a person wants a service → mechanical acceptance, not really informed (people don't read policies; policies vague/ambiguous). **IoT makes it worse** (tracking into physical world).

Proposal — reverse the order: instead of reacting to a controller's policy at the last moment, **data subjects (DSs) define their own privacy policies in advance** (time to reflect, help from experts/peers). Policies then applied automatically to decide what their devices disclose. Each side (DS and data controller, DC) has own policy; the two are **compared** to decide if collection is authorised. Reduces **power imbalance**. Users update policies when meeting new controllers/purposes → coverage grows over time.

Language requirements: GDPR Art 4(11) — consent must be freely given, specific, informed, unambiguous. To guarantee **unambiguity**, language needs a **formal semantics** (precise mathematical meaning so it can't be read two ways). But precise meaning ≠ understanding consequences → also give **information about risks** (**Recital 39** GDPR: data subjects "made aware of the risks, rules, safeguards and rights"). No existing language met all requirements → authors built **Pilot** (not limited to IoT; design draws on IoT users' expectations — Emami-Naeini 2017).

Pilot in plain words:

- **DC policies** declared by controller's devices *before* collecting any data (what controller wants to do). **DS policies** attached by DS's device to any data it sends (restrictions). Controllers can store DS policies received for **accountability**.
- **Building blocks: devices** (phones, laptops, access points) and **entities** (parties behind devices; each device belongs to one entity); **data items** with a **datatype** (age, address, city) and **value** (special "undefined" = deleted/never collected; **owner** = device where created); **purposes** (newsletter, advertisement); **conditions** (simple logic over data and context e.g. "only data from adults (age ≥ 18)", "only locations in Lyon", combine with not/and → policies are **contextual**). Each set has a **partial order** (ranking more general/more specific: Google < Alphabet as entity; city < address as datatype; newsletter < advertisement as purpose).
- **Nested layers:** innermost = **data usage rule** (allowed purposes + retention deadline, e.g. research until 26/04/2019); around it = **data communication rule** (adds a condition + the entity allowed to receive). **Sender checks condition and recipient entity before sending; receiver must respect usage rule.** Complete policy = **datatype + data communication rule + set of transfer rules** (further communication rules saying to whom data may be passed on). Captures two ways data moves: **collection** (controller gets from DS) and **transfer** (already-collected data sent to third parties). A person may have several policies for one datatype (employer at work, museum while visiting).

- Ordinary people can't write formulas → abstract syntax maps to **restricted natural language**: "Parket may collect data of type number plate and use it for commercial offers purposes until 21/03/2019…".

Running example — ANPR (automatic number plate recognition) parking: billing needs no consent (contract performance, Art 6(1)(b)); commercial offers/advertising need **prior consent**. **Parket** (French parking company) wants number plates for commercial offers until 21/03/2019 and to transfer to sister company **ParketWW** until 26/04/2019; no condition; broadcast to cars before entering ANPR area. **Alice** (driver) policy: collect number plate only if car in **Lyon**, commercial offers until 21/03/2019, **no transfers**. Alice's more restrictive → her device (car computer linked to phone) **automatically refuses consent**. Alice's device can send her policy back; Parket computes a **join** and sends Alice a new policy she accepts → **automatic negotiation**; join proven **privacy-preserving**.

Execution model (abstract precise description of how a Pilot system behaves step by step; fixes meaning so no ambiguity; powers the verification tool). System state: (1) values of data items on each device; (2) each device's **policy base** (own policies + received ones; used to decide if data may be communicated); (3) for controllers, data received as **triples (sender, item, policy)**. **Central idea: privacy preserved if the controller's policy is more restrictive than the DS's ("subsumed by")** — checkable **before any data collected**. **4 events: request** (controller asks DS for data type + supplies policy → added to receiver's policy base); **send** (DS sends item; allowed only if both sides have an active policy and controller's is more restrictive; policy "active" if applies to type and recipient entity, retention time not reached, condition holds); **transfer** (controller passes to another; needs active transfer rule in policy that data's owner sent; recipient's policy more restrictive); **use** (controller uses item for purpose; allowed only if purpose allowed and retention not elapsed). **Subsumption** = "more restrictive than": usage rule — every purpose sits below some purpose the other allows, retention no longer; communication rule — condition stronger, recipient lower, usage rule more restrictive; whole policy — datatype lower, communication rule more restrictive, each transfer rule covered. **Join** = merge two policies: keep only shared purposes (more specific), **shorter retention**, **both conditions**, lower entity/datatype, merge compatible transfer rules pairwise → result more restrictive than both.

Risk analysis with SPIN: precise semantics says what a policy says, not what might go wrong. Risks come from **misbehaviour** (using beyond purpose or transferring to unauthorised third parties). **Risk assumptions** about **risk sources** (entities with strong interest in using data for a purpose, or able/willing to pass data on); generic (databases by peers/NGOs on past misconduct) or DS-specific (fear a friend will pass info on). DS asks: "if I add policy p, is there a risk my data of type t is used for purpose pur? Is there a risk entity e gets my data?" Tool = **SPIN model checker** (checks every possible run to see whether a property can ever be broken); model in **Promela**; properties in **Linear Temporal Logic (LTL)** ("never"). "Is there a risk ParketWW profiles Alice?" → LTL: "ParketWW never uses Alice's data for profiling". Each device = process randomly executing events; misbehaviour = added **illegal events** (*illegal_use*, *illegal_transfer*). If no sequence breaks property → risk cannot occur; if one does → SPIN returns a **counterexample** explaining how. Not tied to SPIN (could use SMT solvers/theorem provers).

Case study: 4 entities — Alice, Parket, ParketWW, **CarInsure** (insurer = risk source); one datatype number plate (GD-042-PR); two purposes (commercial offers, profiling). Two risk assumptions: ParketWW may transfer to CarInsure ignoring DS policies; CarInsure has strong interest in profiling. Alice weighs two candidate policies (transfer to ParketWW allowed / no transfer). Results: Parket can receive data in every case, neither Parket nor ParketWW can use for anything other than commercial offers; ParketWW receives only if Alice allows transfer. **Decisive:** under normal behaviour CarInsure can't receive or profile

whichever policy; **under misbehaviour both become possible (flagged violations) if Alice allows transfer, neither if she forbids**; counterexample: CarInsure gets data only after ParketWW executes illegal transfer. **Alice's 3 options:** neither policy (Parket uses data only for billing on contract basis); no-transfer policy (offers, no transfer); transfer policy (offers + transfer). If she wants offers but no risk of insurer profiling → option 2. = **"more genuinely informed consent"**: she chooses knowing what could happen to her data if someone breaks the rules. **Prototype:** web app: enter Pilot policies via form, choose risk assumptions from generated list, ask questions, click "Verify!" → SPIN runs; answers change "Not Analyzed" → "Yes"/"No". Tailored to ANPR; code on GitHub.

Versus earlier work: P3P (pioneer; purpose/retention/conditions; website-focused, unsuited to IoT, no data transfers); **EPAL, A-PPL** (enterprise/accountability focus; no precise execution model → ambiguity, divergent implementations); **DHP** (closest in spirit; actions/purposes per recipient; deletion obligations; no explicit transfer rules/retention; service providers focus); De & Le Métayer's **harm trees** (manual per application; Pilot automatic once risk assumptions defined); **S4P, SIMPL** (formal trace semantics, prove global correctness, can't build enforcement, pre-GDPR); **contextual integrity** in LTL, **PrivacyAPI, PrivacyLFP** (formalise HIPAA, COPPA, GLBA — model laws not DS/controller policies); **UCON, OSL** (usage control/obligations/DRM — control use after access; no policy comparison; don't distinguish DS from controller); **PIAs/privacy risk analysis** assess risks of *systems*, Pilot assesses risks of *policies* (based on parties' motivation, reputation, history, not system vulnerabilities beyond a DS's expertise).

Conclusions/strengths/weaknesses: can underpin **personal data managers** (enforce automatically) and **personal data auditors** (check *a posteriori*). IoT challenge: DS must know about collection around them and communicate consent/objection to sensors directly or via registers (Cuncha). Future work: richer risk model (inference between data types — Privacy International; history of data already collected), theorem prover, verifying enforcement systems.

- **Strengths:** formal semantics removes ambiguity; each side states its own policy → **restores bargaining symmetry**; join = automatic negotiation; risk-based info implements **Recital 39**; counterexamples **explain why** a risk exists.
- **Weaknesses:** requires users to **author policies** (usability/effort; echoes Santos and **privacy paradox**); risk assumptions depend on someone curating trustworthy databases; **cannot stop misbehaviour, only predict it** (lighter, predictive alternative to Najdi whose design prevents data leaving); enforcement still relies on controllers honouring policies after receipt (**trust problem**); toy case study (one datatype, four entities); web app tailored to one scenario; **no user evaluation**; inferences not handled.
- **Where it fits:** "**automate the user's side**" answer to notice-and-consent. Restricted natural language = middle path between comprehensive and comprehensible. On ambiguity (undermines consent, texts, data): formal semantics. Like GDPR consent and Najdi it assumes an informed deliberate user (**privacy paradox** calls into question). Against scoping review (R5): non-ML formal policy analysis with user-facing tool but no user evaluation. Legal anchors: **Art 4(11)**, **Art 6(1)** (billing on contract not consent), **Recital 39**.

R5. VAN DER SCHYFF, PRIOR & RENAUD (2024) — "Privacy policy analysis: a scoping review and research agenda"

Why needed: privacy policies are legal documents, longer/more complex (GDPR etc.); users spend only **seconds or minutes** scanning (Obar & Oeldorf-Hirsch) because of time, cognitive overload, distrust,

convoluted sentences. Consequences: unwitting consent to disliked practices; mistrust (seen as designed to obscure); privacy-conscious people disengage from services. Fixes studied: **simplification** (plain language), **layered design** (essentials up front), **visual elements** (icons/infographics), **privacy-literacy education**. **Earlier reviews narrow:** Del Alamo 2021 (Android 2016–2020 only); Del Alamo 2022 (automated NLP only); Bhattacharjee 2020 (visualisation); Leicht & Heisel 2019 (policy languages like P3P, now largely unused); Liu 2022 (ML as PET). Missing = broad **platform-agnostic** review. **Contributions:** overview of techniques in **97 studies**; account of primary challenges; detailed research agenda. **RQ1:** which analytic techniques used? **RQ2:** what challenges deterred analyses?

Method — scoping review (Arksey & O'Malley; reported using **PRISMA-ScR**, Tricco 2018). Chosen over systematic review: suits complex areas with many concepts/techniques; maps where research likely useful (interdisciplinary); can include very different study designs without quality assessment; preliminary assessment for future systematic reviews. Search: **10 databases** (IEEE Xplore, ACM, ScienceDirect, Springer, Google Scholar…) + **56 IS journals** rated A*/A on 2022 ABDC list. Peer-reviewed only (no grey literature). Search string: "privacy policy" + classification, benchmarking, completeness, evaluation, analysis, integrity, assessment, test, visualisation; context-specific terms deliberately left out. Inclusion: empirical findings, online privacy policies, published **2004–2023** (2004 = emergence of Web 2.0). Exclusions: mostly conceptual, reviews/meta-analyses, non-technological, non-English, non-peer-reviewed. **1,429 studies (deduped) → 168 after titles/abstracts → 97 after full texts.** All authors screened titles; first two did full text; third resolved disputes. Charted data (context, country, design, theory, new/existing dataset, participants, techniques, challenges, effectiveness). Two **co-occurrence analyses** (ML and non-ML) using matrices (radial diagrams wouldn't work).

What the 97 studies look like: US 41; Germany and UK 8 each; China 7; Canada 5; Australasia 3; **no studies from Africa**. **45 studied websites** (8 used Alexa rankings e.g. top 1,000); **36 mobile apps**. **72 created own dataset**; of those using existing, most used **OPP-115** (115 annotated website policies; 14 studies); only 2 used **APP-350** (Android). **50 quantitative, 27 mixed, 8 qualitative**, 1 unclear. **Only 5 used an established theoretical framework; only 3 privacy-specific; 2 used Contextual Integrity** (to annotate social-media policies).

RQ1 — techniques: Non-ML: manual dominated (**22 studies**; 5 exclusively manual). Most common manual = **annotation** (8; expert annotators e.g. lawyers label statements, often vs GDPR = "tagging"); **content analysis** (6; not guided by theory); category assignments (2; beyond GDPR concepts, WhatsApp/RestAssured → policy template). Single studies: virtual-assistant dashboard questions (Bolton), heuristic evaluation of Facebook policy, readability of 113 organisations' policies, layered design vs "privacy finder" (Reeder), IoT ontology, risk assessment of 94 IoT device policies. Manual combined with **visualisations (8)** and **word counts/readability (7)** (Flesch-Kincaid, Gunning-Fog, SMOG). Stats: ANOVA for visual designs; Mann-Whitney-U for annotation. **ML dominates: 61 studies** (SVM, ML+NLP, NLP alone); annotation again most common accompanying technique (22), word counts (5), readability (4), visualisations (4). Bhatia 2016: **Hybridized Task Recomposition (HTR)** crowdsourced annotation; Manandhar: Device Attribute Mapping (2,442 smart-home policies). **Crowdsourcing (6; e.g. Mechanical Turk) = way to collect data not analyse. No study used PLS-SEM.** Few non-English; one Chinese study used distance calculations for readability.

RQ2 — challenges (ML studies, 5 themes): (1) **analytic complexity** — **ambiguity** (tools like **PolicyLint** need manual verification; seed words ambiguous; ontologies subjective); **policy harvesting** hard (longitudinal, network traffic vs claims, Android/VR). (2) **language/semantic variation** — other languages, semantic dependencies, limited lexicons (risk in Japanese); unit of analysis (paragraph inaccurate vs

sentence too narrow for unfair/unlawful use); tools English only; translation loses nuance; keywords without context; Liepina suggest supervised ML + neural. (3) **visualisation & user evaluation** — often missing (Dombetzki's **Amaryllis** plugin no user study); users confused (Reeder's interactive grids, unused P3P). (4) **data collection** — few non-English; missing policies (esp. apps); many datasets pre-GDPR; **Wayback Machine/OPP-115 reliance** limits inference; narrow sampling, unknown APIs bias; crowd workers annotate inaccurately; emotionally charged user reviews. (5) **temporal nature of legal/policy terms** — definitions change over time, hurting comparative/longitudinal work (distinct from ambiguity). **Non-ML (3 themes):** (1) **analytic limitations & subjectivity** (content analysis interpretive; readability indices = "**silver bullets**" (Brooks, *Mythical Man-Month*) though test different things; unknown instruments of indeterminate validity; little user feedback); (2) **data scope & collection** (narrow industries/demographics/regions mostly US; vague terms; single case studies; nutrition labels risk **priming** — Fox); (3) **visual & technical** (software choices unclear; third-party flows hard to show; unfamiliar icons; nutrition labels confuse (Kelley, McDonald); people interpret "personal information" very differently; pre-training participants may verge on priming).

Research agenda — 10 recommendations (1–3 all research; 4–7 ML; 8–10 non-ML):

1. Use **established privacy-centric theory** — **Contextual Integrity (Nissenbaum)**, **Privacy Calculus (Dinev; Laufer & Wolfe)**, **Informational Self-Determination** (structured vocabulary, reduces ambiguity, bridges disciplines, enables benchmarking; "**much of privacy policy analysis research avoids the user**"; blanket GDPR compliance checking not enough).
2. Incorporate **privacy risk assessment + full DPIA** (necessity & proportionality); define scope; choose methods with comparative frameworks (IoT, blockchain).
3. Improve methodology: **user evaluations**, demographic/geographic inclusivity, comparative usability studies, diverse datasets (apps and websites), clear collection protocols/annotation guidelines, version tracking, crowdsourcing with care.
4. (ML) advance NLP for ambiguity: **BERT** embeddings, beyond OPP-115/APP-350, coreference resolution, syntactic parsing, benchmark datasets; **NER** for cross-border transfers (countries + mechanisms: SCCs, adequacy, BCRs).
5. (ML) better **policy harvesting**: adaptive scraping, page monitoring, differential analysis across versions, standardised formats/ontologies, legal experts; **blockchain/DLT** for immutable record of policy changes.
6. (ML) language/semantic: machine translation, **multilingual BERT**, classification at right granularity, topic modelling, sentiment analysis, language-specific ontologies, bespoke models for under-represented languages, linguists + legal experts.
7. (ML) **context-aware keyword extraction** (surrounding text, grammar, semantics; unsupervised word embeddings/topic modelling; detect emerging keywords).
8. (Non-ML) **standardise content analysis** (NLP aids, ML for automated content analysis, evaluator guidelines, **inter-rater reliability**).
9. (Non-ML) use **PLS-SEM** (Partial Least Squares Structural Equation Modelling): complex/non-linear relationships, reflective and formative constructs, measurement error ("noisy data"), multiple mediation/moderation paths (beats CB-SEM), non-normal data (non-parametric), multi-method data (surveys, interviews, observations).
10. (Non-ML) multifaceted solutions for visual/technical challenges: user-centred icon design/testing, interactive visualisations, legal experts, alternative data sources/innovative scraping respecting platforms' terms (Google Play).

Limitations: diverse methods → hard to compare ("not heterogeneous" in paper — authors mean methodologically varied); researcher bias in selection/coding (mitigated by two independent coders); grey literature excluded; recommendations not validated/tested. Future: standardised content analysis, PLS-SEM, broader data across industries/demographics/regions via industry/government/NGO partners, taxonomies/ontologies, user-centric visual design, better scraping for longitudinal studies, privacy theory, risk assessment. Conclusion: ground analyses in theory, integrate risk assessment, need user evaluation and user-centric design; ML work should use advanced NLP; non-ML should use standardised content analysis and PLS-SEM. **Criticisms:** recommendations untested; peer-reviewed only → misses industry/regulator work; ends 2023 → misses **LLM wave (GPT-4 era)**; PLS-SEM recommendation narrow (authors' IS background). **Where it fits:** frame for whole field. Pałka (uses LLMs) and Pardo & Le Métayer (formal language + model checking) = the two families mapped: ML/NLP vs non-ML formal work. **Ambiguity** is the common enemy: hurts ML labelling; makes experts and GPT-4 fail (Pałka); Pilot's answer = formal semantics. Ambiguity in acts (clicks), texts (policies), data (annotations) undermines consent at every layer. **Gap in user evaluation** runs through others: Pilot has no user study, Najdi no implementation, Santos leans on others' user studies. Finding that users spend only seconds on policies = evidence against GDPR's assumption of an informed deliberating user. Second recommendation ties to GDPR's own risk tools (DPIA among **Arts 32–36**, alongside security, breach notification, prior consultation).

R6. NAJDI, ATHAUDA, BANDARA & LUO (2025) — "Technical Framework to Ensure Data Subject's Rights in GDPR: A Conceptual Design"

Problem: rights on paper, trust in practice. Users trade personal data for services; because of cloud hosting data sits on providers' servers. Data = "**predominant currency**" of online services; companies monetise through **secondary use or sale**. Stats: 2023 **OAIC** survey **74%** of Australians saw data breaches as one of the biggest privacy risks; 2022 only **54%** of UK population trusted providers; 2024 **half of global data breaches involved customers' PII**. Illustration: **Cambridge Analytica — 87 million Facebook users**' data collected without consent, used for political advertising; Facebook fined. **GDPR** (May 2018) applies to every organisation processing EU citizens' data incl. outside EU; "world's strongest privacy and security law"; influenced Australia. But **legal framework, not prescribing technology** → organisational autonomy but compliance difficult; technical solutions fragmented/manual. Users feel consequences: **Bowyer et al.** — delayed/inadequate responses, data collected without consent appearing in responses, incomprehensible data files, no ability to control/modify/delete. **Pöhn et al.** — some sites compile data manually (long waits); most comply with access right but lack completeness/understandability. **Three contributions:** review technical approaches supporting DS rights; map each to rights it supports (large gaps once trust in controller relaxed); propose own reference framework + discuss limits. Underlying question: **can technology guarantee DS rights even if the organisation that wants the data can't be trusted?**

The paper's map of GDPR: 99 articles; 4 roles — **DS** (data subject), **DC** (controller: purposes and methods), **DP** (processor on controller's behalf), **SA** (supervisory authority). 7 principles: lawfulness/fairness/transparency; purpose limitation; data minimisation; storage limitation; integrity & confidentiality; accountability; accuracy. **Rights IR1–IR11:** | | Right | Meaning | |---|---|---| | IR1 | Informed | what data, why, by whom, how long; existence and logic of ADM | | IR2 | Give & withdraw consent | any time | | IR3 | Transparent processing | concise, transparent, intelligible, accessible, clear plain language | | IR4 | Request & response on action | told without undue delay what was done on requests under IR5–IR10 | | IR5 | Access | confirmation + access to own data | | IR6 | Portability | structured, commonly used,

machine-readable; transmit to another controller | | IR7 | Rectification | correct inaccurate/incomplete without undue delay | | IR8 | Erasure | when consent withdrawn, DS objects, no longer necessary, unlawful | | IR9 | Restrict processing | future processing stops; controller may still store | | IR10 | Object | incl. **absolute** right to stop direct marketing/profiling | | IR11 | Complain to SA | legal not technical → **excluded from analysis** |

Trust gap in existing technology: searched Google Scholar, ACM DL, IEEE Xplore 2020–2024 ("personal data", "control", "GDPR", "blockchain", "consent management") → **19 papers**, scored strictly: right **fully supported** only if ensured by design **and** shown via implementation/evaluation; **partially** if only in some contexts or not implemented/evaluated. **Findings:** (1) research focuses overwhelmingly on **consent management and processing (IR1–IR3)**; other rights sparse. (2) **Blockchain** widely used (shared record: immutable once written, transparent to parties, **decentralised trust**) — to record consent requests, **provenance**, audit logs. (3) **KEY ARGUMENT:** after consent, data is handed to DC and transitively its processors → **implicit trust** that DC won't misuse (intentionally or not). GDPR deterrent is **legal** (complaint to SA/IR11, legal action) — bites only if misuse is **detected and proven**; **no technical means to monitor or prevent misuse once data handed over.** If trust relaxed, none of existing designs fully meets IR3–IR10, and even IR1/IR2 can be violated. Conclusion (stark): "**none of the existing approaches meets any of the DSs' rights**". **Legal deterrence works only after misuse is detected and proven; technical design could prevent it in the first place.**

The framework — 4 design decisions (if the danger is handing data over, don't hand it over):

1. **PII never given to DC or DP**: stays under DS's control in a **Personal Data Store (PDS)** (individuals collect, store, manage, share data by own rules; e.g. **Solid Pods**, **Self-Sovereign Identity (SSI)**).
2. A **Consent Management System (CMS)** essential for IR1/IR2; formal/machine-readable consent (ontologies mapped to actions and rights) so what each consent permits can be checked automatically.
3. **Blockchain + smart contracts** (programs on blockchain) log consent actions and processing transparently, auditably, immutably.
4. **Process data in a secure environment**: DC sends its approved **algorithm** to the secure environment; consent validated, PII pulled in and processed there; only **output** goes to DC (**algorithm travels to the data, not data to the company**). Processing smart contract stores **hash** (digital fingerprint) of algorithm, hash of results, timestamp, list of consents → anyone later can confirm that the algorithm run and its results are those recorded.

How it works: two actors (DS, DC), two components: **Secure Consent Management System (CMS)** and **Secure Computing Environment (SCE)**.

- **Consent:** DC asks via DS's CMS; DS grants/rejects. If granted, CMS creates a **consent ID** stored with data items covered, types of access allowed, DC's ID. Consent also recorded (timestamp) in **Consent Smart Contract (CSC)** on blockchain; **rejected requests recorded too** (transparency). For sensitive data DS can ask to see/check the algorithm (no leakage, nothing beyond consent) and store its hash with consent. Consent ID returned to DC.
- **Processing:** DC calls SCE with algorithm, list of consent IDs and DS IDs, own DC ID. SCE nodes hosted by public cloud providers, authenticated via **PKI**. After authenticating DC, SCE starts a **Secure Computing Pod (SCP)** hosting a **trusted execution environment (TEE / enclave)** — hardware-isolated area where computation runs sealed off. SCP contacts each DS's CMS with DC ID, token, consent ID, algorithm hash; CMS verifies and performs **remote attestation** (checks from a distance that enclave is genuine) before releasing any PII. Algorithm runs, results return to DC,

Processing Smart Contract (PSC) records hash of algorithm, DC ID, list of DS ID/consent ID pairs, timestamp. Net effect: **PII known only to the SCP during processing; DS keeps control throughout.**

How each right is met (claim: fully meets 9 of 10 technical rights IR1–IR9):

- IR1 informed: DC gives GDPR info via CMS; CSC records show who processes, why, how long.
- IR2 consent: CMS lets DS give/amend/withdraw; PII released only after consent validated; DS can verify/hash algorithm; works for new and existing systems.
- IR3 transparent: all processing logged in PSC → DS sees directly even if DC untrusted.
- IR4 request/response: by design; DS gets info from PDS, CMS, CSC, PSC without asking DC. IR5 access: PII in PDS, consents in CSC, processing records in PSC. IR6 portability: PII already in PDS; Solid Pods provide standard formats. IR7 rectification: DS edits PDS; future processing uses corrected data.
- IR8 erasure (modified sense): withdrawing consent has same effect for future processing; PII never collected without consent. IR9 restriction: DS revokes consent; SCE checks consent before any processing; GDPR's "controller may still store" irrelevant because DC never stores PII.
- **IR10 object (marketing/profiling) — the one right it cannot technically ensure:** e.g. DS consents to data used to train an ML model; **trained model = output → goes to DC**; if DS later objects, nothing stops DC continuing to use the model. Link to Custers & Vrabec: models aren't personal data, one person's erasure barely changes a model, data can be re-inferred.

Limitations/answers/criticism:

- Candid limitation 1: depends on algorithm respecting consent — malicious DC could write algorithm that **hides PII inside results**. Answers: DS can complain to SA; PSC lets auditors compare stored hash with real algorithm/results so SA can enforce; DS can review algorithm before consenting and store its hash. Overhead on DS (must validate algorithms) → future research on **automatic verification** that algorithm doesn't leak/go beyond consent. Limitation 2: IR10 / ML model problem; possible fix: keep ML models inside a TEE in the secure environment rather than at DC. **Only conceptual design; authors now implementing and testing.**
- **Strength:** shifts debate from "trust + legal deterrence" to "**don't hand the data over**" = **privacy by architecture**, spirit of **Art 25 GDPR**; integrates known technologies; gives DS direct visibility instead of relying on subject access requests.
- **Weaknesses: not implemented or evaluated** yet describes itself as giving "**fully supported**" rights while requiring other papers to show implementation to earn full credit (**asymmetry — sharp exam point**); heavy **burden on users to vet algorithms** (unrealistic; privacy paradox; Santos, Pałka, cost of self-management); outputs/aggregates can still leak or enable profiling; **blockchain immutability vs erasure** (hashes/IDs on chain may themselves be personal data and chain can't be changed); **trust shifted** not removed — to cloud providers hosting TEEs and their hardware; enclave attacks possible; performance and cost; weak **adoption incentives** (business models depend on holding data); **processors under Art 28 would disappear or change role**. **Where it fits:** technological answer to failures of consent. In notice-and-consent debate: "**not on its own: change the architecture**" — even perfect consent fails if controller misuses data afterwards. Notice-and-consent survives only if cost of self-management falls and controllers are technically/legally constrained after consent (**Najdi + Art 28**). **Contrasts:** Pilot (predicts misuse risks) vs Najdi (prevents data leaving); Irish DPC guide (contractual/legal controls over processors) vs Najdi (not enough without technical enforcement). Shares **rational-user assumption** (people will

vet algorithms). **Best answer: complementary — Art 25 is the bridge: law sets requirements and sanctions, design makes them usable, technology makes them enforceable.** Najdi's own framework proves it: when a stored hash doesn't match, **the SA must still act** → "technology narrows our reliance on law, but doesn't remove it".

R7. DATA PROTECTION COMMISSION (Ireland) (2019) — *A Practical Guide to Controller-Processor Contracts*

What it is: regulator guidance (not academic), last updated **June 2019**; refers to GDPR and Irish **Data Protection Act 2018**. **Central message:** whenever a controller engages a processor, the two **must sign a legally binding contract** containing at least the terms of **Art 28(3) GDPR**. With *Planet49*, one of two readings stating what the law requires (others propose design/technical fixes). Shows how law keeps data protected once it leaves the collecting organisation.

Roles: controller = decides purposes and means (why and how); **processor** = processes on controller's behalf and **only on documented instructions**. GDPR (25 May 2018) = heavier obligations on both. **Background duties: Art 28(1) duty of selection** — controllers may use only processors giving "**sufficient guarantees**" to implement appropriate **technical and organisational measures (TOMs)** so processing complies and protects data subjects. Processors also have **direct GDPR obligations** (records, security) in addition to contract → **two layers of liability**: GDPR fines/penalties **and** claim for breach of contract. Applies to all controllers in **public and private sectors**. Before GDPR a written contract was already needed; GDPR prescribes **many more provisions**.

Contract content — part 1: describe the processing: subject matter and **duration**; **nature and purpose**; **type of personal data**; **categories of data subjects**; **obligations and rights of the controller**. **Part 2: nine clauses binding the processor** (guide lists without letters; letters are standard GDPR refs):

1. Process only on **controller's documented instructions**, incl. international transfers, unless law requires otherwise (**28(3)(a)**).
2. Everyone processing is under **confidentiality** duty (**28(3)(b)**).
3. Take all **Art 32 security** measures (TOMs) (**28(3)(c)**).
4. Engage a **sub-processor** only with controller's **prior specific or general written authorisation**; if general, give controller chance to **object in advance** to each new sub-processor (**28(2), (3)(d)**).
5. Impose same obligations on sub-processors, **remaining directly liable** to controller for their performance (**28(4)**).
6. **Assist controller** (appropriate TOMs) in responding to **data subject rights requests** (**28(3)(e)**).
7. Assist with **Art 32 security, Arts 33–34 breach notification, DPIAs and prior consultation Arts 35–36** (**28(3)(f)**).
8. At end, **delete or return** personal data as controller instructs (**28(3)(g)**).
9. Make available all info to **demonstrate compliance with Art 28** and allow/contribute to **audits** by controller or mandated third party (**28(3)(h)**). **Optional extras:** liability/indemnities, detailed technical security provisions, additional cooperation provisions case by case. **Compliance task:** ensure a legally binding contract exists for every controller-processor relationship and keep it up to date with at least Art 28(3) terms.

Links: accountability chain — Art 28 uses **contract** to extend controller's obligations down the chain (controller → processor → sub-processor); = law's answer to the **trust problem** Najdi approaches

technically. Najdi argue contractual/legal controls aren't enough without technical enforcement; keep data with DS so only results are sent; but under Najdi, **Art 28 processors would disappear or change role**. Notice-and-consent can survive only if cost of self-management falls and controllers constrained technically/legally after consent (Najdi + Art 28). **Pałka:** comprehensive policy format must name each recipient and **role (processor vs controller)** — exactly the distinction Art 28 turns on (mock policy: **CoolAccountants, FraudDetectors, Cloud711, Microsoft = processors; Facebook, Google = controllers**). **Santos:** CMPs may act as processors or controllers for websites, so errors in recording consent raise who is responsible. **Pilot:** transfer rules and usage rules = machine-readable "documented instructions" and limits on onward transfers. **Limits of contractual approach:** contracts/audits work **ex post** (misuse must be detected then proven); **small controllers have little leverage over big processors** (cloud providers); "**documented instructions**" can be vague in practice. Hence law, design, technology complementary: Art 28 = binding requirements with sanctions, but (Najdi) law alone can't stop misuse once data left DS.

(R8 onward → Part 3.)

UNIT 2 — PART 3: R8 (McDonald & Cranor) · R9 (PIAs in the Wild) · R10 (PIA/PRA methodologies) · R11 (Custers & Vrabec) · R12 (Lindegren et al.)

R8. McDONALD & CRANOR (2008) — "The Cost of Reading Privacy Policies"

Idea: an old proposal said privacy could be handled by **economics instead of law**: a market where people accept/reject **micropayments** for giving up data. That market never appeared (advertisers might pay ~1 penny per name/IP address — Garfinkel — few would sell contact details for a penny). Authors **flip it**: users don't get paid, they **pay with their time** — researching privacy policies to keep their privacy. **Question:** if users read the policy of every site they visit once a year, what would that time be worth?

Headline answer (point estimate): ~244 hours per person/yr ≈ $3,534 per person ≈ 781*billionnationally* * * —*farmorethanthewholeUSonlineadvertisingmarket*(* *21 bn in 2007). Conclusion: the FTC's self-regulation vision ("**read, compare, choose**") is unrealistic; targeted advertising may have **negative social utility**.

US background: notice and self-regulation

- **Late 1990s FTC** backed **industry self-regulation** over legislation (internet young; legislating early might stifle innovation; business more efficient than FTC staff). **Exception: children → COPPA (1998).**
- Based on **Fair Information Principles (FIPs)** — 1970s (mainframe credit databases); not law but principles for legislation (like Art 12 UDHR). FTC chose **5**: **notice/awareness, choice/consent, access/participation, integrity/security, enforcement/redress** (subset of **OECD's 8**). **Notice** underlies privacy policies. **1998 report: 92% of US commercial sites collected data, only 14% gave comprehensive notice.**
- Policies **voluntary**; no rule on format/length/readability/content. But once published, FTC enforces via **fraud/deception law**. ***Cartmanager* (2005):** FTC used **unfairness** even where company had no policy of its own (rented customer lists in breach of clients' policies).
- FTC "Internet sweeps": more sites posted policies each year, yet people still feared shopping online. FTC backed two further tools: **privacy seals** (TRUSTe, BBBOnline — criticised as weak; one study found TRUSTe-sealed sites had *less* protective policies) and **PETs** like **P3P** (machine-readable policies read by software "user agents"; built into browsers but unfamiliar to most users).

Economic theory

- **Search attribute** (judge before buying, e.g. colour) · **experience attribute** (only after use) · **credence attribute** (never verifiable, e.g. nutrition content). **Nutrition labels turn credence into search**; a privacy policy should let you check *before* handing over your email whether you'll get spam.
- **Information asymmetry** → market failure (**Akerlof's "market for lemons"**, applied to privacy by Vila et al.). Policies are meant to reduce it — but if **cost of reading > perceived benefit**, rational actors **won't read** (Acquisti & Grossklags). Time = real cost (value of time literature from Becker 1965).

- **Why self-regulation fails:** (1) much of the web has **no substitute** (choose Amazon vs Barnes & Noble, but no substitute for Wikipedia); (2) policies are hard to read, read rarely, don't support rational decisions.
- **Explicit data markets don't exist:** Laudon's National Information Market (baskets of information); Varian: privacy = "right not to be annoyed" (sell specific data for specific uses for a fixed time). Prices tiny: ~1 cent/name; stolen data ~1/10 of former value; full clickstream ~**40 cents/user/month**. Yet outrage at **AOL search data release** shows people value data far higher → **no zone of agreement**.

The model & inputs

National reading time = (internet users) × (avg time to read one policy) × (unique sites per person per year). Skimming time computed the same way. **Money:** hour at **work = 2× wage** (salary + overhead ≈ 2× take-home); hour at **home = ¼ wage**. BLS wage **17.93/*hr*(*Mar*2008) * * → * *35.86/hr work; $4.48/hr home.** All estimates given as **low / point / high** (1st quartile / median / 3rd quartile).

- **Reading time (calculated, not measured):** word counts of policies of **75 most popular sites** (AOL data on 30,000 most-clicked sites, Oct 2005); range **144–7,669 words (~15 pages)**; reading speed **250 wpm**; short policy **2,071 words = 8 min**, median **2,514 = 10 min**, long **3,112 = 12 min**. Likely underestimates (jargon; slower online reading).
- **Skimming time (measured):** online study, **212 participants** (44 outliers removed e.g. 5-hour sessions; fast participants deliberately kept = conservative). **Six policies:** 928 words, 6,329 words, and four near 2,500. Five multiple-choice questions ("Does this policy allow Acme to put you on an email marketing list?" "Does the website use cookies?"). **Median 18–26 min** (lowest Q1 12 min, highest Q3 37 min). Time not linear in length: three ~2,500-word policies had medians 23–24 min, no significant difference (t-test p = 0.518, 0.690, 0.891). Earlier study (93 participants, 928-word policy) found ~6 min but artificially low (first question excluded as training; most time spent on Q1 = 1/3–1/2 of total).
- **Final skim figure:** time on **first question only** (find company's street address, at end of policy → forced full skim): medians 4–8 min → **3.6 min (low), 6.3 (point), 11.6 (high).** Defended: independent of number of questions; regular readers get faster.
- **Number of sites** (Nielsen March 2008): **66 unique sites/month at work, 119 at home, 105 overall**; 52 work-only, 105 home-only, 14 both. Assumes policy read at **first encounter**. Low bound: shared sites first seen at home; point = half/half (59 & 112); high = first seen at work (66 & 105). Weekly Nielsen data (25 and 40 unique sites/week) → **repeat-visit scale factors 66% work, 74% home**. Annual = monthly × 12 × scale factor → **1,354 (low: 412 work + 942 home), 1,462 (point: 467 + 995), 1,518 (high: 586 + 932)** sites/yr. Cross-check: 2008 study of 25 people found **390 unique sites over 52–195 days (mean 105 days)** → their estimate is conservative. **Population 221 million** Americans online (Nielsen, Pew, Census). (Abstract's lower bound = **119 sites** = monthly home figure.)

Findings

	Low	Point	High
Hours reading/person/yr	181	**244**	304
Hours skimming/person/yr	81	**154**	293
National hours reading (bn)	39.9	**53.8**	67.1

	Low	Point	High
National hours skimming (bn)	17.9	**33.9**	64.8
$ per person (reading)	2,533	**3,534** (= $2,791 work + $743 home)	5,038
$ skimming per person	1,140	**2,226**	4,870
$ national reading	$559.7 bn	**781*bn* * * (617 bn work + $164 bn home)	$1.1 trillion
$ national skimming	$251.9 bn	**$492 bn**	$1.1 trillion

- **Perspective:** 244 hrs/yr = **40 min/day** = more than half of the **72 min/day** then spent online; more than time on shopping (1.9%), spam (6.2%) and games (13%) combined. Adware start-up delays ≈ 60 hrs/yr (¼ of this). In 2000 US taxpayers spent **26.4 hours each / 3.4 bn hours total** on federal tax returns. **Money:** 2005 internet access cost **$237/yr dial-up or $508 broadband** → reading time dwarfs it; **US online sales 2007 ≈ $260 bn** < employer cost of reading time at work.
- **Conclusion's headline figures: "~201 hours and $3,534 per user per year, $781 bn nationally"** — *internal inconsistency* (201 vs results' 244 hours).

Caveats & argument

- **Cost could be higher:** self-regulation assumes comparison-shopping across sites (could double); connectivity costs not quantified. **Lower:** media consolidation (one policy covers many sites — though merged policies longer); people may care only about some threats (e.g. credit-card theft) so skip sites that don't collect that data.
- **Pilot study (behavioural):** some users believe only risk = losing **up to $50** to credit-card fraud → reading never worth it even at lower bound. Implications: (1) users **don't understand privacy risks** (even FTC said unclear whether consumers know data is collected/aggregated for ads); (2) **reduce cost of reading** — headings for skimming, hide irrelevant parts. Existing: **layered notices** (one-screen standard summary on top), **P3P** (XML), **Privacy Bird** (P3P add-on, expandable bullet-point report), **P3P Expandable Grid** (icons), **Privacy Finder** (search engine with icons; study found users **pay a premium** for more privacy-protective sites).
- **Answer to industry claim** ("people don't read, so they don't care"): sites must convey practices usably and cut reading time; if they can't, **regulation** may be needed. **Disclosure legislation alone may be insufficient** — adding text nobody reads gives transparency but "**limited practical utility**".
- **Advertising comparison:** $21 bn ads vs $781 bn time — "**out of kilter**"; not an argument to ban ads (direct-mail sales ≈ 10× cost of ads; ad spend understates market). Ads are usually an economic "**bad**" (people pay to remove them — Becker & Murphy); welfare analysis of online ads should include **cost of reading time**.

Strengths / weaknesses / links

Strength: turns "policies are too long" into a **quantified opportunity cost**; transparent assumptions; ranges; deliberately **conservative**. **Weaknesses:** US only, **2008 data** (pre-smartphone, pre-GDPR); assumes each policy read **once per site per year**; values of time (**2× wage at work, ¼ at home**) contestable; ignores that **reading is useless when policies are vague** (Pałka: even unlimited time doesn't yield answers); the **201 vs 244** inconsistency. **Links: Pałka et al. cite it** ("hundreds of hours each year"; cost of self-management > expected loss) but **flip the solution** — not shorter policies/layered notices/P3P agents (McDonald & Cranor) but **longer complete policies + LLM readers**. Place in **comprehensiveness (Arts 13–14) vs comprehensibility (Art 12)** debate. Echoes Santos (consent is a "secondary task") and van der Schyff (users spend only seconds). **Pilot's user-defined policies and**

P3P-style agents descend from the PETs McDonald & Cranor describe. On **notice-and-consent**: "notice and choice" asks the impossible; "limited practical utility" suggests more disclosure isn't the answer; undermines **rational-user assumption** (user who thinks only risk is $50 never reads → misjudges risk). **On self-management:** McDonald & Cranor — reading costs far exceed perceived losses → **not reading is rational and self-regulation has failed**; Pałka — agree on costs, but people *do* care; use LLMs; Santos — friction and dark patterns shape "choice" anyway. **Best conclusion: not reading is rational at the individual level but a regulatory failure at the system level.**

R9. IWAYA, ALAQRA, HANSEN & FISCHER-HÜBNER (2024) — "Privacy Impact Assessments in the Wild: A Scoping Review"

Background: PIAs are a central tool of **privacy by design** (build privacy in from the start). Wright's definition: PIA = "**a methodology for assessing the impacts on privacy of a project, policy, programme, service, product or other initiative and, in consultation with stakeholders, for taking remedial actions as necessary in order to avoid or minimise negative impacts.**" Should start early, continue after implementation, involve stakeholders. Grew out of **Technology Assessment**, common from **mid-1990s** (Clarke). **EU law = DPIA: Art 35 GDPR** requires one where processing "likely to result in a **high risk to the rights and freedoms of natural persons**", measured against Art 5 principles; **Art 36** = **prior consultation** with supervisory authority if high risk can't be mitigated. Authors don't strictly separate terms: Privacy (**Art 7 CFR**) and data protection (**Art 8 CFR**) are distinct Charter rights; Art 35 says "rights and freedoms", **broader than data protection** (Hallinan & Martin). "**PIAs are more than DPIAs**": PIA predates GDPR, from English-speaking countries, broad multi-dimensional privacy concept; DPIA = EU legal label, "to some extent a new label for something already existing". **WP29's own DPIA guidelines pointed to existing PIA methods** → DPIAs are part of the PIA family. **Methodologies:** New Zealand PIA Handbook (2007), German BSI (2011), French **CNIL PIA** (2015), Australian OAIC (2020), standard **ISO/IEC 29134 (2023)**. Some general, some app-specific (RFID PIA, Smart Grid PIA); some **lightweight** (short mHealth questionnaire), some **full-fledged, risk-based** (severity × likelihood) — supervisory authorities may not accept lightweight PIAs → full-fledged recommended. **Why the review:** literature contradicts itself — some call PIAs commonplace (Edwards; Bayley & Bennett; Stoddart), others little known/used (McKee; Iwaya) and rare even for mHealth apps. Earlier overviews limited: **Wright 2012** not systematic and pre-GDPR; **van Puijenbroek & Hoepman 2017** interviewed only Dutch DPOs. Aim: synthesise how PIAs work **in practice**, positives and negatives, appraise research quality, identify gaps. (Design of methods left to companion review **Wairimu et al. 2024** = R10.)

Method: scoping review (maps concepts/evidence; breadth over depth — Arksey & O'Malley), **PRISMA-ScR** + PRISMA-P protocol. **RQs:** RQ1 what literature discusses PIAs in practice; RQ2 main methodologies + positive/negative aspects in practice; RQ3 state of primary research. Searched **1 Nov 2023**: Scopus, Web of Science, IEEE Xplore, ACM DL ("privacy impact assessment*" OR "data protection impact assessment*"), no limits on year/type + **snowballing** (references backwards, citations forwards). Qualifies only if **practice/real-world application** (theory excluded) but every study type counted (opinion & practitioner experience papers). Two reviewers screened double-blind in **Rayyan**, third resolved. **746 records → 60 relevant → 42 included + 3 by snowballing = 45 studies. Thematic analysis** (Braun & Clarke), coded in **NVivo** by three researchers to consensus. Quality via **CEBMa checklists** (10 questions qualitative; 12 surveys); replication package published.

Evidence landscape (young, practice-dominated): two-thirds (30) primary research; **37.8% experience papers** (Nokia, Siemens, Vodafone); **28.9% solution proposals**; evaluation research only

"incipient"; **77.8% lessons learnt**. **UK = 12 studies (26.7%)**; **11 studies are chapters of one book — Wright & De Hert (2012)**, the field's most influential work. **Public sector 42.2%; private only 22.2%. GDPR mentioned in 60%**; **UK ICO framework most cited (37.8%)**; **62.2% after 2017**. **8 new methodologies introduced (7 post-GDPR):** PIAF (Wright & Wadhwa), **DPIA Data Wheel** (Henriksen-Bulmer), **Agile E/PIA** (Kroener), **Persona-Oriented DPIA for SMEs** (Schneider). **CNIL PIA = most used existing method, underlies PAPAYA tool**; 5 organisations used in-house methods (Nokia **PISA** template, Vodafone **Strategic PIA**). **Quality is sobering:** of 30 primary studies, **28 qualitative** (case studies; interviews; focus groups; **Delphi** study; cognitive walk-through); only **4 (10%)** surveys. Qualitative: clear questions, suitable methods, described context — but **weak on data collection** (omitted participant numbers, interview length/guides) and **analysis** (rarely said how/by how many). Quantitative: **convenience samples, no power analysis, no response rates, no validity/reliability tests, significance assessed in only one study (Dashti et al.), no confidence intervals** → generally **not generalisable.** Exception: **Wright & Wadhwa (2013)** surveyed the **27 EU DPAs, 17 replies (63%)**, mostly free-text opinions.

13 positive aspects (43 studies; ordered by frequency, not importance):

1. **Legal compliance & accountability** (most frequent): meet obligations while pursuing business goals; demonstrate compliance in audits; basis for discussion with regulators/public; **formal sign-off** by owners/managers/privacy officers/executives; regulators help via guidance (WP29 "high risk").
2. **Protecting individuals & managing risk:** identify threats/controls focused on data subjects; force organisations to justify data collection; raise developers' awareness via risk matrices; **bridge legal principles and engineering**; work best integrated into general risk management with **privacy risk owners**.
3. **Good process: living document** (refined, reviewed); start early; **scope proportionate** to size, data sensitivity, intrusiveness (guards against **scope creep**); **independent assessors**; reuse past PIAs/templates (CNIL); **stakeholder consultation** (internal interdisciplinary experts + senior management buy-in; external public consultation, data subjects/representatives, regulator feedback).
4. **Transparency & culture:** PIAs force transparency (Clarke); reports should be **published**, easy to find, ideally in **central repositories run by supervisory authorities**; published PIAs build trust/reputation; self-assessment & training build **privacy culture**; **ISO/IEC 29134** supports standardisation. **Business case:** benefits outweigh costs, fixing at design stage cheaper, privacy = competitive advantage.

17 negative aspects (39 studies; mirror the positives):

- **Methods (most frequent):** risk assessment of new tech = "**shifting ground**" (risk never fully known); methods "not business friendly", "too onerous", "too dense"; little proven effectiveness; **subjectivity** (depends on assessor skill; likelihood/severity "vague").
- **How conducted: poorly conducted**, inconsistent, unplanned; home-made methods inadequate for GDPR; risk analyses miss issues like **law-enforcement access**; **disregard for data subjects** (focus on risk to the organisation); worst = **perfunctory PIAs** (ceremonial, pro forma, "put on a shelf", or ***ex post facto*** after design fixed); even good PIAs fail at **implementation** (clients reject recommendations or press assessors to mask core issues).
- **Organisational capacity:** lack of management support, internal audit, experts; confuse **privacy with security**; unsure who is **processor vs joint controller**; costs/delays hurt **start-ups/SMEs**; even DPAs see PIAs as burden; meaningful PIA disrupts internal workings (arguably the point).

- **Independence:** assessors have **conflict of interest** (livelihood depends on pleasing those who pay); government political barriers (privacy vs efficiency/national security; pressure "to get on" with policy).
- **Openness & regulation:** poor public consultation (comments only after legislation drafted; civil society often uninterested); government PIAs often unpublished; published private-sector PIAs "**almost non-existent**" (fear publication chills honest self-criticism); no central registry, no duty to publish, no accountability for implementing mitigations; regulators lack resources and are weakened by defunding; in many jurisdictions PIAs only "**encouraged**" → depend on controller's goodwill. **Art 35 closed that gap** in the EU for high-risk processing.

Discussion — arc: pre-2012 few empirical studies, mostly government guidelines; **2012 first GDPR proposal introduced DPIA duties**; risk-based methods (RFID PIA, **PRIAM** — De & Le Métayer 2016); most studies post-2017. **22 of 30 primary studies (73.3%) cite GDPR as motivation** → results hard to transfer outside EU. GDPR answers several negatives: controller responsible, DPO monitors, DPIAs mandatory for high-risk and **before processing starts**. **Four research gaps (Miles's typology):**

- **Evidence gap:** disagreement on effectiveness, whether PIAs should be mandatory, how to streamline while rigorous, whether real independence possible → "**a one-size-fits-all PIA approach is unlikely**".
- **Methodological gap:** mostly case studies/expert opinion (low in evidence hierarchy vs controlled studies, cohort studies, RCTs).
- **Empirical gap:** many proposed methods (like privacy engineering generally) **never evaluated in real practice**.
- **Population gap:** over-reliance on **WEIRD** (Western, Educated, Industrialised, Rich, Democratic); only **6 studies (15%)** from elsewhere (Brazil, India, Indonesia). **13 book chapters lack formal peer review → only 32 studies peer-reviewed. Two arguments for practitioners/policymakers:** (1) **A distorted PIA is itself a risk** — misleading PIA leaves risks undetected → unsuitable measures, unlawful processing, later fines; some PIAs commissioned for marketing/"**fig leaf**"; teams "professionally blinkered"; **checklist approaches (UK ICO, CNIL) tempt box-ticking** (Bieker et al.). (2) PIAs should evolve into **Fundamental Rights Impact Assessments (FRIAs)** — risks extend beyond personal data to fairness, society, planet; **DSA Art 34** already requires systemic-risk assessment (civic discourse, elections, minors); **AI Act** (Parliament's approach) requires deployers to do FRIAs (marginalised groups, environment) → PIAs/DPIAs become pieces of a holistic FRIA integrated into risk management. Conclusion: PIAs must become **evidence-based** — one of the most promising paths in **Empirical Privacy Engineering** (empirical methods to evaluate privacy engineering); major frameworks need rigorous independent evaluation; **Human Rights Impact Assessments** even less understood.

Assessment & links: Strength: first systematic map of PIA *practice*; includes experience papers (practitioner voices); balanced about weak evidence. **Weaknesses:** relies on **lower-level evidence** (opinion papers, book chapters); **11 studies from one 2012 book**; **prevalence counts ≠ importance**; mostly European/British; computing databases may miss the legal literature. **Debate: DPIAs — real protection or box-ticking?** *For:* accountability, early privacy by design, risk ownership, transparency if published, Arts 35–36 mandatory with clear roles. *Against:* perfunctory, late, conflicted, checklists, unpublished, poorly supervised. *Remedies:* independence + sign-off, publication + central registries, stakeholder consultation, evaluation research, move to FRIAs. **Wider theme: symbolic compliance** — same critique made of **consent banners (Santos)** and **unread privacy policies (McDonald & Cranor)**. **Links:** scoping review R5 recommends researchers use DPIAs — yet R9 shows DPIAs themselves poorly

evidenced. **DPC guide:** processors must **assist with DPIAs under Art 28(3)(f)**; confusion over processor vs joint controller links to Art 28. **Pilot's risk analysis = policy-level cousin of PRAs; Le Métayer co-authored PRIAM. Companion Wairimu et al. (R10)**: same conclusion — weak evidence, need empirical privacy engineering.

R10. WAIRIMU, IWAYA, FRITSCH & LINDSKOG (2024) — "On the Evaluation of PIA and PRA Methodologies: A Systematic Literature Review"

Background: privacy by design is now law: by **2023, 162 countries had privacy laws** (Greenleaf); **GDPR Art 25** (data protection by design and by default) and **Art 35** (DPIA for high-risk processing). Same Karlstad group as R9; use Wright's definition of PIA and "PIA" to cover DPIA. **PIA** from anglophone countries (US, NZ, Australia, Canada) = process covering many aspects of privacy; **DPIA** = GDPR legal requirement; WP29 pointed to CNIL, RFID PIA, UK PIA as DPIA examples. **Problem:** persistent criticism — little **rigorous evaluation**; overly complicated and time-consuming; steps generic/abstract; deciding level of risk vague, depends on assessor skill; shortage of **historic data**. Same problems affect the two techniques inside a PIA:

- **Privacy Risk Assessment (PRA)** = analyses/evaluates risks and estimates impact. Leading example: **PRIAM** (De & Le Métayer).
- **Privacy Threat Modelling (PTM)** = identifies/lists threats and controls. Leading example: **LINDDUN**.
- **Hybrids** covering security and privacy: **SPIA** (security and privacy impact assessment), **PSTM** (privacy and security threat modelling). **Generalised PIA process (5 steps):** (1) **threshold analysis** (is high risk likely → is full PIA needed?); (2) system description, usually with **data flow diagrams (DFDs)**; (3) **PRA** (core of the PIA, optionally supported by threat modelling); (4) risks prioritised and mitigated with controls; (5) documented in a report kept as a **living document**. **Gap in earlier reviews:** Georgiadis & Poels (13 PIA methods for big data, mostly DPA documents); Xiong & Lagerström and Tuma et al. (threat modelling; mix security & privacy; note "the immaturity of empirical research in the software engineering community"). **None surveyed scientific PIA/PRA/PTM methods; none distinguished validated from evaluated; none appraised study quality. RQ1:** what validated/evaluated PIA and PRA techniques exist in the scientific literature? **RQ2:** how and to what extent validated/evaluated?

Method: systematic literature review (SLR), **Kitchenham** guidelines (planning, conducting, reporting), PRISMA-P protocol in Git repo + replication package. Searched **Scopus, Web of Science, IEEE Xplore, ACM DL** with 7 terms ("privacy risk assess*", "privacy impact assess*", "data protection impact assess*", "privacy threat model*"; IEEE's 8-wildcard limit forced splitting). **Google Scholar excluded** (no incremental query optimisation, Boolean search, bulk export; results can't be reproduced). **991 results → 309 duplicates removed → 682 screened (double-blind, Rayyan, third resolves) → 98 full texts → 34 → +5 snowballed = 39 studies.** Excluded: not English; only listed privacy risks; analysed security alone; low quality (no research question/method); lacked ***a priori*** risk analysis (at design stage); PIA studies that didn't analyse the method itself. Extracted: method name/scope; qualitative vs quantitative risk analysis; how validated/evaluated and extent (e.g. # surveys/interviews); whether it assessed **privacy harms**; conclusions. **Studies:** span **2004–2022**, peak **2018–2022** (GDPR). **69% conference papers**; Springer **41.02%**. **Solution proposals most common; evaluation research least; 26% tested methods proposed by others.** By category: **16 PIA, 9 PRA, 11 PTM, 2 PSTM, 1 SPIA.** Threat modelling included

because it also identifies privacy risks at design stage, uses DFDs, and LINDDUN is often compared with PIAs.

"Validated" vs "evaluated" — THE central distinction (from Wieringa et al.)

- **Validation** = assessing a method **without real-world use**: authors try it themselves on an **invented/hypothetical scenario**, experiment, simulation/prototype, or **paper comparison**. Shows coherent and applicable — **not that it works when real organisations use it**.
- **Evaluation** = analysing/applying the method **in real-world practice**: genuine **case study** inside a company, **action research** with practitioners, other empirical studies. = tested in the conditions it was designed for.
- Wieringa also recognises **solution proposals** (method presented without testing) and **philosophical papers**.
- **Examples:** two-layer DPIA of **Timón López et al.** tried only on invented use case → **validated**. **DPIA Data Wheel** (Henriksen-Bulmer et al.) used in a **3-month case study in a charity (40 charities, 29 staff trained)** → **evaluated**.
- **Sharp critique of "case study":** six method papers call their testing a "case study" but they are **illustrative scenarios built by authors**. **Yin:** case study = "an empirical inquiry that investigates a contemporary phenomenon… in depth and within its real-world context". By that definition these are **validation, not evaluation — better called "use cases"**. Matters because readers may assume method proven in practice when only shown on paper (results hard to transfer to industry).

Findings — PIA methods (10; best-tested group)

50% evaluated, 20% only validated, the rest untested when proposed. Evaluated: **Ahmadian et al. model-based PIA** (3 industrial case studies in EU **VisiOn** project, compared with CNIL, UK PIA, BSI); **Oetzel & Spiekermann seven-step PIA** (system characterisation → privacy targets → protection demand → threats → controls → residual risk → report; evaluated via action research & workshops with IT experts); **Todde et al. DPIA for hospital information systems** (public healthcare enterprise); **DPIA Data Wheel** (based on **contextual integrity**); **Friedewald et al. five-phase method** (tested in **12 organisations**, start-ups to public administrations; extends Bieker et al.'s high-level DPIA operationalising Art 35 — not evaluated at first, later evaluated via Friedewald). **Vemou & Karyda six-step process and Ivanova's DPIA for AI systems:** neither validated nor evaluated. **Compared with Art 35(7) GDPR minimum content:** (1) **systematic description of the processing and purposes**; (2) **necessity and proportionality**; (3) **risks to rights and freedoms of data subjects**; (4) **measures to address risks.** All ten assess risks (core of a PIA); **only half cover measures** (Vemou & Karyda argue suggested measures can mislead; authors reply sector-specific measures e.g. AI/data provenance are a useful knowledge base). Some miss elements (Ivanova treats description as out of scope; two omit necessity & proportionality). **Few PIA methods assess privacy harms** — though harm distinguishes privacy risk from security risk (**Recital 75**: physical or non-physical harm of varying likelihood and severity). **Oetzel & Spiekermann and Ahmadian assess harmful activities drawing on Solove's taxonomy; Friedewald brainstorms harms.** Sector-specific PIAs (healthcare, charities) supported by WP29 and **Art 35(1) + Recital 92** (single assessment for similar processing operations). **No common methodology → controllers choose one aligned with WP29 guidance.** The one **SPIA (Makri et al.)** adds security risks, organisational characteristics, metrics, but rests on OECD principles authors find too abstract; adds overhead; neither validated nor evaluated.

Findings — PRA and threat modelling

- **9 PRA methods: more advanced on harm — 77.8% assess harms; PRIAM** = reference model: **7 components** (system, stakeholders, data, risk sources, feared events, privacy harms, privacy weaknesses); uses **harm trees** (trace how a feared event leads to harm); groups harms into **5 categories: physical, financial, societal, dignity, psychological**. Variants: Wairimu & Fritsch (patients after data breach; actual harms), Alshammari & Simpson (refined harm trees). Push to **reduce subjectivity**: qualitative = criticised as unstructured; semi-quantitative scoring = subjective; quantitative (**Wagner & Boiten; Hart et al. fuzzy set theory; Cronk & Shapiro probabilistic FAIR-P**) claim objectivity but **untested**. **88.9% of PRAs only validated; sole evaluated = Hong et al. ubiquitous computing method** (lo-fi prototypes, interviews with 20 people, test with 3 users). **PRAs more mature on harm than PIAs but barely tested in practice.**
- **Threat modelling — LINDDUN** (privacy counterpart of **STRIDE**: Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege). LINDDUN = acronym of privacy threat categories; protects properties: **unlinkability, anonymity & pseudonymity, plausible deniability, undetectability, confidentiality, content awareness, policy & consent compliance**. Provides measures but **no risk evaluation** (critics fault it; authors say unfair as risk assessment is outside threat modelling scope; Wuyts et al. suggest adding risk quantification of QTMM). **Most evolved:** now **LINDDUN GO** (novices), **LINDDUN PRO** (experts), forthcoming **LINDDUN MAESTRO** (model-driven). **P-STORE** evaluated via usability survey of **59 requirements engineers**. Hybrids: **QTMM** combines STRIDE with privacy goals, uses attack trees, evaluated; **Treacy et al.** STRIDE + LINDDUN for **Internet of Medical Things** — neither validated nor evaluated (promising but unproven).

How testing was done & how good

Validation methods found: invented use cases, illustrative scenarios and examples, realistic scenario, comparative analysis, experiments, misnamed "case studies". Evaluation methods: genuine case studies, action research, empirical studies, classified with **Ivarsson's rubric** (contribution to real-world relevance). **Only 9 of 39 studies evaluated a method; 4 methods neither validated nor evaluated.** Validated methods mostly PRAs (8 of 9); PIAs had fewest merely-validated (2 of 10). **Quality (CEBMa):** all evaluations had focused question, suitable design, clear context — but most **weak on data collection and analysis** (Oetzel & Spiekermann simply say "interviews"); **only two studies described data collection; only the LINDDUN evaluation passed every quality question → model for future research.** Independent comparisons: one found **CNIL did better than ISO/IEC 29134**; another comparing guidance from ten jurisdictions rated **Ontario, Alberta, UK, Victoria best. CNIL and LINDDUN most analysed → most popular.**

Conclusions/agenda/criticism

Most methods only validated with illustrative/hypothetical examples; empirical and practical gaps hinder industry uptake — **LINDDUN the exception**. Why evaluation is rare: needs **industry collaboration, ethics approval, NDAs**; realistic designs hard to build. Expect more **system-specific methods (esp. AI and LLMs)**. **Agenda (3 parts):** (1) evaluate validated methods (**PRIAM, PriS**), independently replicate evaluated ones (**LINDDUN, DPIA Data Wheel**), build quality requirements into designs; (2) **compare PRA methods** (never done), **integrate PRAs into PIAs, include actual privacy harms**; (3) explore/compare **hybrid** methods. **Threats to validity:** peer-reviewed only, no books/chapters; didn't record how many studies each exclusion criterion removed. **Further criticisms:** excluding book chapters omits much PIA-practice literature (R9 relied on it heavily); review ends 2022; validation/evaluation line can blur; quality checklists favour **well-reported** studies over **useful** ones. **Links:** companion to R9 (R9 = how PIAs work

in organisations; R10 = how scientific methods are tested; **both conclude evidence is weak → need empirical privacy engineering**). **Validation vs evaluation turned on other readings: Pilot** only validated (illustrative ANPR scenario) → not evaluated; **Najdi's conceptual design not even validated**; Pilot contrasts its automatic analysis with manual harm trees of De & Le Métayer's PRIAM. Scoping review R5 recommends PRA/DPIAs — "must now reckon with how little evidence shows these methods work in practice".

R11. CUSTERS & VRABEC (2024) — "Tell me something new: data subject rights applied to inferred data and profiles"

Computer Law & Security Review, 2024.

Problem — rights that tell people only what they already know. Three kinds of data in the data economy: (1) data people **give**; (2) data **collected without awareness** (Google sued over tracking in **Incognito mode → $5 bn settlement 2023**; post-*Dobbs* fears about pharmacy data); (3) **new data analytics generates — inferences, categories, risk profiles = "ascribed personal data"** (inferred data + categories/profiles). Ascribed data is often **genuinely novel**; reveals how controller views/assesses person; real legal/practical effects → exactly what a data subject would most want to know. **The dilemma:** GDPR rights clearly apply to data obtained **directly/indirectly** from people (mostly already known to them). Read by wording, most rights **barely reach inferences/profiles** the controller generates → exercising them "**won't tell them anything new**". If rights don't cover ascribed data → uninformative; if they do → hard to delimit; clash with **trade secrets, freedom to conduct a business, privacy of other data subjects**. Tech companies favour narrow readings (**TechNet** lobbied against broad access right in **Oregon**); **California, Colorado, Washington** state laws explicitly include inferences in "personal information". **Is ascribed data personal data?** Usually yes when ascribed to an **identified/identifiable person**. A **group profile** ("beer buyers buy diapers", "55% of teenagers are gamers") **isn't personal data until applied to an individual** ("the probability that John, a teenager, is a gamer is 55%"). **Method:** four classic EU interpretation methods — **grammatical** (text), **systematic** (context), **teleological** (purpose), **historical**. Narrow grammatical reading covers only "**lower-order**" data (needs no analytics); broad teleological reading also covers "**higher-order**" data (inferences, predictions, risk profiles). **EDPB and CJEU appear to support narrow readings in some cases.** Paper offers (1) a **taxonomy** of personal data, (2) a systematic framework mapping each GDPR right (**Arts 12–22**) onto each data type.

Taxonomy (4 types):

1. **Directly obtained** = provided by data subject (address, DOB; social media, sensors, wearables, log-ins) — collected **from** the subject → **Art 13**.
2. **Indirectly obtained** = existing data from another source, typically a **data broker** (**Acxiom: files on 2.5 bn people, ~11,000 attributes; Experian**) — collected **on** the subject → **Art 14**.
3. **Inferred** = new data distilled from available data (age worked out from DOB; health, credit score, life expectancy). **Kosinski: Facebook likes reveal ethnicity, sexual orientation, religion, intelligence, substance use.** Generated by controller.
4. **Categories and profiles** = group labels (**Facebook's four user types: relationship builders, window shoppers, town criers, selfies**; risk groups); also generated by controller. **Crucial:** the type depends on **how obtained, not what it says.** DOB given to A = directly obtained for A; shared with B = indirectly obtained for B; A/B computes age = **inferred**. Had the person stated her own age, it wouldn't be inferred. **Incorrect data is still personal data** (else rectification pointless: DB records

John as female = personal data about John, can be rectified). Inferences are **probabilistic and often unverifiable** (predicted cancer risk). **Profiling:** by **classification** (predefined classes) or **clustering** (groups emerge). **Distributive** profiles true of every member; **non-distributive** true of group but not each individual. **Art 4(4)** = automated processing evaluating personal aspects (captures inferences and profiles but **ignores non-automated profiling** — manual statistics/stereotyping). **Feedback loops:** broker data already enriched with inferences re-profiled → same input counted twice (income → credit score → insurance premium) → **self-fulfilling prophecies** (hot-spot policing — O'Neil: amplifies inequality). Being categorised → fewer offers, higher prices, exclusion, damaged reputation — yet people often **don't know the practice exists, how many categories, or which one they're in.** GDPR partial answers: **Arts 13(2)(f), 14(2)(g), 15(1)(h)** "meaningful information about the logic involved" (basis of contested "**right to explanation**" Wachter et al. argue doesn't exist); **Art 21** objection to profiling. **Profiles that aren't personal data fall outside GDPR** → controllers prefer **de-identified data**; **group privacy** concerns remain.

Right-by-right:

- **Information (Arts 12–14)** = "**primus inter pares**" — cornerstone of transparency; without it no other right exercisable. Procedural info (controller identity, DPO, purposes, legal basis, recipients, storage). **Art 13 can't apply to inferred data/profiles** (subject cannot provide what she doesn't have). **Art 14 may apply** if inferences treated as "self-obtained" by controller or obtained from another controller. Only **two hooks:** (1) **WP29 transparency guidelines**: where purpose involves creating inferred data, **purpose and categories of inferred data must be communicated**; (2) **duty to explain logic of profiling (Arts 13(2)(f), 14(2)(g))**. Both give **clues, not the profile**. CJEU in ***SCHUFA*** said in passing rights should be read in light of purpose of Art 22 (protect against risks of automated processing incl. profiling). **Verdict: ambiguous for inferred data (possible via Art 14), only partial for profiles.**
- **Access (Art 15)** = **substantive**: tells what data is processed, confirmation, **copy (Art 15(3))**. Plainly covers directly/indirectly obtained, incl. "**shadow profiles**" of non-Facebook members built from data collected through like plug-ins. ***Österreichische Post*** **(C-154/21):** access includes **identity of specific recipients** on request. **Inferred data in scope** — **Recital 63** mentions medical records incl. diagnoses & physicians' assessments; EDPB access guidelines agree. **Two limits:** (1) **case law:** AG Sharpston in ***YS and Others***: "only information relating to facts about an individual can be personal data… a legal analysis is not"; ***Nowak***: examiner's notes are personal data but **exam questions are not** → applied to analytics: inputs and inferences personal data, **model not** → can't be accessed (authors respond cases non-digital, outdated; pending **Austrian reference C-203/22** may clarify). (2) **Exceptions: Art 15(4)** copy must not adversely affect others; **Recital 63** protects **trade secrets, IP, software copyright**; reverse-engineering risk; practical burden; **balancing largely at controller's discretion**, almost no case law beyond a **2014 BGH** and **2018 Dutch Supreme Court** decision. AG Opinion in *SCHUFA*: trade secrets may justify not disclosing the algorithm, **never an absolute refusal**; EDPB/WP29: let people check profile automatically. **Art 15(1)(h)** covers **logic**, not the actual profile or category; "who else is in my category?" can't be answered (involves others' data). **Access covers inferred data and profiles only partially.**
- **Rectification (Art 16)** — correct inaccurate/complete incomplete (supplementary statement), alongside accuracy duty **Art 5(1)(d)**. Factual data easy; subjective data → subject's word prevails. ***TransUnion v Ramirez*** **(2021, US):** wrongly flagged on terrorist (**OFAC**) list, discovered only when buying a car. Inferred data harder: **error margins** — 95%-accurate inference may be factually wrong about you yet statistically right; unclear which prevails; supplementary statement doesn't help (only incomplete, not inaccurate). Some predictions (**75% cancer risk, credit score**) **unverifiable**

even later; verifying how inferred needs others' data + controller's tools (conflicts with others' rights); controllers may "**know the data subject better than she knows herself**". CJEU in *Nowak* and *YS* did **not** extend rectification to analytics tools/logic; opinions/assessments challengeable only where a procedure to contest exists; supplementary statements sit in separate systems not used in analytics (Art 16 doesn't require they be). **Rectification covers neither inferred data nor profiles; for unverifiable data erasure may offer more.**

- **Erasure (Art 17)** — e.g. consent withdrawn, subject's interest outweighs controller's legitimate interest; **does cover inferences**. **Four problems:** (1) inferred data seems "**owned**" by controller (tied to controller's model) → dilutes subject's interest; (2) where data shared, controller need only inform recipients (**Art 17 + Art 19**), subject to disproportionate-effort exception; **Art 11(2)** imposes no duty to re-identify de-identified data; (3) **identifiability gap** — de-identified models/profiles fall outside the law even if discriminatory; one person's erasure barely changes a trained model → real change needs **collective action**; (4) **deleted data can simply be re-inferred** (central government DB re-populated a municipality's deleted data every night — "technology does not keep up with the law"). ML best practice = "**exact erasure**" (delete from model and training data). **Erasure covers inferred data but not profiles.**
- **Restriction (Art 18)** — marking data to limit future processing (Art 4(3), Recital 67). Grounds: accuracy contested; processing unlawful; controller no longer needs data but subject does; objection under Art 21 pending. Contested accuracy unusable for inferences (accuracy can't be assessed); unlawful/obsolete → erasure usually preferred. **Redundant and underused.** Practical use for inferences: together with **objection (Art 21)**, esp. marketing → covers inferred data and profiles **only via Art 18(1)(d)**.
- **Portability (Art 20)** — receive data "**provided**" in reusable format. Includes name/email/address and **observed** data (location, logs) but **excludes derived data from analysis (e.g. smart-meter profiles)** — generated by controller not provided. **Reputation scores = grey zone** (Airbnb reviews moved to Couchsurfing?; Commission criticised WP29 as too data-subject-centric). **Solove (sceptic):** portability assumes healthy privacy market; authors: also serves transparency and fairness → excluding inferences concerning. **Probably doesn't cover inferred data; doesn't cover profiles.**
- **Objection (Art 21) & automated decisions (Art 22):** the rights that **clearly reach inferred data and profiles.** Art 21: object to processing based on public interest/legitimate interests; **absolute for direct marketing incl. profiling**; **Art 21(5)** objection by automated means (e.g. Google's personalised-ads switch). Outside marketing, controller can override with **compelling legitimate grounds** → authors suggest broadening absolute right to cover more processing of inferred data (WP29 Opinion 06/2014 favoured wider opt-outs; footnote: CJEU ***Meta Platforms* (C-252/21)** — profiling for personalised advertising "cannot in principle rely on legitimate consent" — paper's wording). **Art 22**: right not to be subject to **solely automated decisions with legal or similarly significant effects**; WP29 and CJEU in *SCHUFA* read as **prohibition** (protected by default); gives some control over inference; **Art 22(3)** some understanding. But **doesn't address systemic discrimination** (algorithms replicate/amplify prejudice); **Solove: automation isn't the key problem, inference is. Recital 71** urges appropriate statistical procedures, error correction, preventing discrimination; Wachter & Mittelstadt propose "**right to reasonable inferences**".

Summary table: Directly/indirectly obtained: every right applies. **Inferred:** information **ambiguous**; access **partial**; rectification & (probably) portability **no**; erasure, restriction (Art 18(1)(d)), objection, Art 22 **yes**. **Categories/profiles:** information & access **partial**; rectification, erasure, portability **no**; only restriction (18(1)(d)), objection and Art 22 **fully** reach them. → **On a textual reading and in practice,**

rights fully cover provided data but reach inferences/profiles only through profiling-specific Arts 21–22 and "logic" duties (Arts 13(2)(f), 14(2)(g), 15(1)(h)).

Case for a broader reading: controllers resist for **practical** (time, cost, extraction effort), **business** (trade secrets, IP, competitiveness), **legal** (others' rights) reasons. **Teleological argument points the other way:** rights exist to put people **in control**; including inferences shows what is done with their data and which decisions follow. **Stages-of-processing argument (original):** processing runs **input → throughput (analysis) → output (results) → outcome (decisions)**, yet rights mostly reach only **input**. Narrow reading gives rights "**little or no meaning**" for inferences ("it would not tell data subjects something new"). Real empowerment needs all four stages + ability to **act** (delete, correct, stop) — mislabelled "terrorist" example. Doesn't ignore controllers: **Art 23 restrictions** still apply; starting point should accommodate the vulnerable. **Proposals:** textual reading doesn't deliver protection; broader reading should cover all stages. Objections answered: practical — "if the data can be extracted for decision-making, they can also be extracted for data subjects"; business — **aggregate/generalise** info; describe **processing and its meaning** rather than technical model details (more useful anyway); disclosure revealing disliked practices is no reason to refuse; legal (others' data) — **let DPAs act as trusted third parties** to scrutinise inferences/profiles; DPAs have powers/expertise but **can't invoke rights on behalf of data subjects** → propose **amending GDPR** to allow this, with subjects' consent. **Strengths:** clear taxonomy; systematic right-by-right grid; original stages argument; practical proposals. **Weaknesses: purely doctrinal** — no empirical study of actual **DSARs** despite framing; relies on contested/pending case law; trade-secret balancing left vague; DPA-as-proxy depends on **under-resourced** authorities. **Links: Najdi** lists 11 requirements (IR1–IR11), admits **IR10 (objection to profiling) can't be guaranteed once ML model leaves the enclave** — Custers & Vrabec explain legal side (models not personal data; one erasure barely affects model; data re-inferable). **Pałka's "inference economy"** (food/music → race/politics) = exactly inferred data; comprehensive policy would disclose purposes such as profiling (matches WP29 rule on disclosing categories of inferred data). ***Planet49*** = cookies tracking for interest-based ads = **input stage** of profiling pipeline; **Pilot** handles purposes like "profiling" at policy level but leaves inferences for future work. Like McDonald & Cranor: current transparency gives little actionable info — they focus on **cost**, C&V on **scope**. Sharpen critique of **rational user** (can't verify a 75% cancer risk). **Trust in DPAs as third parties contrasts with Dove & Chen's controller self-assessment backed by regulator and Iwaya's conflict-of-interest concerns.**

R12. LINDGREN, KAREGAR, KANE & PETTERSSON (2021) — "An evaluation of three designs to engage users when providing their consent on smartphones"

Karlstad University; Behaviour & Information Technology.

Background — identity providers and the consent gap: users often register with a service provider (**SP**) via an **identity provider (IdP)** ("log in with Facebook") — convenient (fewer passwords, data auto-forwarded), but the IdP learns which services you use and when, and sees data in plaintext → social-network IdPs can build detailed profiles. Study grew from EU **Horizon 2020 CREDENTIAL** project: privacy-preserving cloud IdP that can't see data in plaintext (**proxy re-encryption**), delivered through **CREDENTIAL Wallet app**. Starting point: **technology alone not enough if users don't understand data flows.** Consent here = **permission (authorisation) dialogue** ("may the app share certain data?"). Prior work: dialogues offering no choice or only opt-out make it hard to notice/control data; users want to **select data themselves** rather than have it pre-selected. **Legal hook — Art 4(11) GDPR:** consent must

be specific, unambiguous, freely given by an **affirmative action**. GDPR accepts ticking a box or choosing settings as such an action but says **nothing about how effective** they are at producing genuinely **informed** consent → **gap between legal requirements and interface design.** Earlier (Karegar et al. 2018b): checkboxes didn't help users notice/remember details; **drag-and-drop improved recall vs opt-out/pre-selected Facebook-style dialogues (Karegar 2018a).** Nobody had compared drag-and-drop with other active opt-in designs. **Theory — Sundar's (2007) model of interactivity effects:** source, message and **medium interactivity** (the interaction technique: how users access/select info). Different techniques change how users evaluate, engage and process content → cognition/attitudes. Sundar et al. 2014 on desktop websites (click-to-download, dragging, hovering, sliding, zooming, flipping): some techniques (e.g. sliding) improved recall. **Costs:** Wang, Grossklags & Xu 2013 — checkbox-enabled Facebook dialogues → users released less info, opted out more (attention not measured). **Bravo-Lillo 2013 "attractors"** in security warnings — inhibitive attractors (swiping over text, retyping) cut risky installations but took more time (swiping/typing slowest). **Assale 2019** — rich healthcare e-consent with emotional feedback: healthcare workers saw extra interaction as incompatible with workflow → **risk of over-burdening users.** Drag-and-drop idea goes back to **Pettersson et al. 2005 (PRIME)** (break habituation to "OK/Cancel" buttons) and **JITCTAs (Patrick & Kenny 2003, PISA)**. Gap: nobody compared usability of alternative active-engagement designs on **mobile**.

Method: between-subjects; **60 participants** randomly assigned to 3 groups of 20: **checkboxes (control, common practice), drag-and-drop (DAD), swiping.** Prototypes built in **Axure**, tested on **Samsung S6**. Each participant **role-played a persona** subscribing on a laptop to fictitious website **PhotoHex**, using CREDENTIAL Wallet as IdP: opened app on phone, "scanned" fingerprint (clicked icon), selected data on authorisation dialogue, accepted, saw confirmation on website. Website requested **3 mandatory items (full name, email, DOB)** and **2 optional (profile photo, personal interests)**. **Afterwards:** questionnaire covering demographics, **SUS (System Usability Scale)**, **IUIPC (Internet Users' Information Privacy Concerns: control, awareness, collection; 10 items, 7-point Likert, scored 10–70)**, and recall of data shared and purposes. Coffee coupon; Swedish Research Council principles; informed consent; persona = no real personal data. **Participants:** 18 women, 41 men, 1 undisclosed; mean age 25.8 (85% aged 19–29); all at university; education didn't correlate with performance. **Mean IUIPC 55.78 (min 34, max 70)** → fairly privacy-concerned; group means: swiping 51.55, DAD 56.40, checkbox 59.40. **Usability = ISO 9241-11:2018 (3 components): Effectiveness** (accuracy & completeness → task completion + recall); **Efficiency** (resources relative to results → **time from typing credentials to seeing confirmation**); **Satisfaction** (**SUS**: ten 5-point items, 0–100; **<50 unacceptable, >50 OK, >70 acceptable, 85 excellent** — Bangor et al.; new authentication systems should reach ≥70 — Ruoti et al.). **Awareness metrics** (Ronen et al.; Karegar et al.): participants saw list of **14 data types**, marked each shared / not shared / not sure. **Precision** = correctly marked shared/not shared ÷ all marked shared/not shared; **Recall** = correctly marked shared ÷ number actually shared; **Uncertainty** = share of "not sure". **3 designs** — shared card-based layout showing SP identity, mandatory data with general purpose, optional data with general purpose; **sticky footer** (Cancel, Accept, number selected); each item an icon with label (chosen via mini-survey); interactive tutorials via Help (?) icon. Differed only in action: **(1) drag-and-drop** — drag each icon into its own drop zone, undo available; **(2) swiping** — swipe each item left→right, guided by pointing-hand emoji + arrow (**signifier** = visual cue telling users what to do), clear before/after state; **(3) checkbox** — common practice, control. **Results:** all 60 completed. **Time: checkbox fastest 93 s; DAD 129 s; swiping 132 s** (DAD +36 s). Ranges 43–275 (checkbox), 51–592 (DAD), 42–284 (swiping). **Satisfaction (SUS):** all "good"; **DAD highest 81.00**, checkbox 79.25, swiping 72.63. **Recall: swiping 0.93, DAD 0.92 vs checkbox 0.84 — but with only 20 per group, NOT statistically significant. Precision similar** (0.85 swiping, 0.88 DAD, 0.89 checkbox);

uncertainty lowest for checkbox (0.10 vs 0.15 DAD, 0.20 swiping). Time did not significantly correlate with recall. **Two data types excluded** because they exposed **wrong mental models:** many believed their **fingerprint** was sent to IdP and SP; many said they shared DOB but not **age** (implicitly shared). **≤7 participants could recall processing purposes** → users focus on data, not purposes/conditions. **Observed design problems:** 3 DAD users first mistook drop zones for checkboxes; **11 of 20 swipers briefly confused; 4 swiped wrong direction**; only **3 opened tutorial**; signifiers for mandatory data weak in all three; some tried to skip mandatory items without noticing **Continue** disabled (the 592-s DAD user missed that DOB was required). **Correlations:** gender & education unrelated to usability/awareness; age correlated with time (**0.361, p ≤ .01**; under-30s finished in <100 s); **IUIPC negatively correlated with uncertainty (−0.256, p ≤ .05)** → more privacy-concerned = more certain about what shared. **What it means:** earlier work used a confirmation screen to slow users (Karegar 2018b) — better to use that time actively. Better recall likely from **avoiding automated behaviour** (habituation to checkboxes used for T&Cs everywhere) — but study didn't test whether new designs resist habituation themselves. Need stronger signifiers for mandatory vs optional, error messages, **tutorials shown by default the first time a new gesture is used**; unclear whether effectiveness lasts once users get used to them. **Legal implication (heart of paper): active engagement can itself be the affirmative action Art 4(11) requires; the most efficient method is not the most effective or satisfying.** If a design doesn't produce real awareness, SPs **can't rely on the consents they collect** → fines and loss of trust. Takes on Bauer et al., Egelman & Karegar (content of consent forms barely affects understanding): authors say **lack of attention** → users guess from preconceptions; if attention improves, content matters more. **Conclusion:** checkboxes speedy but don't engage like DAD and swiping; newer methods positively affect satisfaction; design patterns notably affect perceived usability. Future: whether more time = more attention (eye-tracking, imprecise); informed consent also needs awareness of **purposes, retention, revocation (Art 13)** — open whether users attend to those if engaged only in selecting data; "not sure" answers may signal **distrust of IdP/SP**: "Until we can find ways to differentiate… the legal requirements of informed consent will be under the control of the service providers." **Strengths:** directly tests what an "affirmative action" should look like using standard metrics (ISO 9241-11, SUS, IUIPC); honest about non-significant results. **Limitations (some admitted):** persona = no real data at stake (reduced attention); **student participants**, not representative; recall can be biased by preconceptions (triangulate with eye-tracking); **small samples**, recall difference **not significant**; **recall ≠ understanding**; covers only **selection of data**, not purposes (almost nobody remembered). **Links:** answers question *Planet49* leaves open — Court said active choice needed and ticking an unticked box suffices, but **which active behaviour actually yields informed consent?** Ticking a box is lawful but may be the **least engaging** option. Complements Santos's heuristics with empirical data; wrong fingerprint mental models echo Santos's cookie misconceptions. **Friction debate:** more engagement costs time — DAD +36 s vs checkboxes, just as Kay & Terry's textured agreements raised reading time ~7 s → ~37 s. Gains real but modest; counterpoints: **McDonald & Cranor** (time is the cost), **Assale** (hospital workflow), **habituation**, **Santos** (design power can become manipulation). **Broader lesson: the legal test checks the form of the action; meaningful consent needs attention-supporting design.**

(R13–R15 + synthesis → Part 4.)

UNIT 2 — PART 4: R13 (Dove & Chen) · R14 (Medzini & Epstein) · R15 (Kay & Terry) · SYNTHESIS & EXAM TOOLKIT

R13. DOVE & CHEN (2020) — "Should consent for data processing be privileged in health research? A comparative legal analysis"

The problem: a research privilege, but divided laws on consent

- **Recital 159 GDPR** defines scientific research broadly: technological development, fundamental research, applied research, privately funded research, public health studies. With safeguards and a basis in EU/Member State law, researchers enjoy a **research privilege** = lighter-touch regime: may **store data for long**, **refuse to delete data even after a participant withdraws consent**, **reuse data across projects**.
- **Rationale (twofold):** protect individuals' rights **and** enable medical innovation (treating research like banking/marketing would slow breakthroughs).
- Yet national laws **diverge sharply** on one question: **must consent be the lawful basis for processing research data?**
- Authors trace the divergence to a **common misperception** + a **contested normative link**:
  - **Misperception:** consent is legally required to process personal data at all — in fact it's **one of several lawful bases**.
  - **Normative link:** some draw a line between consent as a **research-ethics principle** (grounded in autonomy; legally required for e.g. clinical trials) and consent as a **lawful basis under data protection law**. **Authors' counter-argument (runs through whole paper): the two should NOT be conflated** — for ethical, legal and methodological reasons; for public bodies consent may not even be a proper basis; consent is context-dependent not absolute.
- **Questions:** is the divergence harmful to international research collaboration? Could it encourage **regulatory arbitrage** (research moving to "friendlier" jurisdictions)? Should researchers choose (explicit) consent or another basis? What role should **public interest** play?
- **Scope limits:** adults with capacity; data collected for **future** research use; **not** secondary use of existing data, adults lacking capacity, or children.
- **Compares 4 regimes: GDPR; South Africa's POPIA 2013; UK Data Protection Act 2018 (DPA 2018); Ireland's Health Research Regulations 2018.**

GDPR: a framework with no bias toward consent

- Roles in research: **controllers** = companies, researchers, universities; **processors** = cloud providers, research collaborators; **data subjects** = participants.
- **Art 6** lists **six lawful bases**; consent (**Art 6(1)(a)**, defined in Art 4(11)) is only one. **Recital 50:** further processing for scientific research is **compatible** with original purpose → no new lawful basis if same controller (fits **purpose limitation Art 5(1)(b)**). Two particularly useful bases: **legitimate interests** (mainly commercial research) and **public task** (needs basis in EU/Member State law). **UK Health Research Authority (HRA) recommends researchers use bases other than consent.**
- Health and genetic data = **special category data (Art 9)** — processing generally prohibited unless one of **ten exceptions in Art 9(2)** applies → research must satisfy **two conditions at once**: an Art

6 lawful basis **and** an Art 9(2) exception. **Key exception: Art 9(2)(j)** — scientific research based on law and subject to **safeguards in Art 89(1)** → lets researchers avoid the **explicit consent route Art 9(2)(a)**. (Pormeister argues legislators probably didn't intend this to apply to genetic data.)
- **Consent is a poor fit for much research:** requirements (esp. **freely given**) so strict that for **clinical trials** consent may not be the most appropriate basis — **EDPB Opinion 3/2019**. Researchers gravitate to **Arts 9(2)(j) and 89(1)**. **GDPR on its own shows no bias toward consent.** But **Art 89(1) lets Member States build such a bias into national law** → source of divergence.

The middle of the spectrum: South Africa and the UK

South Africa — POPIA 2013. Information Regulator provisions in force 2014; main body **not yet in force** when written. Influenced by early GDPR drafts; complements health research ethics guidelines (fit with **broad consent** — consent for a wide range of future research — questioned). **s 26 "special personal information":** religious/philosophical beliefs, race/ethnic origin, trade union membership, political persuasion, health or sex life, biometrics, criminal behaviour → prohibited unless exemption. **s 27 lists five exemptions:** (1) data subject consented; (2) establishment, exercise or defence of a legal right/obligation; (3) obligation of international public law; (4) **historical, statistical or research purposes**; (5) information deliberately made public by data subject.

- **Research exemption s 27(1)(d)** is **conditional:** applies only if **either** (a) purpose serves a **public interest** and processing is **necessary** for it, **or** (b) it's **impossible or would involve disproportionate effort to ask for consent** — **plus guarantees** that privacy not disproportionately affected. (Paper at one point says "Section 27(7)(d)" — slip for s 27(1)(d).) → **"two-track system":** public-interest research may rely on consent **or** exemption; research **not** in public interest must prioritise consent, may use exemption only if consent impractical. **Consent favoured but not mandated.**
- **Legislative history (contested balance):** SA Law Reform Commission **2005 Discussion Paper** proposed narrow exemption with **four cumulative** conditions (public interest, necessity, impracticability of obtaining explicit consent, safeguards). **2009 Final Report removed the exemption** (citing **World Medical Association, BMA, Canadian Medical Association** on importance of consent); Government Bill 2009 followed. National Assembly committee later **re-introduced it in watered-down form** — conditions now **alternative not cumulative**; safeguards always required.

UK — DPA 2018. Gives effect to GDPR + implements Law Enforcement Directive. **Schedule 1, para 4:** research processing of sensitive data allowed only if (i) necessary for **archiving, scientific/historical research or statistics**; (ii) carried out per **Art 89(1) as supplemented by s 19**; (iii) **in the public interest** (**third condition is new** — GDPR requires public interest only for archiving, DPA 2018 for all three purposes). Act doesn't define public interest in research; ICO: exemption doesn't cover **commercial research** such as market research or customer satisfaction surveys. "**Substantial public interest**" is a separate basis (Art 9(2)(g), s 10(1)(b)).

- Also **two-track but stricter than POPIA:** for research not in public interest there's **no impracticability escape route** → consent becomes privileged/only basis. **s 19(3)** requires **ethics approval** for research that leads to measures/decisions about a particular data subject.
- **Data protection isn't the only UK law: common-law duty of confidentiality** (important but not absolute). England & Wales: **Reg 5 Health Service (Control of Patient Information) Regulations**

2002 and **s 251 NHS Act 2006** (formerly s 60 Health and Social Care Act 2001) allow NHS patient data use **without consent and without breaching confidence**; governed by **HRA** under **Care Act 2014** via NHS research ethics committees and the **Confidentiality Advisory Group**. Scotland: **Public Benefit and Privacy Panel**; Northern Ireland: **Medical Directors of Health and Social Care Trusts** decide case-by-case. **Digital Economy Act 2017 (Part 5, ch 5, s 64)** lets public authorities disclose personal info for research without consent. Crucially these **set aside duty of confidentiality, not data protection** — a lawful basis under GDPR/DPA 2018 still needed, and it isn't consent. Laws complement each other; **DPA 2018 = baseline absent a *lex specialis*.**

Ireland: strong presumption of consent

- **Health Research Regulations 2018**, made under **s 36 Irish DPA 2018**, in force **August 2018**. Six elements: (1) mandatory **suitable and specific measures** (Reg 3(1)); (2) define health research (**Reg 3(2)**) through five broad types — normal/abnormal functioning; innovative diagnosis/treatment/prevention; improving diagnosis/treatment/rehabilitation/palliation/quality of life; health system efficiency; population health and its social/cultural/environmental/occupational/economic determinants; (3) **consent declarations for new research (Reg 5)**; (4) transitional arrangements (Reg 6); (5) **committee with right of appeal (Regs 7–13)**; (6) misc (Regs 14–16).
- **Heart: Reg 3(1)(e)** requires **explicit consent** before the research begins, for specified health research, either in a particular area or more generally in that area/related one → works as a **rebuttable presumption**. **Rebutted via Reg 5(1) carve-out:** researcher may apply to the **Health Research Consent Declaration Committee (HRCDC)** for a declaration that the **public interest in the research significantly outweighs the public interest in requiring explicit consent.** Before applying: **DPIA under Art 35(1)** + **research ethics approval.** Application must set out: lawful basis and Art 9(2) condition; controllers and joint-controller responsibilities (**Art 26**); proof **personal rather than anonymised data is necessary**; no damage/distress; data minimised; no disclosure without law/consent; safeguards; **DPO appointed**; ethics approval; **DPIA results (esp. on data linkage)** and consultations with data subjects; **reasons why consent will not be sought.**
- "May apply" sounds voluntary but **in practice is the only way around explicit consent.** Critics (**Clarke et al.**): harms **retrospective chart reviews, biobanks, research involving people lacking capacity.** HRCDC describes explicit consent as "**the default position**" and about "**empowering the patient**"; aims for "**Transparency, Confidence and Trust**".

The spectrum (side by side)

Regime	Mechanism	Consent privileged?
GDPR default	Exemption from consent under Art 9(2)(j) + Art 89(1) safeguards; consent = one option	**Not at all** — researchers have almost no incentive to choose it
POPIA / DPA 2018	Exemption for public interest or impracticability (POPIA); public interest (DPA 2018); **controller** makes the assessment	**Moderately**
Ireland	Requires **significant public interest + consent-waiver declaration from independent third party**	**Strongly**

Authors accept simplification: Art 89(1) safeguards specified differently — more detailed in Ireland and UK than POPIA's "sufficient guarantees"; UK adds ethics approval (s 19(3)).

Core argument: the "consent misconception"

- **Research-ethics (informed) consent** = powerful ethical-legal norm resting on **respect, autonomy, dignity, bodily integrity**. **Art 7 ICCPR:** "no one shall be subjected without his free consent to medical or scientific experimentation"; consent forms also serve an **evidentiary** function.
- **Data-processing consent** = simply **one lawful basis**; not necessarily a legal or ethical obligation.
- **"Consent misconception"** = assuming that because consent is the key norm in research ethics, it must also be the data-protection basis. **Participants especially think that by consenting to take part they're consenting to data processing.**
- **Authorities: GMC** — implied consent works for confidentiality but unlikely enough under **Art 6(1)(a)** or to count as **explicit consent under Art 9(2)(a)** → doctors may rely on different justifications under the law of confidence and under GDPR. **EDPB Opinion 3/2019 (Clinical Trials Regulation 536/2014):** informed consent under CTR **must not be confused** with GDPR consent; CTR consent protects **dignity and integrity under Arts 1 and 3 of the Charter (CFR)**, not data protection. EDPB also points to **power imbalance** in research (participants may be ill, disadvantaged, institutionally dependent) → consent often **not freely given** → other lawful bases should be used in most cases.
- **Two further problems if consent mandated:** (1) **definitions of valid consent differ** between data protection and ethics, and across countries (what counts as "informed"; how "broad" broad consent can be) → harms **international collaboration**; (2) **withdrawal (Art 7(3)) removes the lawful basis** → complicates **research repositories**, whereas withdrawal in research ethics usually doesn't undo past research. **Form design: Art 7(2)** requires consent request clearly distinguishable from other matters → information sheets must **separate consent to participation from consent to processing** and name all parties relying on consent.

Normative position: "South Africa+"

- Data-processing consent is still valuable — "**manifestly stronger legal form**" for autonomy over one's data and participation; gives control over body/bodily integrity (data is part of it); shows respect; creates **communicative bond** between controller and data subject. Consent should be **privileged, but "in a moderate and rebuttable form"**.
- **Criticism of both ends:** GDPR default **favours researchers too much** (they'll use other bases even when consent easy; broad research definition risks abuse by private entities; if consent isn't onerous, is ethically appropriate and methodologically sound, researchers should get it — esp. privately commissioned research without clear public interest). **Ireland privileges consent too much** — disproportionate, burdensome, dampens research, competitiveness, patient access to innovation. Authors prefer **self-assessment with accountability to a regulator over third-party bureaucracy**; reject Irish premises: consent isn't the only way to empower patients, research without consent isn't automatically unethical, and **access rights don't depend on consent being the lawful basis.**
- **UK approach better** (controller decides public interest; ICO can intervene) = "**co-regulation**" — presumed trust rather than command-and-control (though public interest not always easy to show). **Preferred model close to POPIA:** consent privileged **unless** either (a) public interest (determined by controller) + necessity, **or** (b) consent impossible/disproportionate effort. Always **guarantees against disproportionate privacy impact**; onus on researcher to make an **honest, informed determination, accountable to a regulator.**
- **"South Africa+" = POPIA-style core + GDPR-style procedural/substantive safeguards:** anonymisation/pseudonymisation encouraged; **DPO** required where core activities involve large-scale genomic/health data; **DPIA** for new technologies/high-risk processing; controllers transparent

about why consent impracticable or public interest overrides; other duties (confidence, research ethics) kept **distinct** from data protection for conceptual clarity.

Conclusions, criticism, links

- **Conclusion:** research-ethics consent and data-processing consent must be distinguished to avoid the consent misconception so participants are "**under no illusions**" about what they consent to. Data protection consent is "**less powerful but should be privileged as well — to a degree**", because it "**symbolizes respect**" and puts data subject on a "**more symmetrical informational and communicative plane**" with controller. **GDPR and Ireland "pull too far on opposite ends"**: one risks infringing rights and lets researchers dodge consent, the other overly burdensome. Context should be assessed by the **controller/researcher rather than a third party.**
- **Strengths:** clear comparative spectrum; useful concept of the **consent misconception**; balanced proposal. **Weaknesses:** model **relies on controller self-assessment** = the same trust in controllers that Najdi doubts; same **conflict-of-interest** problem as PIAs (Iwaya); "**public interest**" vague and self-declared; doesn't address **secondary use, children, adults lacking capacity**; POPIA not yet in force when written.
- **Links: counterweight to consent-centred readings** (*Planet49*, Santos, Pilot, Lindegren) — consent **not always the right basis**. Power imbalance that stops consent being "freely given" mirrors **Art 7(4)** and the **coupling issue *Planet49* left open**. **Irish DPIAs** connect to impact-assessment readings (R9/R10); withdrawal/erasure tensions connect to **Custers & Vrabec** and **Najdi**. **Who should decide?** Authors' controller self-assessment + regulator vs **third-party committee (HRCDC)** vs **Custers & Vrabec's DPAs as trusted third parties**. **Kay & Terry** link back: research-software example + ethics board feedback concern research-ethics consent.

R14. MEDZINI & EPSTEIN — "Privacy Governance from a Polycentric Perspective" (book chapter)

Background: from regulation to regulatory governance

- Claim: **privacy is not governed by the state alone** — by many interdependent actors at many levels, with overlapping mandates and **no final arbiter**. In the authors' vocabulary privacy governance is **polycentric** (many centres of decision-making rather than one). Best seen by looking at **regulatory intermediaries** (actors between rule-makers and rule-takers).
- Two contrasting case studies: **formal, legal institutionalisation of the Data Protection Officer (DPO) in the EU**, and **informal governance of remote-teaching technology by educators in early COVID-19**. Both display **transscalarity and transsectorality, diffusion of knowledge and authority, fluidity.**
- **Regulation** (classic) = state **"command and control"** (state writes rules, enforces on regulated). **Regulatory governance** = plural forms of governing: government, industry, civil society and public **share responsibility** (Levi-Faur). Related scholarship: "**regulatory state**" (Majone 1994), "**decentring regulation**" (Black 2001), "**post-regulatory state**" (Scott 2004), "**regulatory capitalism**" (Levi-Faur 2005), new tools of public action (Salamon), "**smart regulation**" (Gunningham), audits (Power's *The Audit Society* 1999), "**regulatory intermediation**" (Abbott et al. 2017). Common thread: non-state and transnational actors have real regulatory impact at

supranational, national, local levels; they're interconnected, interdependent and also **compete for legitimacy, authority and power.**

The polycentric framework (Scholte 2017 — first to apply it explicitly)

Seven features: transscalar (local/national/international at once); **transsectoral** (government, business, civil society); **diffused** (authority spread out); **fluid** (arrangements keep changing); **overlapping mandates**; **ambiguous hierarchies**; **no final arbiter** (several bodies claim responsibility; unclear who outranks whom; no one has last word).

- Rests on Black's (2001) **fragmentation of knowledge and power:** no single actor has all knowledge for complex, dynamic "**wicked**" problems; power distributed so no actor controls all critical resources → breaks traditional **public/private dichotomy**; draws attention to how power and everyday mundane practices are recalibrated.
- **Two ways to study: institutional** view (formal organisations, explicit rules, authority relations) and **non-institutional** (informal norms, practices, techniques). Together reveal "**ordered chaos**" (Koinova et al. 2021) — order without a central authority.
- **Actor categories: rule-makers** and **rule-takers** (separate = **second-party regulation**, e.g. state regulating companies; same = **first-party** self-regulation — Black 1996); **rule-beneficiaries** (people whose interests rules protect — citizens, consumers, users; includes indirect beneficiaries like captured interest groups; consumers benefit from food-safety rules without being rule-takers); **data subjects = "empowered beneficiaries"** (rights to access, rectify, erase, restrict, port) — **but "being empowered… does not mean these actors act upon their powers"**; **third-party regulation by regulatory intermediaries** = individuals/organisations, formal or informal, with unique capacities, resources, expertise, responsibilities that rule-makers/rule-takers lack — **auditors** classic example (Power: firms publish own financial reports but need auditors to assure outsiders reliable). Focusing on intermediaries = a way to **operationalise** polycentrism.
- **Informational power** (Braman 2009) underlies all other forms of power (instrumental, structural, symbolic); governing information = "decision-making with **constitutive effects**" — shapes the world it governs; happens via formal regulation **and** technology design; formally **and** informally.

Privacy governance and the research question

- Polycentric thinking already runs through information policy: from 1980s liberalisation/privatisation of telecoms moved expertise outside the state, created strong private/transnational actors; internet brought **informal regulation through design**; **WGIG 2005** defined internet governance as "the development and application by governments, the private sector and civil society, in their respective roles, of shared principles, norms, rules, decision-making procedures, and programmes that shape the evolution and use of the Internet" → debates on **multistakeholderism**, "ecosystem" (Hofmann), "networked governance" (Mueller), "**co-regulation**" (Marsden). Similar in **cybersecurity** governance (Mueller 2017) and **platform** governance (Facebook, Amazon, Apple, Microsoft, Google navigate many legal systems, lead standardisation, self-regulate → governance **by and of** platforms).
- **Privacy scholarship works in separate strands: legal** (rights-based; **informational self-determination** — backbone of EU data protection, also in US law); **regulatory** (power of independent DPAs; limits of private self-regulation; strength of US FTC); **economic** (privacy calculus — Acquisti et al.); **behavioural** (**privacy literacy** as basis for individual agency). **Missing: map of "loci of control"** (where control over personal data actually sits).

- **Earlier implicitly polycentric work: Bennett & Raab (2003)** — four groups of privacy instruments (**transnational, legal, self-regulatory, technological**); laws not dominant, regulators not necessarily pivotal; privacy governance = "a complex phenomenon that involves a plurality of actors and a range of methods of operation and coordination". **Mayer-Schönberger (2010)** criticised reliance on individuals to enforce own rights → learn from Europe's **privacy professionals** as information governance intermediaries. **Bamberger & Mulligan, *Privacy on the Ground* (2015)** (five countries): ambiguous legal requirements, activist regulators, stakeholder scrutiny (esp. US, Germany) **empowered privacy professionals inside companies**. Engineers have narrow perceptions of privacy (Waldman 2018; Ribak 2019).
- **Critics: Koinova et al.** — polycentrism neglects structural context in which authority is assigned; **Julie Cohen (2012)** — US "new privacy governance" ill-equipped for **surveillance capitalism**, rooted in ideology that "systematically downplays the need to hold market actors accountable" and relies too heavily on private regulation and **notice and choice**; **Bennett & Raab (2020)** — governance may be reverting to a **simple two-party** relationship between regulator and regulated organisation. **Research question** (paraphrasing van Eeten & Mueller 2013): "**where is the governance in privacy governance and why does it matter?**"

Case one: the DPO in the EU (formal intermediary)

DPOs = **information governance intermediaries** placed **inside** organisations: interpret law, manage risks, strengthen accountability of rule-takers. Three milestones (a polycentric institution built slowly and through political struggle):

1. **German BDSG 1977:** independent internal compliance officers (*betriebliche Datenschutzbeauftragte*) **mandatory in organisations above a certain size**; enforcement left to the **Länder** supervisory authorities. Professional DPO associations followed: **Germany 1977, Austria 1983, UK 1993** (where the role had no legal recognition).
2. **1990s Data Protection Directive (95/46):** DPO as a **political compromise** in the fight against "**data havens**". **French-led coalition** wanted power **concentrated in DPAs** (extensive notification/registration of processing); **German delegation** wanted a **diffused** approach (organisations appoint own internal supervisor, or DPAs delegate tasks to DPOs). **Council Presidency brokered:** organisation **exempt from notifying DPA if it appointed and registered a DPO.** In practice **weak at national level** — DPOs confined to national law, kept public registries, notified DPAs of risks; Member States had wide discretion; **Belgium and UK legislated but never issued implementing decrees**; most DPAs treated DPOs as their "**eyes and ears**" or a sanction tool (could strike officers from registries) → polycentric recognition of DPOs **stunted**.
3. **GDPR** (negotiated after **Lisbon Treaty**): Commission chose a **directly applicable regulation**; proposed **mandatory DPOs** alongside simpler notification, more managerial responsibility, self-regulatory mechanisms. **Council (via DAPIX working party)** resisted: questioned mandatory DPOs / more granular / which entitlements; opposed ~**50 powers to adopt delegated and implementing acts**. **Parliament sided with Commission on DPOs, with Council against the delegated powers.** Compromise **December 2015**; GDPR adopted **April 2016**. **Result — much less Member State discretion:** GDPR requires a DPO (**internal or contracted externally**) for set categories of organisation; Member States can **add** categories but **not subtract**. **Tasks:** monitor compliance; **advise** managers and staff; indicate TOMs needed; extra tasks allowed if no **conflict of interest**. DPO must be **proficient** and is **protected from dismissal or penalty**. **No formal degree or certification required** (DPAs such as **France's CNIL accredit training courses but cannot make certification mandatory**). **Assessment:** diffused and polycentric but **not polycentric in the ideal**

sense (Scholte) because **hierarchy remains**: **DPAs arbitrate** non-standard DPO decisions; **courts are final arbiter** in a crisis. Meanwhile DPOs depend on **non-state actors (professional networks)** for knowledge, credibility, proficiency, defence of professional interests.

Case two: educators & remote teaching in COVID-19 (informal intermediary)

- **Spring 2020:** >**1.2 billion pupils** and >**200 million university students** lost in-person classes; rapid tech adoption exposed normally hidden governance — "**crises reveal implicit governance structures**". (Evidence mostly from **WEIRD** countries.)
- **Concerns:** *Institutional* — schools lost control over student data to **commercial platforms** → power shifted from state to platform providers. *Social/pedagogical* — home and professional life collapsed into each other → "**privacy boundary turbulence**" (disruption of usual lines between private and public spheres). Role of **street-level bureaucrats** (front-line officials — here teachers — who apply policy in daily practice) and **epistemic communities** (networks sharing expertise) became crucial.
- **Responses shaped by path dependency and national culture: Israel** — teachers, pupils, parents already used **WhatsApp** with little attention to privacy → main teaching channel. **Germany** — higher privacy sensitivity; teachers sometimes had only pupils' postal addresses; using WhatsApp seen as an "**act of rebellion**". Institutions chose different platforms: **closed commercial (Blackboard, Canvas, Google Classroom)** accepting/ignoring privacy risks vs **self-hosted open-source (Moodle)**; later **Zoom, Webex, Teams, BigBlueButton** provided centrally. **US: Data Protection Addenda** agreed at level of each institution substituted for central regulation. **Estonia** started with GDPR-friendlier **BigBlueButton**, yet **Zoom came to dominate.**
- **Decisive factor = agency of individual teachers:** learned tools from personal/professional networks, not formal sources → "**hyperlocal, authentic expertise**"; sometimes required extra tools exposing students to third-party data collection; could **enforce or circumvent** official policy (e.g. whether students had to keep cameras on in Israeli schools). → **knowledge, expertise, agency, resources and authority distributed across many actors**; reveals "**informal institutionalisation**" (individual agency + social structures + socio-technical systems = lasting arrangements); **crisis decisions create path dependency.**

What the two cases show — 3 polycentric markers

1. **Transscalarity & transsectorality:** DPOs (formal delegated authority) and educators (choose among commercial products; develop norms-in-practice on surveillance and video) act **outside government but in the "shadow of hierarchy"** of regulators and technology designers (discretion while knowing more powerful actors set the frame and could intervene). **Interpretive flexibility** (room to read rules/tools their own way) creates tension with top-down order. Other actors (engineers, certification and monitoring bodies) also belong.
2. **Diffusion of knowledge & authority:** both rely on **epistemic communities and professional networks**. DPOs must demonstrate qualities through associations, certifications, academia; some associations also act as **interest groups**. Educators rely on peers and respond to **parent pressure**. A new "**network effect**": epistemic networks compensate for **literacy deficits, information overload, missing authority**. Call for research on **isomorphism** of networks (tendency to become alike) and their **politicisation**.
3. **Dynamism & fluidity:** DPO role formalised over **decades** alongside technology change; **COVID-19 compressed change** (Israeli universities now accept recording of lectures — a new norm that outlasted the emergency). Research must be **longitudinal** and study **crises/disasters**. Authors call two cases "**tip of the iceberg**" and "**proof of concept**". Future: governance **of and by algorithms**,

mapping networks that produce norms/language/practice, systematic **comparative analysis** across cultures/systems.

Criticisms & why it matters

Strength: reframes **who protects privacy** — not law vs individual but a **landscape** of rule-makers, rule-takers, rule-beneficiaries and intermediaries; supplies useful vocabulary (**Scholte's seven features**); historically grounded account of the DPO (BDSG 1977 → Directive compromise → GDPR). **Weaknesses:** rests on **two illustrative cases** not systematic study; COVID case relies on emergent evidence from **WEIRD** countries; authors admit **hierarchy persists** (DPAs and courts have final say) — sits uneasily with "no final arbiter"; doesn't fully answer critics (**Cohen**: fails to hold market actors accountable; **Bennett & Raab**: return to two-party regulation; polycentrism ignores **structural context** in which authority is assigned). **Links:** adds **intermediaries** (DPOs, educators, professional networks) to the **law vs design vs technology** debate. Intermediaries appear throughout: **DPOs** required under **DPC guide** and **Ireland's Health Research Regulations**; **Iwaya** discusses DPO roles and warns of **PIA consultant conflicts of interest**; **consent management platforms** (Santos); **LLM readers and consumer associations** (Pałka); the federation that brought ***Planet49***; Custers & Vrabec's **DPAs as trusted third parties**; **Dove & Chen's HRCDC**; processors under **Art 28**. "**Empowered beneficiaries often don't act on their rights**" links to the **privacy paradox**, to McDonald & Cranor (time to read notices is itself a cost), to Lindegren's wrong mental models, and to Kay & Terry's "all EULAs are basically the same". **Chapter's answer to its own question:** the governance in privacy governance lies **not only in statutes and regulators but in the many intermediaries who interpret, apply and sometimes bend the rules in practice.**

R15. KAY & TERRY (2010) — "Textured Agreements: Re-envisioning Electronic Consent"

The problem: agreements nobody reads

- **Fewer than 2% of people read license agreements** when installing software. Matters because **EULAs** (end-user license agreements) can contain terms of direct concern: **data collection**, installation of extra software (DRM, ad-serving) affecting privacy, security, user experience. People skip because reading doesn't serve their immediate goal (use the software). "**Software agreements**" = privacy policies, EULAs, consent agreements for research software → paper speaks directly to **electronic consent**.
- **Who wants better agreements:** proprietary firms building trust (**Aviary** puts a summary in a side column); free/open-source producers explaining philosophy (**Free Software Foundation's GNU GPL**); researchers distributing software (**ingimp project**) with an ethical duty of informed consent (without better agreement participants may miss risks like sensitive data being made public); governments considering legislation should base it on demonstrably better processes. **Aim: find a way of presenting agreements that people actually read.**

Earlier solutions and their limits

Approach	Limit
Single-screen summaries / layered notices (Good et al.; from medical consent forms and financial privacy notices) — summary layer in front of full text; cut spyware installs	**Summaries omit terms and may reduce reading of the full agreement**

Approach	Limit
Privacy "nutrition labels" (Kelley et al. 2009, tested on P3P sites) — data uses and opt-ins as a table	Unclear whether they generalise to other agreement types
JITCTAs (Patrick & Kenny) — small agreements at the moment data is collected	Only work if agreement can be split into context-specific pieces without overloading users
Polymorphic dialogs (Brustoloni et al.) — reorder buttons/temporarily disable them so users can't follow learned click paths	Designed for **short warnings**, not long dense texts
Enhanced text in medical consent (Campbell et al.) — better headers/pictures helped low-literacy readers; video did worse	Subjects were **told to read**

- Most current solutions remain **plain text with minimal typography** → opportunity to apply **visual design**. (Footnote: layered notices could be **multiple progressive layers**, but untested.)

Designing a textured agreement

- Came from a **formative evaluation** (early exploratory study) with **21 subjects**; dozens of **low-fidelity prototypes** (paper and computer mock-ups with supplementary videos, illustrations, enhanced text, inspired by **advertising, technical communication, comics**). Prototypes shown inside **mock installers using deception** (participants told they were there to "evaluate usability"); order varied. **Key insight: videos and separate illustrations caused confusion or disinterest; visually redesigned text worked best.** Users felt company had made "an explicit effort to communicate".
- **Design theory drawn on: Tufte** — "separation" and "layering"; **Kress & van Leeuwen** — "salience", "framing", hierarchy of information, composition enabling **non-linear reading**; **Wright (1977)** — headings make skimming easier and help readers integrate information; design influences **pacing** (speed/rhythm of reading).
- **Textured agreement** = agreement **visually redesigned using typography, factoids, vignettes and iconic symbols, without changing the underlying text. Two high-level goals:**
    1. **Clear information hierarchy** — give visual weight to what matters from the **user's perspective** (e.g. automatic data collection) rather than standard liability clauses. Counters impression agreements are irrelevant, unskimmable, long and hard; readers can **enter at a high level** (headers, factoids) then drop to detail nearby → "**skimmability**" lowers barrier to reading further.
    2. **Capture and retain attention through visual variety.** Overuse kills the effect: **users read only 3–4 warning boxes per document → progressive exposure** to new elements and balanced techniques across the document. Hierarchy + variety create accessible pace; plain text signals "**long and arduous**".
- **Four techniques: (1) Typographic manipulation** (bold key terms, headers, bullets = first level of hierarchy); **(2) Factoids** (replace pull-quotes, impractical for dry legal text; written for the purpose; either show **consequences of terms** (e.g. most popular OS among users — hints OS is being collected) or **humorous hooks** like "**98% of users don't read consent agreements**" which acknowledge tedium and signal this agreement is different); **(3) Vignettes** (comic-like mini-narratives of the user using the software, e.g. a user clicking the contrast tool with caption "we're collecting COMMAND NAMES!" — creates personal relevance); **(4) Iconic symbols** (warning icons, coloured boxes marking sensitive terms; used sparingly to keep "**arousal strength**" — Wogalter & Laughery). Factoids kept **germane** (relevant) + add a human touch. **No single template** — a set of strategies; templates published online.

Experiment 1 — does texture capture attention?

- **Between-subjects** (each participant saw one version); **used deception** (participants didn't know agreements were being studied). **Five conditions: control** (plain text); **minimal** (pretty but didn't reinforce content — tests whether any effect is mere **novelty**); **moderate** (balanced: scholarly heading font, warning boxes for 3 clauses, relevant factoids); **heavy** (as many techniques as possible); **summary** (one-page summary in Good et al. style before installer).
- **Task:** "you got a digital camera" — download, install and use three image apps ("**Photo Time**", "**Photo Job**", "**Photo Desk**") from a mock web page to choose best for **rotating images**. Agreements derived from real ones; each stated data would be collected, with varying details. **Verbal consent first** (written consent primed attention in formative tests); debrief and paper consent after. Order counterbalanced → **5 × 6 design**. **Windows XP in VMware**, internet disabled, snapshots; custom **Java installer** mimicking Windows logged screen times, scrolling, cancellations. **Measures:** first-run **time on installer screens**; **maximum scroll** into the agreement. **90 recruited, 6 dropped → 84** (17 per condition, 16 in heavy); 43 female, 41 male, age 17–47 (mean 24); expertise 3.4/5; **$10 coffee gift certificate**; 3 outliers (>3 SD) dropped.
- **Results:** mean first-run time on agreement screen: **heavy 39.8 s (SD 39); moderate 35.6 s (SD 39.2); summary 10.3 s; control 7.1 s. ANOVA significant: $F(4,76) = 5.65$, $p < 0.01$. Tukey:** heavy > control ($p < 0.01$); heavy > summary ($p = 0.026$); moderate > control ($p = 0.026$); trend moderate > summary ($p = 0.063$). **Minimal did NOT significantly improve on control → effect of texturing isn't just novelty. Scrolling** differed significantly ($F = 3.96$, $p = 0.014$): heavy beat control and summary. **Self-reported reading** higher for moderate than control ($p < 0.05$); **reading habits** (never noticed/never/rarely/often/always) significant factor. In summary condition many participants **cancelled at the summary screen** (as in Good et al.) → summaries **do communicate.** Total pre-install time only a trend ($p = 0.089$); scrolling across all runs significant (moderate and heavy beat summary). **Visual appeal:** heavy and moderate rated higher than control and summary; minimal higher than summary.
- **Comments:** heavy participant: "It got me to read them… I NEVER read them. Big letters, organized points, and cartoons help." Moderate: headings "placed similar to a newspaper". But heavy was also "**somewhat obnoxious**" and "**over-the-top**" → **moderate may strike the better balance.**

Experiment 2 — does texture improve retention?

- **Two conditions:** control (plain text from Exp 1) vs refined textured design (more vignettes/sensationalism than moderate but more judicious than heavy). One app, "**Program A**"; participants **stopped right after agreement screen** (no controls to skip ahead); then **8-question open quiz** ("According to Program A's license agreement…": which image characteristics are recorded, whom to contact); each question 2 pts (max **16**; 2 complete, 1 partial). **28 participants** (17 female, 11 male, 19–31, native English).
- **Results:** textured spent **53.6 s vs control 19.7 s** ($F(1,26) = 7.54$, $p < 0.05$); scrolled to max **71.4% vs 47.4%** of document ($p < 0.05$). **Median quiz score 4 (IQR 5.74) textured vs 0 (IQR 4) control**; ANOVA on ranks **$p = 0.052$ — borderline, not conventionally significant. Quiz score strongly correlated with reading time ($r = 0.83$, $p < 0.0001$)** → extra time translated into knowledge. Textured users read/skimmed whole document more slowly; control users **jumped to the end.** Comments: control — "All of the EULAs are basically the same"; textured — "I read more due to the diagram stating that 98% of the users don't read the License Agreement" (hooks pulled readers in).

Conclusions

- Across both experiments texturing **raised attention substantially**: time on agreement rose from ~7 s to ~37 s (36–40 s depending on design) in Exp 1; +34 s (20 → 54 s) with better recall in Exp 2. Only a subset of techniques used → room for improvement. **Works on the agreement itself, not on an auxiliary document.**
- **Summaries — more cautious verdict:** they **are read** (hold attention **18 s longer than welcome screens**, $p < 0.0001$) **but reduce reading of the full agreement.** Echoes **McDonald et al. (2009)** — users less accurate with summaries when answers weren't in the summary layer. "Summaries… do so at the cost of reading the full agreement." → caution about **partitioning** consent (splitting into separate phases).
- **Ethics board** feedback very positive (getting participants to read consent forms is a known struggle) but noted **heavy designs may be hard for seniors. Future work:** long-term **habituation/desensitisation**, other demographics (seniors), real-world agreements, templates for easier adoption.

Strengths, criticisms, connections

Strength: changes **only the form of the agreement, not the legal text** → compatible with existing law; realistic **deception design**; combines **behavioural measures (time, scrolling)** with a **comprehension measure. Weaknesses: small samples** (Exp 2 only 28; quiz result $p = 0.052$); **student participants**; saw agreements **only once** (habituation untested); even improved comprehension is **low (median 4/16)**; "**sensationalism**" and humour could become **manipulative** — the same design power used for **dark patterns** (Santos); someone must **curate what counts as "important"** → choice left to the designer.
Debates:

- **Form vs content:** Kay & Terry fix the form; **Pałka** says content of vague policies is the real problem → texturing a vague policy just highlights its vagueness.
- **Reading cost:** Kay & Terry make people read more (time goes up) vs **McDonald & Cranor** (time *is* the cost; 5× increase in reading time per agreement multiplies the national bill) → **trade-off between engagement and burden**, confirmed by **Lindegren** (more engaging designs take longer): drag-and-drop **+36 s** vs checkboxes; textured agreements **~+30 s** vs plain text.
- **Summaries & layered notices** (scoping review, McDonald & Cranor recommend) — K&T show summaries **displace** full reading → caution for **Santos's dashboards/icons** and **nutrition labels.** Their answer to comprehensiveness vs comprehensibility = **fix the form of the full text rather than shorten it.**
- **Meaning of "clear affirmative action" (Art 4(11), Recital 32, *Planet49*):** ticking an unticked box is enough in law, yet plain-text agreements get only **~7 s** of attention → **legal test checks form of the action; meaningful consent needs attention-supporting design.** With Lindegren, shows design can raise attention/recall, **but gains modest**; control participant's "all EULAs are basically the same" shows users assume agreements are **interchangeable**. **Dove & Chen:** sometimes consent isn't even the right legal basis. **Ingimp example + ethics board feedback** link to Dove & Chen's **research-ethics consent**.

SYNTHESIS & EXAM TOOLKIT FOR UNIT 2

1. One-paragraph summary of each reading (quick revision)

#	Reading	Core message	Camp
R1	*Planet49* (CJEU 2019)	Pre-ticked box ≠ consent; applies to non-personal data too; tell users **cookie duration + third-party access**; **bundling left open**	Law floor (fix the form)
R2	Santos et al. 2026	Lawful AND usable consent possible via heuristic evaluation (3 heuristics, 10 design choices); "**Not yet**"/**right to be ambivalent**; tensions: colours, consent walls/friction; browser-level consent	Fix the form
R3	Pałka et al. 2025	Make policies **longer and fully comprehensive**; let **LLMs** (GPT-4) read them; tradeoff exists only while humans are sole readers; real policies answer **2/9** questions; GPT-4 6/9 flawless on mock policy	Fix the content / reader
R4	Pardo & Le Métayer 2019	**Pilot** formal language: user defines policy in advance; join = automatic negotiation; SPIN model checker predicts misuse risk → "genuinely informed" consent	Automate the user's side
R5	van der Schyff et al. 2024	Scoping review of 97 privacy-policy analysis studies; ML vs non-ML; 10 recommendations; ambiguity is the common enemy; user evaluation missing	Frame of field
R6	Najdi et al. 2025	**Don't hand data over**: PDS + CMS + blockchain/smart contracts + TEEs; algorithm travels to data; 9/10 rights met; IR10 fails	Change the architecture
R7	DPC Ireland 2019	**Art 28(3)** controller–processor contract: 2 describe + 9 clauses; accountability chain; ex post limits	Law (contractual control)
R8	McDonald & Cranor 2008	Reading policies = **244 h/yr, $3,534/person, $781 bn**; self-regulation unrealistic; rational non-reading	Cost of self-management
R9	Iwaya et al. 2024	PIAs **in practice**: 45 studies; 13 positives, 17 negatives; **perfunctory**; 4 gaps; move to **FRIAs**	Impact assessments
R10	Wairimu et al. 2024	**Validated vs evaluated**; only **9/39** evaluated; **LINDDUN** the exception; PRIAM harm trees	Impact assessments
R11	Custers & Vrabec 2024	Rights **tell people nothing new** about **inferences/profiles**; 4-type taxonomy; only Arts 21–22 clearly reach them; broad teleological reading	Rights scope
R12	Lindegren et al. 2021	**DAD / swiping / checkbox** n=60; DAD slower (+36 s), higher SUS (81) and recall (n.s.); active engagement can be the affirmative action	Fix the form (design)
R13	Dove & Chen 2020	**Consent misconception**; research-ethics consent ≠ data-processing consent; spectrum GDPR/UK/POPIA/Ireland; **"South Africa+"**	Counterweight to consent
R14	Medzini & Epstein	**Polycentric** governance; DPO (formal) vs educators in COVID (informal); intermediaries	Who governs
R15	Kay & Terry 2010	**Textured agreements** (typography, factoids, vignettes, icons); 7 s → 37 s; summaries displace full reading	Fix the form (visual)

2. The master debate: "Can notice-and-consent be saved?" — arguments for a 25-mark answer

Thesis: Notice-and-consent survives only if (a) the cost of self-management is reduced or shifted to collective bodies, AND (b) controllers are technically/legally constrained after consent; law, design and technology are complementary, with Art. 25 GDPR (data protection by design & default) as the bridge.

Position	Readings	Key point	Weakness
Law sets the floor	*Planet49*, Art 4(11), Recital 32, Art 7	Opt-in, active, specific, informed	"Regulates the click, not the choice architecture"; bundling left open; ex post
Design can make it usable	Santos, Lindegren, Kay & Terry	Heuristics; DAD/swipe; texture raise attention/recall	Modest gains; friction/burden; habituation; manipulation = dark patterns; small samples
Content/reader tech	Pałka, Pilot, scoping review	Complete policies + LLMs; formal policies + model checking	LLM reliability, one mock policy; users must author policies; no user evaluation
Architecture	Najdi	Data never leaves DS; TEEs	Unimplemented; burden on users; trust shifted to cloud/TEE vendors; IR10
Cost	McDonald & Cranor	244 h; $781 bn	US 2008; once per site; ignores vague content
Governance/intermediaries	Medzini & Epstein, DPC guide, Iwaya	DPOs, processors, assessors, consumer groups	Conflicts of interest; hierarchy persists; ex post
Consent isn't always the right basis	Dove & Chen	Research: use other bases + safeguards; "South Africa+"	Relies on controller self-assessment (trust)
Rights don't reach inferences	Custers & Vrabec	Consent/information rights can't touch ascribed data	Doctrinal only; relies on contested case law

Cross-cutting concepts to weave in: privacy paradox vs rational non-reading (Pałka reframes: people care but cost > expected loss); **control paradox** (more control → more sharing; Strycharz); **friction** as feature (Guggenberger; Terpstra) vs burden (McDonald & Cranor, Assale, Lindegren, Kay & Terry); **dark patterns** (DSA Art 25, Recital 67); **ambiguity** at every layer (clicks, texts, data); **validation vs evaluation** (R10); **symbolic compliance** (banners, policies, PIAs); **inference economy** (Pałka, C&V); **collective bodies** (consumer associations/Federation in *Planet49*; DPAs as trusted third parties).

3. Cross-reading connection map (quick lookup)

- ***Planet49*** → Santos ("unambiguous"; "X"), Pałka (Federation = collective body), Lindegren (which active behaviour gives informed consent?), Kay & Terry (7 s attention), C&V (cookies = input stage of profiling), Dove & Chen (Art 7(4) coupling).
- **Santos** → Planet49, Lindegren (empirical data; cookie/fingerprint mental models), Kay & Terry (design power → dark patterns), Pałka (rational user vs cost), Iwaya/McDonald (symbolic compliance).
- **Pałka** → McDonald & Cranor (flips solution), van der Schyff (LLM wave; ambiguity), DPC guide (processor/controller roles in mock policy), C&V (inference economy), Kay & Terry (texturing a vague policy highlights vagueness).
- **Pilot** → Najdi (predicts vs prevents misuse), DPC guide (transfer/usage rules = machine-readable "documented instructions"), Iwaya/Wairimu (only validated; PRIAM comparison), McDonald & Cranor (P3P descendants).
- **Najdi** → C&V (IR10; models not personal data), DPC guide (Art 28 would disappear/change), Dove & Chen (trust in controllers), Santos/Pałka (burden on users).
- **DPC guide** → Najdi, Pałka, Santos (CMPs as processors/controllers), Pilot, Iwaya (DPIA assistance Art 28(3)(f)).
- **McDonald & Cranor** → Pałka, Santos, van der Schyff, Pilot, Kay & Terry (5× reading time).

- **Iwaya/Wairimu** → van der Schyff (rec 2 DPIAs), Pilot (PRIAM), DPC guide, Dove & Chen (Irish DPIAs; conflict of interest), Santos/McDonald (symbolic compliance).
- **C&V** → Najdi, Pałka, Planet49, Pilot, McDonald & Cranor, Dove & Chen/Iwaya (who decides: DPAs as trusted third parties vs controllers vs committees).
- **Lindegren** → Planet49, Santos, Kay & Terry (friction), McDonald & Cranor (time = cost), Assale (workflow).
- **Dove & Chen** → Planet49 (Art 7(4)), Iwaya (DPIAs, conflict), C&V/Najdi (withdrawal/erasure), Medzini (HRCDC as intermediary), Kay & Terry (research-ethics consent).
- **Medzini & Epstein** → DPC guide, Ireland's Health Research Regs, Iwaya (DPOs), Santos (CMPs), Pałka (LLM readers/consumer associations), *Planet49* (Federation), C&V (DPAs), Dove & Chen (HRCDC).
- **Kay & Terry** → McDonald & Cranor, Pałka, Santos, Lindegren, Dove & Chen, scoping review (layered notices).

4. Key numbers & quotes cheat sheet

- ***Planet49*:** C-673/17; **1 Oct 2019**; Art 267 TFEU; AG **Szpunar**; **57** companies, **30** partners; **Remintrex**; Recital 32 "silence, pre-ticked boxes or inactivity should not constitute consent"; 3 rulings.
- **Santos:** 3 of Nielsen's 10 heuristics (A match real world; B visibility of status; C user control & freedom); **10 design choices (3+4+3)**; Bouma-Sims **24.0%/17.2%**; Utz **57.4%**; Matte **141/1,426** and **27/560**; Bielova: consequences → refusal up to **3×**; LG Passau **9 Apr 2024**; "**right to be ambivalent**"; DSA **Art 25 + Recital 67**; Italian DPA re-ask ≥ **6 months**.
- **Pałka:** 9 Orderoo questions; **4,379–13,765** words (real policies); only **2/9** answerable (Q6 insurers, Q8 contact); mock policy **6,880** words; GPT-4 **33/45** fully correct, Prompt 2 (CoT) **29/45**; Llama2-7B **1/45**, 91% missing, 62% hallucination; GPT-4 on real policies 9 correct, 47% missing info, 33% inferences, 0% hallucination; Llama 1 correct, 38% hallucination; GPT-4 cost **< $3**.
- **Pilot:** Pilot components (devices, entities, data items, purposes, conditions; usage rule → communication rule → transfer rules); 4 events (request/send/transfer/use); **subsumption + join**; **SPIN/Promela/LTL**; Parket, ParketWW, Alice, CarInsure; 3 options.
- **Scoping review: 97** studies of **1,429**→168; **US 41**; **10 databases + 56 IS journals**; 2004–2023; OPP-115 (14 studies), APP-350 (2); **61** ML studies; **22** manual non-ML; **10** recommendations; 1–3 all/4–7 ML/8–10 non-ML.
- **Najdi:** IR1–IR11; **19** papers 2020–2024; 4 design decisions; CMS/SCE/CSC/PSC/SCP/TEE; **87 million** (Cambridge Analytica); 74% OAIC; **9/10** rights met (IR10 not).
- **DPC guide:** Art 28(1) sufficient guarantees; **2 + 9** clauses; 28(3)(a)–(h); 28(2),(4); **two layers of liability**.
- **McDonald & Cranor: 244 h**, **3,534 * *, * *781 bn**; **21*bn* * * *ads*; * * 75 * * *sites*; * * 250*wpm* * *; * * 212 * * *participants*; * * 66/119/105 * * *sitespermonth*; * * 1,462 * * *sites/yr*; * * 221*m* * * *users*; * *35.86/$4.48**; headline **201 h** (inconsistency).
- **Iwaya: 45** studies (746 → 60 → 42 + 3); **13 positive / 17 negative**; **11** from Wright & De Hert 2012; **22/30 (73.3%)** cite GDPR; **6 (15%)** non-WEIRD; **32** peer-reviewed; Wright & Wadhwa **17/27 (63%)**; **4 gaps**; FRIAs; **DSA Art 34**.
- **Wairimu: 39** studies (991 → 309 dups → 682 → 98 → 34 + 5); **9/39** evaluated; PIA 10 (50% evaluated); PRA 9 (88.9% validated only); **PTM 11, PSTM 2, SPIA 1**; PIA 16; LINDDUN GO/PRO/MAESTRO; only LINDDUN passed all quality questions; **Art 35(7)**.

- **C&V:** 4 types; **Acxiom 2.5 bn/11,000 attributes**; Arts 12–22 grid; ***SCHUFA***, ***Österreichische Post*** (C-154/21), ***Nowak***, ***YS***, ***Meta Platforms*** (C-252/21), pending **C-203/22**; *TransUnion v Ramirez*; stages: input → throughput → output → outcome.
- **Lindegren: 60** (3×20); DAD **129 s**, swipe **132 s**, checkbox **93 s**; SUS **81.00 / 79.25 / 72.63**; recall **0.92 / 0.93 / 0.84** (n.s.); IUIPC mean **55.78**; **11/20** swipers confused, **4** wrong direction; **3** opened tutorial; age corr **0.361**; IUIPC–uncertainty **−0.256**.
- **Dove & Chen:** 4 regimes; Recital 159, 50; Art 9(2)(j), 89(1); POPIA **s 26–27(1)(d)**; DPA 2018 **Sch 1 para 4, s 19**; Irish **Reg 3(1)(e), Reg 5(1)**, **HRCDC**; "**South Africa+**"; EDPB **Opinion 3/2019**.
- **Medzini & Epstein:** Scholte's **7** features; BDSG **1977**; Directive compromise; GDPR Dec **2015** / Apr **2016**; **1.2 bn** pupils; Israel WhatsApp vs Germany; Estonia BBB → Zoom; **3** markers.
- **Kay & Terry: <2%** read; Exp 1 **84** participants, 5 conditions, times **39.8/35.6/10.3/7.1 s**, F(4,76)=5.65; Exp 2 **28** participants, **53.6 vs 19.7 s**, **71.4% vs 47.4%** scroll, median quiz **4 vs 0**, p = 0.052, r = **0.83**; summaries hold attention **+18 s**.

5. Likely essay questions — skeleton answers

1. **"Can notice-and-consent be saved? Discuss with reference to the readings."** Use §2 thesis + table; start with *Planet49* floor → McDonald & Cranor cost → three fix families (form, content, architecture) → Dove & Chen/C&V limits → governance/intermediaries → conclusion (complementarity, Art 25).
2. **"Critically evaluate *Planet49*."** Facts, three rulings, reasoning (wording, context, evidential, legislative history, specificity, *a fortiori* under GDPR), personal vs non-personal (ePrivacy protects device integrity), what it did NOT decide (bundling), critique ("regulates the click"), links (Santos "X", Lindegren, Kay & Terry).
3. **"Is consent via cookie banners lawful and usable?" (Santos)** Heuristics A/B/C; 10 choices; opportunities/challenges/tensions; DPA conflict on colours; friction vs freely given; "Not yet"; limits (no new user testing, expert-only, 3/10 heuristics).
4. **"Should privacy policies be shorter or longer?" (Pałka vs McDonald & Cranor vs Kay & Terry)** Art 12 vs Arts 13–14; WP29 example; Pałka's experiments; M&C cost; K&T texture; layered design middle path; limits (LLM reliability, digital divide, burden).
5. **"Can technology guarantee GDPR rights?" (Najdi, Pilot)** IR1–IR11; trust gap; 4 design decisions; 9/10; IR10 and C&V; critique (unimplemented, burden, TEE trust); Pilot predicts vs Najdi prevents; Art 25 bridge + role of SA.
6. **"Controller–processor relationships" (DPC guide + Najdi + Pałka)** Art 28; 2 + 9 clauses; two-layer liability; ex post limits; leverage; link to Najdi (processors disappear) and CMPs.
7. **"Are DPIAs real protection or box-ticking?" (Iwaya, Wairimu)** positives/negatives; perfunctory; validation vs evaluation; evidence gaps; FRIAs; symbolic compliance; conflict of interest.
8. **"Do GDPR rights apply to inferences and profiles?" (C&V)** taxonomy; right-by-right table; stages argument; objections/answers; DPA as trusted third party; Najdi IR10 link.
9. **"Should consent be privileged in health research?" (Dove & Chen)** research privilege; consent misconception; spectrum; South Africa+; critique (self-assessment trust); EDPB power imbalance; links Art 7(4).
10. **"Who governs privacy?" (Medzini & Epstein)** polycentric features; DPO history; COVID educators; intermediaries across readings; critiques (hierarchy persists, Cohen).
11. **"Active engagement as affirmative action" (Lindegren, Kay & Terry, Santos)** Art 4(11)/*Planet49*; results; friction trade-off; habituation; manipulation risk; legal test checks form, not attention.

6. Common traps

- *Planet49* did **not** rule on bundling (Art 7(4)); it required info on "**consequences of any consent he or she might give**" — not "of refusing".
- Santos et al. used **3** of Nielsen's **10** heuristics; **no new user testing**; DPA decisions on colours **conflict** (Danish/Belgian 113/2024/Austrian vs Belgian 161/2023 and **LG Passau**).
- Pałka: GPT-4 **never hallucinated** on mock policy, but CoT prompt made it **worse**; a typo labels the consent question "Q6" (actually Q4).
- McDonald & Cranor: **244 h** in results vs **201 h** in conclusion; skimming figure = first-question time (**6.3 min** point).
- Najdi: framework claims "**fully supported**" without implementation, while holding others to implementation/evaluation standard (asymmetry).
- Iwaya: **prevalence ≠ importance**; 11 studies from one book.
- Wairimu: "case study" often = **use case** (validation not evaluation); Wairimu = **39** studies, Iwaya = **45**.
- C&V: type depends on **how obtained**, not content; **incorrect data is still personal data**; group profile isn't personal data until applied to an individual.
- Lindegren: recall difference **not significant**; **DAD took longer** but had **highest SUS**.
- Dove & Chen: POPIA s **27(1)(d)** (paper's "27(7)(d)" is a slip); POPIA not yet fully in force when written.
- Kay & Terry: Exp 2 result **p = 0.052** (borderline); **heavy** design also "obnoxious"; **summaries displace** full reading.
- Medzini & Epstein: DPO system is **polycentric but not ideal-type** (hierarchy remains: DPAs/courts).

UNIT 3 — CONTROLLERS, PROCESSORS & JOINT CONTROLLERS (condensed from your 5 readings C1–C5)

Source: your "Controllers, Processors & Joint Controllers — essay-ready summaries" PDF. † marks where your notes flag their own add-on/general knowledge. Where your notes flag an error in a source, it's marked ***⚠ slip****.*

0. THE BIG PICTURE (read this first)

- **Why roles matter:** the GDPR allocates responsibility **by role**. Whether an entity is a **controller, joint controller, processor, recipient or third party** decides **who must comply, who can be fined, and against whom data subjects can exercise rights.**
- **Accountability anchor: Art 5(2)** (controller responsible for, and must be able to *demonstrate*, compliance with Art 5(1) principles) → **Art 24** (appropriate TOMs) → **Art 28** (rules on engaging processors).
- **Four framing points (EDPB Guidelines 07/2020):**
    1. Concepts and criteria **have not changed since Directive 95/46/EC** → CJEU cases under the Directive **still apply**.
    2. Concepts are **functional**: roles follow **what parties actually do**, not contractual labels. Allocation "should stem from an analysis of the factual elements… and as such is **not negotiable**". AG Mengozzi (*Jehovah's Witnesses*): "excessive formalism would make it easy to circumvent" the rules.
    3. Concepts are **autonomous** (EU data protection law, not IP/competition law).
    4. "Controller" read "**in a sufficiently broad way, favouring as much as possible effective and complete protection of data subjects**" (avoid gaps/circumvention) "while at the same time **not diminishing the role of the processor**" (*Google Spain* C-131/12; *Wirtschaftsakademie* C-210/16; *Fashion ID* C-40/17).
- **The five readings:** | # | Reading | Core message | |---|---|---| | C1 | EDPB Guidelines 07/2020 (v2.1, 2021/2022) | The authoritative framework: roles, tests, Art 26 & Art 28 consequences | | C2 | Cimina (2020), EDPS — Regulation 2018/1725 | Same concepts for **EU institutions**; **joint controllership** via CJEU trilogy | | C3 | EDPB Opinion 22/2024 | **Processor/sub-processor chains**: controller must know the whole chain; verification; transfers; "unless required by law" wording | | C4 | Baquero, Restrepo Amaríles et al. (2025) | **Compliance gap** in data supply chains; contract specification languages (**Symboleo**) + smart contracts | | C5 | CJEU cases + Unit 3 link to **DPDP Act 2023** (Data Fiduciary / Processor, s 8) | Case line *Google Spain → Wirtschaftsakademie → Jehovah's Witnesses → Fashion ID*; India comparison |
- **Master theme tying them:** the law puts **ultimate responsibility on the controller**, yet many controllers (esp. SMEs, public bodies) face **take-it-or-leave-it contracts and opaque chains**. EDPB answers with **legal duties** (verify, know the chain, no excuse for "practical difficulties"); C4 answers with **technology** (formalise contracts + monitor on blockchain); C5 shows how **India** concentrates everything on the fiduciary without the Art 28 machinery.

C1. EDPB GUIDELINES 07/2020 on the concepts of controller and processor in the GDPR

Status/timeline: adopted under **Art 70(1)(e)** GDPR; consultation draft **2 Sept 2020**; final **v2.0 on 7 July 2021**; corrected **v2.1 on 20 Sept 2022**. **Replaces Art 29 WP Opinion 1/2010 (WP169).** Part I = concepts; Part II = consequences of each role; **annex flowchart**.

The controller — Art 4(7): five building blocks

Controller = "natural or legal person, public authority, agency or other body which, **alone or jointly with others, determines the purposes and means** of the processing of personal data"; where **Union or Member State law** determines purposes and means, that law may **designate the controller** or the criteria for choosing it.

1. **Type of entity** — no limit (organisation, individual, group; e.g. the religious community together with its members in *Jehovah's Witnesses*). **In practice the controller = the organisation, not its CEO, an employee, compliance officer or department.** A marketing department running a campaign with considerable independence still acts for Company ABC (the controller). **Employees' processing is presumed under the organisation's control**, unless an employee **unlawfully** uses data for own purposes (e.g. setting up own company) → organisation must prevent via measures such as **training**. Employees = "persons acting under the authority of the controller" (Art 29), **not** controllers/processors. In **company groups**, each entity's role must be checked.
2. **"Determines"** = influence through decision-making power. Questions: "**why** is this processing taking place?" and "**who decided** it should take place for a particular purpose?"
3. **"Alone or jointly with others"** — several entities may control the same processing; a party can be controller without taking every decision.
4. **"Purposes and means"** = the core. **Purpose** = "an anticipated outcome that is intended or that guides your planned actions" (the **why**); **means** = "how a result is obtained or an end is achieved" (the **how**). Controller must decide **both**; **a processor can never determine the purpose.**
5. **"Of the processing of personal data"** — control may attach to a **single operation** or a **set of operations**, the **whole processing or only one stage** (*Fashion ID*). Chain operations that look disconnected at micro level, each with own purpose, may at **macro level** form "a set of operations" pursuing a joint purpose with jointly defined means → **joint control**. Actor can be controller **even if it doesn't deliberately target personal data or wrongly thinks it processes none. Access to the data is not necessary** (*Wirtschaftsakademie*): an entity that outsources processing but has determinative influence (e.g. adjusting parameters deciding whose data is processed) is a controller.

Sources of control; essential vs non-essential means

- **Legal provisions** — **explicit** competence (law designates controller or criteria; "will be determinative") or **implicit** (law sets a task requiring processing / obliges a body to retain or provide data; the body charged = controller; e.g. municipality obliged by law to pay welfare benefits based on claimants' finances).
- **Factual influence** — judged on all circumstances; same entity can be controller for some operations, processor for others. Some roles are **"naturally attached"** to an activity via traditional roles or professional expertise: **employer→employees, publisher→subscribers, association→members. Law firm representing Company ABC** = controller (considerable independence on what info to use and how; processing "linked to the functional role" of a law firm). **Email service provider** = controller of traffic/billing data but **not** of message content where it only transmits messages (sender controls content).

- **Contracts help but aren't decisive:** a contractual statement of roles can be followed if no reason to doubt it reflects reality, but "**it is not possible either to become a controller or to escape controller obligations simply by shaping the contract in a certain way where the factual circumstances say something else**". Calling someone a "subcontractor" doesn't make it a processor (**WP29 SWIFT opinion, WP128**). Even for a pre-defined service the controller must **actively approve** how processing is done; processor can't later change essential elements without approval. Cloud provider with **standardised take-it-or-leave-it contract** → Company X remains controller (it chose that provider for its own purposes); provider is processor insofar as it acts on customers' behalf/instructions.
- **KEY CONCEPT — essential vs non-essential means:** | | Essential means | Non-essential means | |---|---|---| | Definition | "traditionally and inherently reserved to the controller" and "closely linked to the purpose and the scope" | "more practical aspects of implementation" | | Examples | **type of personal data** ("which data?"); **duration/retention** ("for how long?"); **categories of recipients** ("who shall have access?"); **categories of data subjects** ("whose data?") | choice of **hardware or software**, **detailed security measures** | | Who decides | **Controller only** (together with purpose decide whether processing is lawful, necessary, proportionate) | **May be left to processor** | Even then controller must stipulate elements in the contract (e.g. instruction to take all **Art 32** measures + duties to assist), remains responsible under **Art 24**, and must be "**fully informed about the means that are used**". Advisable to document at least necessary TOMs in the contract.
- **Worked examples (know these):**
  - **Payroll administrator** given clear instructions by **Employer A** (payments, retention, disclosures), choosing only software and internal access = **processor**. **Bank B** receiving data to make payments and independently deciding what to keep and for how long = **controller** → transfer = disclosure between two controllers.
  - **Accounting firm C** auditing A's books without detailed instructions, deciding purpose/data/retention/technical means under auditing laws = **controller**; but if law imposed no specific obligations and A gave very detailed instructions, C would be **processor** (difference: core professional activity vs limited ancillary task).
  - **Hosting provider** storing encrypted data without knowing if it's personal = **processor**; so is a **call centre** using own software but whose security measures Company X approved.
  - **Market researcher XYZ:** ABC gives the questions and receives only statistics → **ABC controller (without any access to data), XYZ processor**; but if XYZ collected data independently with own methodology and produced statistics for ABC without instructions → **XYZ sole controller, ABC has no role.**

Joint controllers — Art 26(1)

"Where two or more controllers **jointly determine the purposes and means** of processing, they shall be joint controllers." Existed under the Directive; GDPR adds **specific rules**; CJEU clarified in *Wirtschaftsakademie*, *Jehovah's Witnesses*, *Fashion ID*. Assessment is **factual not formal**; "jointly" = "together with" or "not alone". **Overarching criterion: joint participation of two or more entities in the determination of purposes AND means (must cover both).**

- **Two forms of joint participation:**
  1. **Common decision** — deciding together with a common intention.
  2. **Converging decisions** — decisions that "**complement each other and are necessary for the processing to take place in such manner that they have a tangible impact on the determination of the purposes and means**". Must concern **purposes and means**, not other

commercial matters (all commercial arrangements involve converging decisions). **Key test:** whether the processing **would not be possible without both parties' participation**, in the sense that each party's processing is "**inseparable, i.e. inextricably linked**". A processor also participates but **not for its own purposes**.

- **Three refining principles:** (1) **Access to data not required** (*Jehovah's Witnesses*: members took notes door-to-door; community was joint controller without access or written instructions because it organised/coordinated the activity and knew in general processing took place to spread the faith). (2) **Joint control covers only the jointly determined operations**; for earlier/later operations decided alone, an entity is **sole controller** (*Fashion ID*). (3) **"Joint" does not mean "equal"** — operators may be involved "**at different stages**" and "**to different degrees**" (*Wirtschaftsakademie*).
- **Jointly determined purposes** may be identical, common, or closely linked/**complementary** (e.g. mutual benefit from same operation) provided each participates in determining purposes and means. *Fashion ID*: embedding Facebook's "Like" button served economic interests of both retailer and Facebook; *Wirtschaftsakademie*: fan-page statistics helped Facebook's advertising and the administrator's promotion. **Mutual benefit is "not decisive"** — "the mere existence of a mutual benefit (for ex. commercial)" doesn't create joint control; an entity with no purpose of its own that is "**merely being paid for services rendered**" is a **processor**.
- **Jointly determined means** — each party needn't decide all means. Where one entity provides a platform/standardised tool, the entity that **decides to use it for its own purpose also participates in determining the means**: "the use of an already existing technical system does not exclude joint controllership when users … can decide on the processing". Fan-page admin defined parameters (target audience, objectives); Fashion ID, by embedding the button, "exerted a decisive influence" over collection and transmission to Facebook. **A common system does not always produce joint control**, esp. where processing is **separable** or the provider has **no purpose of its own** ("a mere commercial benefit … is not sufficient to qualify as a purpose").
- **Examples: Travel agency** sending bookings to airline and hotels = three separate controllers; but if they build a **common booking platform** for package deals, agree essential means and market jointly → **joint controllers for the platform and marketing, sole controllers otherwise. Co-branding companies** jointly running a marketing event = joint controllers for the event. **Clinical trial:** investigator and sponsor who **draft the protocol together** = joint controllers; investigator who simply accepts sponsor's protocol = processor. **"global matchz" headhunter:** no formal joint decision, but X's decision to run the matching service and Y's decision to feed it CVs are **complementary, inseparable, necessary converging decisions** → joint controllers for finding candidates; X alone controls own database; Y alone controls hiring. **Joint health study:** party that merely ran the analysis for the others with no purpose of its own = **processor** even if it chose non-essential means.
- **NO joint control in 3 situations:** (1) **mere exchange of data between separate controllers** (employer sending employee data to tax authorities under legal obligation); (2) **shared infrastructure where each entity decides its own purposes** (group companies sharing a database hosted by parent — parent = processor for storage — each deciding on its own data, access, retention); (3) **chain of successive operations with independent purposes and means** (authority compiling legally mandated statistics from data other bodies must send it = only controller of the statistics; senders responsible for accuracy).

The processor, third parties and recipients

- **Processor — Art 4(8):** processes personal data "**on behalf of** the controller". Any actor (even an individual) can be one; processors **can be held liable and fined**. Two basic conditions:
    1. **Separate entity** — one **group company** can be processor for another, but **a department cannot** be processor for another department of the same entity; employees/temporary staff under controller's direct authority fall under **Art 29**.
    2. **Processing on behalf of** the controller = "serving someone else's interest"; recalls legal concept of **delegation**. Processor follows instructions **at least on purpose and essential means**; **lawfulness (Art 6 / Art 9) derives from the controller's activity**; processor may have **some discretion over TOMs** but **may not process for its own purposes**.
- **Processor going beyond instructions → Art 28(10):** infringes GDPR and is **treated as a controller** for that processing. **MarketinZ example:** contract called it GoodProductZ's "data processor" for advertising; it used the customer database to **develop its own business** → became controller for that processing, an infringement.
- **Not every service provider is a processor** — role stems "from its concrete activities in a specific context", not entity type. **Taxi company whose platform lets businesses book airport taxis for employees** = controller (designed the platform, decides categories and retention). **General IT support provider** with "systematic and inevitable" access = **processor** needing an Art 28 contract; **IT consultant fixing a bug with purely incidental, very limited access** = **neither processor nor controller** (customer relies on Art 32 measures). **Standardised cloud service used by a municipality's schools** = processor, but municipality must ensure its **specific storage and deletion instructions** are respected "regardless of what is generally offered in the standardized service", since the controller "must make the final decision to **actively approve** the way the processing is carried out, at least insofar as concerns the **essential means**."
- **Third party (Art 4(10))** = anyone other than data subject, controller, processor, and persons under their direct authority authorised to process (e.g. employees). **Employee accessing data without authorisation for own purposes = third party** (and controller if processing for own purposes). Another company in the same group = third party; so are cleaners; **parent company requesting subsidiaries' employee data for group statistics = third party that then becomes controller of its own statistics.**
- **Recipient (Art 4(9))** = anyone to whom data are **disclosed**, third party or not, **except public authorities receiving data in a particular inquiry under the law** (e.g. tax/customs — Recital 31). A processor receiving data is a recipient; so are the airlines/hotels/excursion providers to which travel agency ExploreMore sends data (all controllers).

Controller–processor relationship & the Art 28 contract

- **GDPR novelty:** processors now have **direct obligations** — records (**Art 30(2)**), security (**Art 32**), DPO in some cases (**Art 37**), notifying controller of breaches without undue delay (**Art 33(2)**), **Chapter V** transfer rules and (in EDPB's reading) the **Art 28(3)** duties such as assistance.
- **Art 28(1) sufficient guarantees:** controller may use only processors providing **sufficient guarantees** of appropriate TOMs and must **assess** them and be able to **prove** it took the GDPR's requirements into serious consideration. Processor demonstrates via documents (privacy policy, information security policy, **external audit reports, certifications such as ISO 27000**). **Case-by-case risk assessment; no exhaustive list**, though **Recital 81** points to expert knowledge, reliability, resources, market reputation; adherence to **approved code of conduct or certification (Art 28(5))** helps. **Continuing obligation**: "does not end at the moment where the controller and processor conclude a contract" → verify at appropriate intervals incl. audits/inspections.

- **A contract or other legal act is mandatory:** in **writing, incl. electronic form (Art 28(9))**; non-written agreements insufficient however thorough; signatures recommended. Must **bind the processor** and set out the controller's obligations too; an "other legal act" (e.g. national law) must be supplemented if content missing. **Absence of contract = infringement for which both controller and processor are responsible** → SA may fine both; **pre-GDPR contracts not updated to Art 28(3) are also an infringement.** Yet the contract **doesn't decide whether the relationship exists** (factual analysis can set it aside; a relationship can exist without a contract, in breach of Art 28(3)). EDPB recommends gathering the Art 28 terms **in one place (e.g. an annex)**.
- **Standard contractual clauses (SCCs)** — parties may draft own terms or use SCCs in whole/part (**Art 28(6)**), adopted by the **Commission (Art 28(7))** or by an **SA through the consistency mechanism (Art 28(8))** (e.g. Danish SA's clauses in **EDPB Opinion 14/2019**). **Not to be confused with Art 46(2) transfer SCCs.** SCCs optional, but if used the clauses must stay the same (blanks may be filled; non-contradictory clauses added).
- **Power imbalance:** contracts often drafted unilaterally by providers; SCCs "**may contribute to rebalancing the negotiating positions**"; provider drafting "is not in itself problematic". But "**the imbalance in the contractual power of a small data controller with respect to big service providers should not be considered as a justification for the controller to accept clauses … which are not in compliance**", nor can it "discharge the controller from its data protection obligations". A controller that freely accepts such terms "has also accepted full responsibility". **Modifications must be directly notified to and approved by the controller**; "the mere publication of these modifications on the processor's website is not compliant with Article 28".
- **Contract content:** "should not merely restate the provisions of the GDPR"; must give "**more specific, concrete information** as to how the requirements will be met and which level of security is required"; "far from being a pro-forma exercise" (**Recital 79** — clear allocation of responsibilities). Must describe: **subject-matter** ("video surveillance recordings of people entering and leaving a high-security facility"), **duration**, **nature and purpose** ("filming" and "archiving of images" to detect unlawful entry), **type of personal data** "in the most detailed manner as possible" (not merely "personal data pursuant to Art 4(1)" but e.g. "health records"), **categories of data subjects**, and the **controller's obligations and rights** (instructing, supervising, auditing).
- **THE EIGHT MANDATORY CLAUSES OF ART 28(3) (memorise):** | # | Clause | Content | |---|---|---| | 1 | **(a) Documented instructions** | Incl. on **third-country transfers**, unless EU/Member State law requires otherwise → processor must **inform controller first unless that law forbids it**. EDPB recommends an annex with procedure/template for further instructions. Without authorisation for transfers, processor can't use a third-country sub-processor or its own non-EU divisions | | 2 | **(b) Confidentiality** | Persons authorised to process bound by an "appropriate" contractual or statutory duty; covers employees/temporary staff on need-to-know basis | | 3 | **(c) Art 32 security** | Processor takes all Art 32 measures; contract must describe the measures in enough detail for controller to assess, require **approval before changes**, and provide for regular review | | 4 | **(d) Sub-processor conditions** | Respect Art 28(2) and (4) | | 5 | **(e) Data subject rights** | Assist "insofar as this is possible", from forwarding requests promptly to technical extraction; **controller still decides admissibility**; **Chapter III deadlines cannot be extended** because processor must supply info | | 6 | **(f) Arts 32–36** | Assist with security, **breach notification, DPIAs, prior consultation**; notifies breaches to controller "**without undue delay**" (possibly within hours in contract); may be authorised to notify SA/data subjects directly but **legal responsibility stays with controller**; for DPIAs the controller takes the initiative; "**the duty of assistance does not consist in a shift of responsibility**" | | 7 | **(g) Deletion/return** | At end of services **delete or return** all data at controller's choice (may be set at outset and changed later); secure deletion confirmed within agreed time | | 8 |

(h) Compliance info & audits | Provide **all information necessary to demonstrate compliance**, allow and contribute to **audits incl. inspections**; processor may suggest an auditor but **final choice of auditor and of remote vs on-site audit is the controller's**; audit costs are a commercial matter but "**clearly disproportionate or excessive**" fees that would make Art 28(3)(h) "purely theoretical" not allowed |

- **Infringing instructions:** Art 28(3) also requires the processor to **immediately inform** the controller if, in its opinion, an instruction **infringes data protection law**; controller then assesses. Contract should set consequences (termination if controller persists; suspension of the instruction until controller confirms, amends or withdraws).
- **Sub-processors (Art 28(2) and (4)):** "chains of subcontracting are becoming increasingly complex" while controller "retains its pivotal role"; need **prior specific or general written authorisation** before any data entrusted. Processor must list intended sub-processors with **location, tasks, proof of safeguards**.
    - **Specific authorisation:** covers a **named** sub-processor for a specific activity and time; **a request left unanswered within the timeframe counts as DENIED.**
    - **General authorisation:** annexed list + selection criteria; processor informs controller "**in due time**" of changes so it can object; **failure to object in time = authorisation**. **Key difference = meaning of the controller's silence.** Changes must be **actively flagged**; merely giving access to a list updated from time to time is not enough.
    - **Art 28(4):** processor must impose **"the same data protection obligations"** on sub-processor by contract, **including audit rights**, since "the whole chain … needs to be regulated by written agreements". "Same" read **functionally** (substance must match, not words; obligations irrelevant to the sub-processor's task needn't be included). **Initial processor remains fully liable** to the controller for its sub-processors → should propose only those with sufficient guarantees.
- **Liability: Art 82(2)** processor liable for damage only if it breached **processor-specific obligations** or acted **outside/contrary to lawful instructions**; **Art 82(4)** each party involved is **jointly and severally liable for entire damage** to ensure effective compensation, with **recourse between them (Art 82(5))**. Breaches of **Arts 25–39** incl. Arts 26 and 28 can attract fines up to **€10 million or 2% (Art 83(4)(a))**.

The Art 26 arrangement between joint controllers

- Joint controllers must determine their respective responsibilities "**in a transparent manner**" (Art 26(1)) — "who does what" — to avoid reduced protection or "**a negative conflict of competence**" where no one complies. One party's **dominant influence** "does not negate the joint controllership and cannot serve to exempt either party".
- Art 26(1) mentions "**in particular**" data subject rights and **Arts 13–14** information → list **non-exhaustive**. EDPB adds: **Art 5 principles, legal basis, security, breach notification, DPIAs, use of processors, transfers, contact with data subjects and SAs. Each controller needs its own legal basis** and must prevent incompatible further use (joint control doesn't authorise purposes beyond joint scope).
- Allocation is **flexible, need not be equal** (*Wirtschaftsakademie*); should reflect who is **competent and in a position to act**, and be **documented**. But some duties **cannot be divided**: with shared tools **both must ensure purpose limitation and security**. GDPR doesn't specify legal form; EDPB recommends a **binding contract or legal act** (so one can seek the other's liability for its allocated part and both can demonstrate compliance), in **clear and plain language**.

- **Towards data subjects:** arrangement must "**duly**" (accurately) **reflect the parties' roles (Art 26(2))**; its "**essence**" must be made available. EDPB: essence should cover at least all **Arts 13–14** information, stating which joint controller is responsible for each element, and the **contact point**. Controllers choose means (e.g. privacy policy). Contact point **recommended but not mandatory**.
- **Crucially, data subjects are NOT bound by the arrangement** and may exercise rights **against each controller (Art 26(3))** — e.g. against the one in their Member State; requiring them to use the contact point would be an "**excessive burden**" → controllers should forward requests internally. **SAs also not bound** (by joint-controller qualification or contact point) and may approach any of them (**Art 58**).

The flowchart & debates

- **Flowchart logic:** check legal appointment/legal task → does a party decide **purposes, which data, which individuals, whether and to whom data are disclosed, how long kept**? If so = **controller**; if it merely acts on another's instructions, deciding at most **non-essential means** = **processor**. In doubtful cases: **benefit beyond payment for services** or a **relationship with the data subjects as employees/customers/members** points to control; **following documented instructions with no purpose of own** points to processing. Last step: would processing be **impossible without more than one party's decisive influence**? → **joint controllers** for whole processing or particular stages.
- **Debates:** (i) **functional approach** prevents circumvention but creates uncertainty — EDPB eases by following contracts that reflect reality. (ii) **Expansion of joint control** via the CJEU trilogy closes gaps but critics warn of **over-inclusion**, small parties bound by platform terms they can't influence, vague boundaries (**AG Bobek in *Fashion ID*** warned against making everyone responsible for everything†). Answers: **"joint ≠ equal"**, **control limited to particular phases**, **commercial benefit alone isn't enough**. (iii) **Power imbalance** stance can be criticised for ignoring a cloud market where **SMEs cannot negotiate** (responses: SCCs, certification, collective procurement†).
- **India link: DPDP Act 2023 s 8(1)** = fiduciary responsible "irrespective of any agreement to the contrary"; **s 8(2)** requires processors to act under "a valid contract" but **prescribes no contract content**, has **no Art 26-style arrangement rules** and **no equivalent of Art 28(10)** → lacks the machinery these Guidelines elaborate.

C2. CIMINA (2020) — "The data protection concepts of 'controller', 'processor' and 'joint controllership' under Regulation (EU) 2018/1725" (*ERA Forum*, Oct 2020)

*Written by a Legal Officer at the **EDPS** (in a personal capacity). Summarises novelties of the **EU institutions' data protection regulation** for the three concepts, esp. **joint controllership** as interpreted by the CJEU.*

Why it matters; the Regulation

- EU institutions, bodies, offices and agencies (**EUIs**) are **not governed by the GDPR** but by its sister instrument **Regulation (EU) 2018/1725 ("EUDPR")**, which **repealed Regulation 45/2001**, supervised by the **EDPS**. **Deliberately aligned with the GDPR**: provisions mirror GDPR's but with different numbers.

- **Mapping (memorise):** | Concept | EUDPR | GDPR | |---|---|---| | Controller definition | **Art 3(8)** | Art 4(7) | | Processor definition | **Art 3(12)** | Art 4(8) | | Accountability | **Arts 4(2) and 26** | Arts 5(2), 24 | | Processors | **Art 29** | Art 28 | | **Joint controllers** | **Art 28** | **Art 26** | | Data subject rights | Arts 17–24 | Chs III | | Information duties | **Arts 15 and 16** | Arts 13–14 | | Compensation | **Art 65** | Art 82 |
- Because texts run in parallel, **CJEU case law carries across** to EUIs. **Timing note:** Cimina wrote **before final EDPB Guidelines 07/2020**; relies on the **September 2020 consultation draft** and **EDPS Guidelines of 7 Nov 2019** on the same concepts.

The controller (Art 3(8)) — six elements

Controller = "the Union institution or body or the **directorate-general** or any other organisational entity which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means … are determined by a specific Union act, the controller or the specific criteria for its nomination can be provided for by Union law".

1. **Who can be a controller:** includes a **DG** (department of Commission etc.) and "any other organisational entity" → **a DG can be a controller in its own right.** *Differs from GDPR* where **EDPB says a department can't be controller; the organisation is.*
2. **"Alone or jointly with others"** → opens door to joint control; CJEU confirms each actor has its own obligations.
3. **"Determines"** = **factual influence** over a specific operation (*Wirtschaftsakademie*, *Fashion ID*, AG **Bot** and **Bobek** Opinions). Factual evaluation: reason for the processing, **who initiated it, who benefits**.
4. **"Purposes and means"** = heart. Controller decides purpose as a matter of fact; "means" = **TOMs** used to carry it out. Following EDPB: **essential means** (type of data, retention, data subjects, who has access, recipients) = controller; **non-essential means** (software/hardware choice, detailed technical security measures) = may be decided by processor under general instructions.
    - ⚠ **Wording tension to flag in an essay:** Cimina writes "**although purposes and means are linked, it is not necessary for an entity to equally determine both in order to be considered a controller**." On its own this **conflicts with the final EDPB Guidelines** (controller must decide **both** purpose and means). **Reconciliation:** controller must always decide **purpose + essential means**, but need not decide **every aspect of the means equally** (non-essential means may be delegated). Her sentence permits delegating non-essential means; it **doesn't make means optional.**
5. **Control relates to "the processing"** — Art 3(3): any operation or set of operations; control may cover the whole or part (decisive in *Fashion ID*).
6. **EUI-specific:** where a Union act determines purposes and means, it may **designate** the controller; even without express designation, controller found through **implicit competence** (law assigns a task to an EUI that requires processing).

- **Art 26:** controller bears **main responsibility for compliance and duty to demonstrate it**; towards data subjects (Arts 17–24) it is "**the main point of reference**". CJEU has **broadened data subject protection by extensively expanding joint controllership**, building on the broad reading of "controller" in ***Google Spain*** (C-131/12) — justified by need for **effective and complete protection**.
- **Liability — where Regulation departs most from GDPR: Art 65** gives anyone who suffers **material or non-material damage** a right to compensation from the EUI "**subject to the conditions provided for in the Treaties**". Unlike Art 82 GDPR, it is **brief and silent on how liability is split between controller and processor** → read with **Art 340 TFEU** (Union makes good

damage caused by its institutions per general principles common to Member States' laws) and **Art 268 TFEU** (CJEU jurisdiction). **No case law yet** → allocation will be settled by the CJEU.

The processor (Art 3(12))

- Defined **exactly as Art 4(8) GDPR**: processes personal data "**on behalf of** the controller".
- **Striking EUI point:** DGs are listed as possible **controllers** but **not as possible processors**. Yet, as the EDPS observes, DGs often process data **on behalf of other DGs** as "**support DGs**" or business owners, in a role similar to a processor's, sometimes reinforced by **Service Level Agreements (SLAs)** → EDPS recommends **internal arrangements identifying exact tasks and responsibilities** of support DGs.
- **Essence of the role:** processing on behalf of the controller, in its interest, following its instructions. **Processor is not a mere tool** — keeps "**a considerable degree of autonomy**" in deciding how to provide services and choosing non-essential means; may propose/advise but controller decides whether to accept without imposing every element. If a processor goes beyond its mandate and decides purpose and essential means → may become **controller or joint controller** depending on scope of deviation (e.g. whether it departed from instructions to comply with data protection principles). **Reusing data for its own purposes = clear breach.** GDPR reaches same result in **Art 28(10)**.
- **Art 29(1):** controller may use only processors offering **sufficient guarantees** of appropriate TOMs; accountability means it must **assess** and **prove**. **Due diligence:** check privacy/records-management/information-security policies, external audit reports, processor's reliability & expertise on breaches/security → only then contract; **keep verifying compliance regularly**. EDPS adds: processor should not outsource further without **prior authorisation**, keep controller informed of changes with a **right to object**, pass **same contractual obligations** to any subcontractor; a processor subject to GDPR → GDPR compliance is one element of sufficient guarantees. Processor must also **assist** with data subject rights and with **Arts 33–41** (security, breach notification, DPIAs, **confidentiality of electronic communications**) → controller must set clear rules and precise instructions in the contract.
- **Processor liability "still more limited in scope"** than controller's (Recitals 45 and 50 and Art 29 strengthen processors' responsibilities, but): controller may be liable for damage from an infringement **or a breach of contract**; processor liable when it **acts outside the controller's mandate or breaches its own obligations under the Regulation**. Can be **entirely liable if it bears the main responsibility** for the damage; **if it followed strict instructions it is not liable.** Towards data subjects, controller is the main responsible party; processor answers only if shown to have acted beyond mandate. **Compare Art 82(2) GDPR** (processor liable only for processor-specific breach/outside or contrary to lawful instructions) and **Art 82(4)** (joint and several liability for whole damage)†.

Joint controllership under Art 28

- Not new (Reg 45/2001 and Directive 95/46 already referred to "alone or jointly"). **Novelty = full dedicated provision, Art 28 (= Art 26 GDPR). Art 28(1):** joint controllers exist "where two or more controllers or one or more controllers together with one or more controllers **other than Union institutions and bodies** jointly determine the purposes and means". Can link **two EUIs**, or an EUI and an **outside actor** (management portal provider; national public authority). Outside party is subject to the GDPR but **Art 28 of the Regulation still applies in full.**

- **Each joint controller must have the possibility or right to determine purpose and essential means** — by agreement, or (following *Fashion ID* and EDPB) by **converging** on purpose and essential means where the processing "**would not be feasible without the participation of both parties**". Cimina: "in substance, a **general level of complementarity and unity of purpose** may already be enough to trigger joint controllership, if these elements are jointly determined." **Access to data not needed** (lack of access may affect a party's level of responsibility, **not its role**). **Distinguishing joint from separate controllership** (each pursuing own purposes) is difficult in practice; if parties neither jointly determine nor converge on purpose and essential means → **separate controllers**. **EUI example:** institution processing data for **security purposes** and, after an incident, transferring data to authorities for investigation → **each a separate controller**.
- **Art 28(1) arrangement:** joint controllers determine responsibilities "in a transparent manner", "**in particular**" for **data subject rights and information duties**, "**by means of an arrangement**", **unless and in so far as Union or Member State law already does so.** Cimina: clear allocation = "**an essential condition for the protection of the rights and freedoms of data subjects**". **Responsibility need not be equal** — *Wirtschaftsakademie*: "the existence of joint responsibility does not necessarily imply equal responsibility … those operators may be involved at different stages … and to different degrees" → assessed **case by case, by stage** (e.g. the party that deals with data subjects will likely take on that responsibility).
    - **Arrangement mandatory unless law allocates the roles.** If EU legislation gives a clear allocation (even partial) in the **operative part of the act or at the latest in an implementing or delegated act**, no further arrangement needed — **EDPS recommends such allocation in legislation**; otherwise arrangement fills the gaps. Form: **Memorandum of Understanding (MoU) or contract**; an **SLA** may supplement an MoU with technical detail, and EDPS accepts that **an SLA alone can suffice if it contains all required elements.** Must be **agreed by all joint controllers, not adopted unilaterally by one EUI**, and define scope (subject matter, duration, nature and purpose, categories of data and data subjects). Substance should cover: roles/responsibilities; **information duties under Arts 15 and 16**; **a contact point** for requests; cooperation in replying to data subjects and in DPIAs; any processor engaged.
    - **Art 28(2):** "**the essence of the arrangement shall be made available to the data subject**" — through the data protection statement, separately, in a common notice, or by one designated controller.
    - **"Irrespective of the terms of the arrangement"** the data subject may exercise rights "**in respect of and against each of the controllers**" → Chapter III rights cannot be limited. Because organisationally complex → include **cooperation obligations** and a **specific contact point** (EDPS recommends a single one, e.g. email). "**It is insufficient for a joint controller to merely forward a data subject's request to the responsible data controller: it must, in fact, also ensure that adequate follow-up is provided.**" **Art 65** governs joint controllers' liability **in the same way as a single controller's.**

The CJEU trilogy (all decided under Directive 95/46, but with the new framework in mind)

Case	Facts	Holding
Wirtschaftsakademie Schleswig-Holstein (**C-210/16, 5 June 2018**, Grand Chamber)	German education company ran a **Facebook fan page**. **Facebook Insights** (free, **non-negotiable terms**) gave administrators **anonymous visitor statistics** gathered through **cookies with a unique user code active for 2 years**. ULD (Schleswig-Holstein authority) ordered page **deactivated**; company argued processing was Facebook's	**Joint controller with Facebook Ireland**: by **defining parameters** (target audience, objectives, promotion of its activities) it took part in determining purposes and means; could request anonymised demographic (age, sex, relationships, occupations), lifestyle/interest and geographic data. **Using a platform didn't exempt it. Access unnecessary**; joint responsibility ≠ equal responsibility. Mahieu & van Hoboken: "the responsibility of a controller should be dependent on the **stages of the processing** in which it is involved and on the **degree of this involvement**". Cimina accepts the **imbalance between small administrator and Facebook** but says it doesn't defeat the ruling since aim is "fundamental and complete protection"
Jehovan todistajat / Jehovah's Witnesses (**C-25/17, 10 July 2018**)	Finnish authority prohibited the community from collecting data in **door-to-door preaching**; members noted **names, addresses, religious beliefs, family circumstances** as memory aids, without people's knowledge. Community gave **no written instructions** but made maps allocating areas, recorded preachers/publications, kept list of people refusing visits	(1) **Manual processing covered** where data forms or is meant to form part of a **filing system** — notes qualified, **no need for data sheets, lists or search methods**. (2) **Community and preaching members = joint controllers**: by **organising, coordinating, encouraging** the preaching it participated in determining purposes and means, with general knowledge data were collected to spread the faith; **absence of written instructions or access didn't exclude it.** Control can arise from **organisation alone**; **individuals can be joint controllers with an organisation**
Fashion ID (**C-40/17, 29 July 2019**)	Online clothing retailer embedded Facebook's **"Like" button**; visitors' data transmitted **automatically** to Facebook Ireland **without awareness, whether or not members or clicked**. **Verbraucherzentrale NRW** sued; **OLG Düsseldorf** referred	**Joint controller with Facebook for collection and disclosure by transmission**: embedding the plug-in "**exerted a decisive influence**", for own **commercial advantage** (publicity/visibility on Facebook). **NOT a controller for Facebook's subsequent processing** (couldn't determine purposes/means). Duties follow same line: **inform at collection (identity and purposes)**; where consent needed, obtain it **only for operations it jointly controlled**. EDPB generalised: for any preceding/subsequent operations an entity decides alone → **sole controller**. **"Phase-oriented" approach narrows the breadth of *Wirtschaftsakademie***

- **Cimina's 7 conclusions (CJEU clarifications):** (1) full and complete protection of data subjects is key → they must always be able to exercise rights easily and know each entity's role; (2) specific influence over processing for **one's own purposes**, by participating in purposes and essential means, may be enough for joint control; (3) an entity is joint controller **only for operations in which it participates** → duty to inform data subjects of its identity and purpose at collection; (4) joint control ≠ necessarily equal responsibility; (5) **lack of written guidance/instructions doesn't exclude decisive influence**; (6) clearly defined roles foster data subject protection and underline **accountability**; (7) **no access to data doesn't exclude joint control.**

Critical assessment

Beyond the wording issue on purposes/means: (1) **Over-inclusiveness** of *Wirtschaftsakademie* and *Jehovah's Witnesses* — every site with a plug-in or fan page becomes a co-controller; unclear liability and **compliance burdens for small actors who cannot influence large platforms**. *Fashion ID*'s phase limit,

"joint ≠ equal" and later EDPB "mere commercial benefit alone doesn't create joint control" moderate this; **AG Bobek (Fashion ID)** warned against making everyone responsible for everything†. (2) **Power imbalance:** fan-page admin had no negotiating power over Facebook yet was jointly responsible; EDPB Guidelines refuse to let small controllers hide behind imbalance (→ *Compliance Gap* reading, C4). (3) **EUDPR liability gap:** Art 65's vague reference to the Treaties leaves allocation between EUI controllers and processors unclear until CJEU rules. (4) **DGs can be controllers but not processors** — an internal-organisation nuance unique to the EU institutions.

C3. EDPB OPINION 22/2024 on certain obligations following from the reliance on processor(s) and sub-processor(s) (adopted 7 October 2024)

Background and questions

- **Scenario:** a public body moves to the cloud; the cloud provider (initial processor) relies on subcontractors, who may use further subcontractors. Under **Art 4(8)** the term "processor" covers not only the initial processor but also the processor's processor "**and so on along the processing chain**". GDPR governs the chain mainly via **Art 28**: controller may use only processors with **sufficient guarantees (28(1))**; processor needs controller's **prior written authorisation** for sub-processors (28(2)); contract must contain **Art 28(3)** clauses; each processor must pass **same data protection obligations** to sub-processors (28(4)). Above these: **accountability (Art 5(2))** and **Art 24** (TOMs in light of risk).
- **Trigger: EDPB Coordinated Enforcement Framework (CEF) report of 17 Jan 2023** on public sector's use of cloud-based services identified **eight challenges** and left the extent of some obligations unclear. On **5 July 2024** the **Danish SA** asked the Board for an opinion under **Art 64(2)** ("matter of general application"). Deadline extended under **Art 64(3)** (8 weeks + 6); **Opinion adopted 7 Oct 2024, signed by Chair Anu Talus.** Admissible because it concerned interpretation of **Arts 5(2), 24, 28**, was reasoned, and hadn't already been answered (Guidelines 07/2020 gave only partial guidance).
- **Limits of the Opinion:** Board did **not** decide who is controller/processor in any arrangement ("primarily up to the parties", subject to SA checks); did **not** address **liability to data subjects (Art 82)**; stressed that meeting the **Art 28(1) verification duty doesn't mean the controller complies with other provisions** (lawfulness, **Art 32 security**, **Chapter V**).
- **Danish SA's questions: Q1 (controller's duties along the chain):** 1.1 must the controller identify **all sub-processors or only the first line**, and how far must it verify safeguards of (sub-)processors and the **content of sub-processing contracts**? 1.2 how far must it, under **Art 28(1) and Art 44**, assess and show that protection isn't undermined when (sub-)processors **transfer data outside the EEA** on its instructions? 1.3 do these obligations **vary between low-risk and high-risk** processing? **Q2 (contract wording):** 2 must the contract contain the **Art 28(3)(a) exception** "unless required to do so by Union or Member State law to which the processor is subject"? 2a is a **broader exception** covering third-country law, "unless required to do so by law or binding order of a governmental body", **in itself an infringement**? 2b should such a broader exception be read as a **documented instruction** from the controller?

Q1.1 — Knowing the whole chain

- **Controller must know the whole chain, not just the first line.** Guidelines 07/2020: "although the chain may be quite long, the controller retains its pivotal role". **"Identity" = name and address of each processor, a contact person (name, position, contact details) and a description of the processing** with a clear delimitation of responsibilities where there are several sub-processors. Mirrors **Annex IV of Commission Controller–Processor SCCs (Decision 2021/915)** and **Annex III of International Transfer SCCs (Decision 2021/914)**.
- **Three reasons:** (1) **choice of recipients, incl. processors, is one of the essential means** of processing (which data used, how long, who has access and whose data) which only the controller may make. (2) **Art 28(2) authorisation system depends on it**: under specific authorisation the controller approves each sub-processor individually (silence = refusal); under general authorisation it approves an initial list and must have enough time to object to changes which the processor must actively flag. (3) **Processors are "recipients" (Art 4(9))**, so transparency and data subject rights depend on knowing them: **Arts 13(1)(e) and 14(1)(e)** require recipient information "**as specific and concrete as possible**" (WP29 transparency guidelines: generally means **naming** them); **Art 30(1)(d)** requires them in the **RoPA**. ***RW v Österreichische Post*** (**C-154/21, 12 Jan 2023**): **Art 15(1)(c)** access right gives data subject the actual **identity of recipients** unless identification impossible or request manifestly unfounded/excessive; under **Art 19** data subject may learn which specific recipients were told of rectification/erasure/restriction.
- **Conclusion:** controllers should have the identity of all processors and sub-processors "**readily available at all times**" → answer access requests without undue delay, react quickly to breaches along the chain, cope if chain breaks (sub-processor unreachable, unwilling or insolvent). Applies "**regardless of the risk**". To make workable: processor should **proactively provide** the info and **keep it up to date**, in a format the contract may specify.

Verifying "sufficient guarantees"; how risk affects it

- ***Proximus*** **(C-129/21):** Arts 5(2) and 24 "impose general accountability and compliance requirements", obliging controllers to "take appropriate steps to prevent any infringements"; accountability remains with controller **even when using processors**. **Central principle:** "**the engagement of processors should not lower the level of protection for the rights of data subjects compared to a situation where the processing is carried out directly by the controller**" — applies to sub-processors and sub-sub-processors. Controller must ensure the **whole chain** consists only of processors with sufficient guarantees and be able to prove it took GDPR requirements into serious consideration, "even if the chain of processing can be long and complex". **Due diligence in both selection and oversight.**
- **Initial processor:** verification **case by case** (nature, scope, context, purposes, risks). **Codes of conduct (Art 40)** and **certification (Art 42)** can help demonstrate (**Art 28(5)**). **Non-exhaustive methods:** questionnaire; requests for documentation; publicly available information; certifications or audit reports from trustworthy third parties; **on-site audits**. Guarantees must be demonstrated "to the controller's satisfaction"; verification **repeated at appropriate intervals**.
- **Risk (Q1.3):** risk-based approach doesn't let a controller "**neglect or deviate from its obligations**" because it considers the risk "low". Following ***Natsionalna agentsia za prihodite*** **(C-340/21)**: the duty to implement appropriate TOMs **always applies**; only the **measures vary**. Art 28(1) doesn't mention risk but implies it; for **high-risk processing** (e.g. special categories) controller may set **stricter TOMs** processors must be able to meet. **Answer:** the obligation to verify sufficient guarantees "**should apply regardless of the risk**", but its **extent varies** — lower risk allows less extensive verification; higher risk makes verification of the **entire chain** more important (controller

may check sub-processing contracts itself or require extended verification and documentation from the initial processor). **Separates the existence of the duty from its intensity.**

Relying on the processor without giving up responsibility

- Verifying a long chain could be impossible, so the Board eases it: (1) processor must **assist (Art 28(3)(e),(f))** and make available **all information necessary to demonstrate compliance** and allow **audits (28(3)(h))** — controller may rely on this "provided that the information … actually demonstrates compliance", and processor should share proactively; duties pass down chain under **28(4)**. (2) **Before a sub-processor is engaged**, a general authorisation should be supplemented with **criteria** (TOMs, expertise, reliability, resources); processor supplies **list of intended sub-processors with locations, tasks, proof of safeguards**; initial processor proposes only those with sufficient guarantees and **remains fully liable** to the controller (Art 28(4)).
- **No burden shift:** processor's Art 28(4) duty "**does not lift the responsibility of the controller**". **Key sentence:** "the ultimate decision on whether to engage a specific sub-(sub-)processor and the pertaining responsibility, including with respect to verifying the sufficiency of the guarantees provided by the (sub-)processor, **remains with the controller**." SAs should ask whether the controller can show verification "**has taken place to the controller's satisfaction**". Controller may rely on processor's information and build on it, but where incomplete, inaccurate or raising questions, or risk warrants, controller must **ask for more and verify, complete or correct it**; for high-risk processing it should **increase verification across the chain**. **"Reliance is allowed; blind reliance is not."**

The sub-processing contracts and the Art 28(4) flow-down

- **Art 28(4)** directly obliges processors to impose "**the same data protection obligations**" on sub-processors; **Art 28(3)(d)** makes this contractual too → initial processor "**legally and contractually required**" to pass them down. "**Same**" read functionally (identical wording not required); under **Module Three of the Transfer SCCs** the exporter warrants it has done so. If a sub-processor fails: "**ultimate responsibility**" rests with controller, but initial processor "**will remain liable to the controller**" (contractual claim).
- **Can controller see the contracts? Art 28(3)(h)** requires the processor to provide them on request; **Clause 7.7(c) Controller–Processor SCCs** and **Clause 9(c) Transfer SCCs** let controller request a copy, **business secrets redacted** ("an expression of the controller's right of audit"). But SCCs don't say whether the controller **must** ask. **Board:** "**the controller does not have a duty to systematically ask for the sub-processing contracts**." Decide **case by case**, and as part of its audit right it should have "**a process in place to undertake audit campaigns … sampling verifications**" that contracts contain necessary obligations. Request a contract **where there are doubts** or the SA asks (e.g. after a data breach at the sub-processor; public/other information suggests a problem such as a sub-processor's template not meeting Art 28(3)).
- **Caveat:** a copy may help but "**contractual clauses cannot – by themselves – demonstrate that the sufficient guarantees are effectively implemented**" → **paper compliance ≠ real compliance** (links straight to C4).

Transfers along the chain (Q1.2)

- "**Transfer**" per **Guidelines 05/2021** — **remote access from a third country can be a transfer. Controller decides whether transfers are allowed at all:** processors must not transfer outside its

instructions (Art 29), instructions pass down chain (Art 28(4)), controller can **prohibit transfers or limit to specific countries**.

- **Controller's responsibility persists though the processor is the exporter**: **dual duties under Art 44 and under Art 28(1)** (whose reference to "the requirements of this Regulation" includes **Chapter V**). **Art 44** binds **both** controllers and processors — both must ensure protection is not undermined whatever the transfer ground (***Schrems II*, C-311/18**), both individually liable; controller can claim back from processor (**Art 82(5)**). Duties apply **before the transfer and while data is processed abroad**; verification again required **regardless of risk**, though a transfer may itself increase risk (**Recital 116**). Controller may **refuse a sub-processor whose engagement would entail a transfer**. Controller is **ultimately responsible for any Art 28(1) infringement**; "**practical difficulties**" invoked in controlling sub-processor engagement, esp. third-country transfers, "**do not exonerate the controller**" — weak bargaining power is no excuse (cloud/Big Tech imbalance).
- **Non-exhaustive documentation** processor/exporter prepares and controller assesses, builds on, and can show SA:
    1. **Transfer mapping** ("know your transfers" — **Recommendations 01/2020**): which data goes where incl. by remote access, for which purposes; controller should ask for more if a sub-processor's location is missing or remote access isn't mentioned; needed before engagement, for transparency (**Arts 13(1)(f), 14(1)(f), 15(1)(c), 15(2)**) and the **RoPA (Art 30(1)(d)–(e))**.
    2. **Ground for transfer:** under **adequacy decision (Art 45)** controller checks decision is **in force and covers the transfer**; for **onward transfers** it need not check onward-transfer rules itself since adequacy decision already covers them (**Art 45(2)(a)**), though must still ensure sufficient guarantees under Art 28(1). Under **Art 46** safeguards (**SCCs or binding corporate rules (BCRs)**), a **Transfer Impact Assessment (TIA)** is needed in line with *Schrems II* and Recommendations 01/2020: assessment of whether third-country law and practice, **esp. public-authority access**, would undermine safeguards, with **supplementary measures** where needed. For onward transfers, controller need not verify the Art 46 tool's rules as such but should be able to show **importers actually comply**.

The wording of Art 28(3)(a): "unless required by law"

- **Art 28(3)(a):** processor acts "only on documented instructions … including with regard to transfers … **unless required to do so by Union or Member State law to which the processor is subject**", in which case it must **inform the controller beforehand unless that law forbids it on important grounds of public interest.**
- **Q2:** Board began from the principle that **contracts cannot override the law or bind third parties such as public authorities**. Every contract must address situations where the processor may be **legally required** to process outside instructions; the **duty to inform** the controller is a **core element** to include. **Outside the EEA** a reference to "EU or Member State law" "may not be very meaningful", and the Commission's **International Transfer SCCs omit the "unless" wording**, handling it via **Clause 8.1** (inform immediately if unable to follow instructions) and **Clause 14(e)** (notify laws preventing compliance). **Board: including the clause is "highly recommended, but not strictly required"**, without prejudice to the **mandatory duty to inform**. Where EU/Member State law clearly relevant, the wording helps demonstrate compliance.
- **Q2a (broader "law or binding order of a governmental body"):** two situations. **EU/EEA Member State law** falls within Art 28(3)(a) anyway, because EU and Member State law share the **same constitutional tradition** (**Art 16(1) TFEU; Arts 8(1) and 52(1) Charter**); if only this is covered, the wording has no impact. **Third-country law** doesn't share that tradition and cannot automatically be

treated the same (**Art 44**). The GDPR's "legal obligation" and "public interest" refer to **EU or Member State law** (**Art 6(3), Recital 40, Art 49(4)**), and **Art 29** permits processing without instructions only where "required to do so by Union or Member State law". For transfers, contracts may in principle address third-country legal requirements, but merely including the broad wording is "**highly unlikely to suffice**". **Better models: Clause 14 Transfer SCCs** (pre-signing assessment, warranty of no conflicting laws, notice of changes, suspension or termination), **Clause 15** (notify exporter, review legality of a government request and challenge it where appropriate), and similar BCR clauses. **Common standard:** third-country laws that **respect the essence of fundamental rights** and **do not exceed what is necessary and proportionate** in a democratic society to safeguard an **Art 23(1)** objective **do not undermine GDPR protection** (**Recommendations 02/2020 on the European Essential Guarantees**). Contracts must distinguish laws that undermine protection from those that do not, with supplementary measures where needed. Even within the EEA, a processor may face third-country law (e.g. via a **US parent and the CLOUD Act†**) but such wording "**does not release the processor from its obligations under the GDPR**". **Conclusion:** the broad wording "**is a prerogative of the contractual freedom of the parties and does not infringe Article 28(3)(a) GDPR per se**", but it doesn't exonerate either party from its obligations, esp. **duty to inform** and **transfer rules**.

- **Q2b: No.** An "**instruction**" = controller specifying what processing the processor should carry out on its behalf **and how**, precisely enough to cover specific processing, and it must **always be withdrawable.** A provision merely recognising legal compulsion isn't a request to process on the controller's behalf. **Controller's influence ends where law requires processing it cannot steer or halt** (***Belgian State (Official Journal)*, C-231/22**; Art 4(7)) → a reminder to obey the law is a **contractual safeguard, not an instruction**; same for third-country law. The word "**unless**" itself shows the exception is processing **not** on instruction. Broad wording "**cannot be construed as a documented instruction by the controller**", and "**the controller remains responsible where it has not ensured that the (sub-)processor processes personal data only on its documented instructions**". Doesn't apply where processing is required by EU/Member State law or by third-country law ensuring an **essentially equivalent level of protection**.

Why it matters; criticisms

- **Takeaways:** tightens controller accountability over long cloud/SaaS chains via **full visibility of the chain, risk-scaled verification, no excuse from practical difficulties**; makes processors **proactive information providers**. **Pragmatic: no duty to collect every sub-processing contract**, **sampling is enough**, controllers **may rely on processor documentation** → balances accountability with feasibility. Targets **boilerplate in US hyperscalers' DPAs** — "unless required by law or binding order of a governmental body" covers US government access such as **FISA 702 or the CLOUD Act†**: not illegal per se, but **insufficient for transfers and not an instruction**.
- **Central tension:** law places **ultimate responsibility on the controller**, yet many controllers (esp. **small businesses and public bodies**) face **take-it-or-leave-it contracts and opaque chains**. EDPB answers with **legal duties**; C4 answers with **technology**. **India:** DPDP s 8(1) makes the Data Fiduciary responsible "irrespective of any agreement to the contrary", s 8(2) requires a valid contract, but no prescribed content and no express sub-processor regulation → **supply-chain gap likely wider**.
- **Criticisms:** (1) **burdens small controllers** who lack bargaining power/expertise to verify multi-tier hyperscaler chains (CEF cloud report; *Compliance Gap* article). (2) **Relies heavily on processor self-reporting** → "paper compliance" despite its own warning about contractual clauses. (3) **Chain-**

wide identity requirement hard to meet where sub-processing is **dynamic** (CDNs, support centres). (4) It's an **opinion, not binding law** (though SAs follow Art 64 opinions for consistency).

C4. BAQUERO, RESTREPO AMARÍLES et al. (2025) — "The compliance gap in data supply chains: contract specification languages and smart contracts as compliance technologies" (*Artificial Intelligence and Law*)

Interdisciplinary team of lawyers and computer scientists.

The problem: a compliance gap at the back end

- Privacy research/regulation has focused on the **front end** (business-to-consumer, **B2C**: privacy policies, consent, empowering data subjects). Far less on the **back end** — the "**data supply chain**" through which a controller passes data to processors, who pass it to sub-processors. **Serious blind spot**: what happens to people's data depends on whether the **whole chain** complies.
- **Ponemon (2018):** data protection compliance = "**the most difficult regulatory challenge**" corporations face (vast data flows + growing use of **algorithmic decision systems (ADS)**). Controllers outsource **storage, cleansing, annotation, computational analysis, algorithm training, visualisation, app development** → division of labour makes it very hard to know what happens to data once it leaves the controller's hands. Firms invest in compliance technology, yet **no effective tool exists for monitoring the data supply chain** → the back end is a "**black box**" for controllers, consumers and regulators alike. **UK ICO (2019):** monitoring the data supply chain = one of the most urgent compliance issues; firms rely mainly on **contractual mechanisms** and neglect **monitoring and technical/organisational controls**.
- **Central claim:** "**individuals' right to data protection may lack effectiveness if it is not possible to monitor compliance regarding the data flowing in data supply chains**." Ties to the critique of **notice and consent** (Unit 2): telling people in a privacy policy what will happen achieves little if no one can check whether companies further down the chain follow the rules; **B2C transparency is not enough.** Compliance failures undermine **consumer trust** (Pavlou; Milne & Boza); and (Acquisti et al.) when firms skew the "**privacy/value balance**" through unbridled profit maximisation, **regulators respond** (GDPR; **CCPA**).

Why existing research and legal instruments fall short

- Privacy research is "**data-subject centric**" (readability/vagueness of policies, opt-out mechanisms, summarisation tools: **P3P, Do Not Track, CLAUDETTE**) — assumes people will trust a company with a privacy policy; **neglects internal company documents** (data processing agreements, processing instructions) that actually govern the back end.
- **AI & Law work has its own limits:** legal ontologies and logic programming (**ODRL, PrOnto**) face the **knowledge acquisition bottleneck** (turning legal texts/facts into formal logic is slow, laborious human work) and the **open texture of legal language** (terms often too abstract/ambiguous to become fixed rules). Real documents (Word, Excel, emails) are **unstructured**; NLP performs poorly on them.
- **The "compliance gap" defined:** data is processed iteratively and dynamically, but the instruments governing it have **four defects:**
    1. **Dispersed** — across many documents rather than one place (hard to update and monitor).

2. **Static** — can't track dynamic processing.
3. **Convoluted** — complex language, puzzling cross-references.
4. **Legalistic** — vocabulary remote from the technical/business staff who apply them. → controllers are "**disempowered**" and can't effectively monitor their own chains. Consequences: **companies** — higher non-compliance risk; **data subjects** — lose trust through lost control and information asymmetry; **SAs** — can't spot violations or systemic risks.

- **Eleven requirements (REQ1–REQ11)** — each defect becomes a requirement: | REQ | Requirement | | |---|---|---| | **REQ1** | One **integrated source** of contractual information | answers *dispersed* | | **REQ2** | **Dynamic updating with real-time monitoring** | answers *static* | | **REQ3** | **Clear and concise language** | answers *convoluted* | | **REQ4** | **Accessible vocabulary** | answers *legalistic* | | REQ5 | Integrate **internal company documents** | | | REQ6 | **Combined conceptual and technological framework** | | | REQ7 | **Extract information from enterprise documents** | | | REQ8 | Monitor the **entire chain incl. post-contractual obligations** | | | REQ9 | Control **unplanned and scattered international flows** | | | REQ10 | Ensure **all processors follow the controller's rules** | | | REQ11 | Keep flows aligned with the **controller's overall purpose** | |

The data supply chain and the law

- Term from **Kneese et al. (2014)**; ICO: data may be processed "**by hundreds of organizations**". Like industrial supply chains, based on division of labour, but with **two complications**: data is **immaterial and intangible** (harder to monitor/protect against leaks; "can be easily copied", esp. serious for sensitive data) and the chain is **international by nature** (data flows globally unless costly technology stops it).
- **Is "supply chain" even the right term?** It implies a leading firm coordinating everyone towards an overall objective, whereas data often flows in an "**unplanned, scattered manner**". **Cambridge Analytica**: Facebook, app developer Kogan and Cambridge Analytica shared **no common purpose**; only "**careless management**" creating flows each party used for its own benefit. **Authors nevertheless conclude** business practice and GDPR **create genuine supply chains**: controllers hire suppliers to achieve a purpose and the GDPR requires controllers to ensure all processors follow the rules and act on contractual instructions → "**an overall purpose to be achieved in coordination**".
- **GDPR provisions showing the stakes: Art 28(1)** only processors with sufficient guarantees; **Art 28(3)** processing governed by contract/legal act with controller's instructions; **Art 28(4)** processor must cascade all instructions to sub-processors and is **fully liable** to controller for them (presumption in EU law that initial processor liable by default); **Art 30** records of processing SAs can inspect; **Art 82(2)** controller liable for damage, processor liable where it acts against/outside instructions; **Art 82(4)** each responsible party liable for entire damage → "**heightened liabilities**" for both. **Financial stakes:** fines up to **4% of worldwide turnover**, record fines vs **Google, British Airways, Marriott**; **FTC 5*billionfineonFacebook* * * (*CambridgeAnalytica*); *annualcompliancecosts* * *7.7 million to $30.9 million**, **up 45% since 2011**.
- ⚠ **SLIP FOR EXAMS:** the paper attributes the accountability-based "burden of proof" to "**Article 7 GDPR**". In fact accountability lies in **Art 5(2) and Art 24**, while **Art 7(1)** only places on the controller the burden of demonstrating that the data subject gave **consent**. *Spotting this error and giving the correct provisions shows close reading.*

The Atos case study: why contracts are not enough

- **Atos** — one of Europe's largest IT companies; operates globally, often within long chains, acting as **processor for its clients and client of its own suppliers**, sometimes both in the same chain. Authors map the documents Atos uses (broad → specific): | Document | Function | |---|---| | **Supplier data protection policies & certifications** | Evidence of compliance **before hiring** | | **Master Services Agreement (MSA)** | Between controller and first processor; services, liabilities, commercial terms; **broad data protection clause** referring to the DPA and binding all later sub-processors | | **DPIA (Art 35)** | Identifies high risks **before** processing | | **Data Protection Addendum (DPA)** | Contains **Art 28(3)** obligations (subcontracting, security, confidentiality, breach procedure, audit) | | **Compliance Assessment of Data Processing (CADP)** | Documents processing details incl. subcontracting and risks; part of the **record of processing**; reviewed by DPO; Excel versions for when Atos is controller (**CADP-C**) or processor (**CADP-P**), a Word version for passing work to sub-processors (**CADP-S**) | | **Technical and Organisational Measures (TOM)** | A **security questionnaire** | | **SCCs and Binding Corporate Rules** | Govern **international transfers** | Almost all are highly **standardised**; only the constantly updated **CADP** is a truly "**living**" document. **Lesson:** "the more a particular document has to be handled by different firms … and by different levels of one particular firm, the higher will be the level of standardization required".
- **Five compliance functions:** (1) framework agreements/master contracts define **legal and ethical obligations and standards**; (2) **DPIA, DPA, CADP assess risks**; (3) **DPA and CADP instruct** the processing (down the chain, from managers to operations); (4) technical/operational documents (TOMs) **define operational measures**; (5) **CADP is used to audit and monitor** processing.
- **By purpose, three types: prescriptive** (give instructions: MSA, DPA, SCCs, BCRs), **evaluative** (collect info to assess compliance: TOMs), **evaluative-prescriptive** (do both: **CADP and DPIA**).
- **Why an Art 28 DPA can't solve it alone:** controllers face long chains with many recipients and real difficulty building a structured monitoring system "**even if the companies are intent on doing that**". Breaches show the danger: **April 2021** healthcare providers reported patient data exposed through **hacked third-party vendors**; **Airbus saw four of its vendors attacked** for technical documents; attempts to obtain **COVID vaccine cold-chain** information. In principle documents should be "living" (evaluative documents tracking changes; prescriptive documents updated with new instructions). **In reality most Atos documents are standardised and never updated**, and even the CADP (a long Excel questionnaire with space for client instructions) fails.
- **Four practical challenges:** (1) **Audits** complex and "burdensome" (multiple documents, formats, actors); (2) documents **not transversal** — the CADP "gets stuck in one particular department" instead of moving between **IT, legal, finance**; different people fill different documents so nothing guarantees coherence; (3) **interoperability** across firms is poor → hard to keep instructions consistent as they pass down the chain; (4) **no real-time compliance** — DPO must constantly screen documents for updates, causing delays or preventing effective compliance.
- **Point for a law student:** an Art 28 contract is a **static text** — it can say what processors must do but **cannot show whether they're doing it.** Links to paper vs effective compliance debate: Guidelines 07/2020 insist contracts must not merely restate the GDPR; **Opinion 22/2024: "contractual clauses cannot – by themselves – demonstrate that the sufficient guarantees are effectively implemented"**. **EDPB answers with legal duties of verification; this paper answers with technology.**

The proposed tools in plain words

- **Smart contract** (Unsworth): "**self-enforcing agreement, written in the form of computer code into an electronic platform**" — a small program that runs automatically when set conditions are

met. Behaves predictably → Hildebrandt: "**code-driven regulation**"; promises to cut monitoring and transaction costs. Difficulty (Binns): **translating natural-language contracts into code.**

- **Contract specification languages (CSLs)** bridge the gap: a structured way of writing a contract that **humans can still read** but is **precise enough for a computer to process and convert automatically** into a smart contract. Sorts wording into standard legal categories: **who owes a duty (debtor), to whom (creditor), what must be done, under what conditions, what powers each side has.**
- **Crucial: aim is NOT full automation.** Goal: "**automate the identification of potential inconsistencies and violations between data protection artifacts and data protection rules**, to be further examined by … data protection officers or other **humans-in-the-loop**". System **flags** possible problems; a **human decides** what to do.
- **Why Symboleo:** meets **3 criteria**: (1) links data protection concepts to higher-level categories (e.g. "storage of data", "retention period", "retention of data"); (2) supports **automated inferences** that flag potential violations (e.g. exceeding a storage period) to a human; (3) comes with **tools to verify** generated smart contracts flag violations **when, and only when**, their conditions occur.
- **Symboleo ontology:** a fixed vocabulary of legal concepts. A **contract** = set of **obligations and powers** between **roles** (controller, processor) held by **parties** (the client, Atos) concerning **assets** (the data). **Obligation** = a debtor's duty to a creditor to bring about a result when a condition holds, created when a **triggering event** occurs; may be **conditional, unconditional, or surviving** (outlives the contract, like deletion or confidentiality duties). **Power** = authority to **create, change, suspend, resume or terminate** obligations or contracts, taking effect only when exercised. **Events** (e.g. "delivered") = fixed points in time. Language has **33 axioms, 13 of which govern runtime monitoring.**
- **Three tools: Symboleo editor** (write specifications); **SymboleoPC** (translates into code for the **nuXmv model checker** — explores every possible way the contract could unfold); **Symboleo2SC** (generates smart contracts for **Hyperledger Fabric**, an open-source **private** blockchain where only approved participants take part).

Method and findings

- Authors **annotated Atos's natural-language contract documents, converted them into Symboleo, verified the result and generated monitoring smart contracts.** They call it "**an illustrative example rather than an experience report**". **Worked example:** simplified **DPA** (client = controller, Atos = processor): client gives documented instructions and must adapt them on receiving an **infringement notice**; Atos must process only on instructions, **warn the client of infringing instructions**, keep a **record of processing**, supply a copy on request. Mapping: client's duty to adapt instructions = obligation **triggered by the infringement notice** (mirrors **Art 28(3)** duty to inform of infringing instructions); Atos's record-keeping = obligation triggered **each time data is processed** (**Art 30(2)**); duty to supply a copy echoes **Art 28(3)(h)**; **Atos's right to suspend service if client fails to adapt = a power**, triggered by client's violation, matching the **suspension clause EDPB recommends**; client's right to have service resumed is also a power.
- **Finding 1 — verification at design time:** human-drafted contracts can contain **conflicting obligations** that make performance impossible → amendment, rollback, disputes, voidability. SymboleoPC and nuXmv check every possible course for **liveness** (every performance ends within bounded time) and **safety** (nothing undesirable happens). E.g. test that if processing is suspended and client never adapts, contract eventually **terminates unsuccessfully**. A failed check produces a **counterexample** (step-by-step trace). Can reveal a party exposed to **unlimited liability**, a contract

ignoring a party's primary intentions, or **impossible performance** (one clause requiring client data to be delivered and another requiring it to be deleted).

- **Finding 2 — monitoring at runtime:** the **blockchain ledger stores every change of state and every event** → contract history **trackable and tamper-proof**. In an illustrative **KYC ("know your client")** identity-checking service offered via an API, the smart contract records all processing so violations by client or provider can be found and reported to a **human-in-the-loop**, who can then trigger a **power** such as suspension. Shows which entities processed users' documents, where, and what computations were performed; **a regulator or watchdog could help maintain the ledger.**
- **Finding 3 — evaluation against the 11 requirements:** Symboleo **well supports REQ2** (real-time dynamic monitoring), **REQ3** (clear language) and **REQ9** (control of unplanned flows) because it is **event-based**. **Partially supports** the rest: **REQ1** (integrated source), **REQ4** (accessible wording), **REQ5** (integrating internal documents — converting DPA/CADP is manual), **REQ7** (extraction via templates), **REQ8** (whole-chain & post-contractual monitoring via surviving obligations), **REQ10 and REQ11** (processor alignment with controller's rules and purpose).

Limitations, criticisms and wider links

- **Authors admit:** Symboleo still in development; smart contracts lack **access control** (role-based controls being added). **Above all, the system cannot verify the truthfulness of its inputs — "garbage in, garbage out"**: the ledger is only as reliable as what the parties enter. Translating contracts into Symboleo remains **manual** (the knowledge acquisition bottleneck again); **SymboleoNLP handles only templates**; **LLMs speed things up but make many errors** and can't handle CADP-style Excel info. **Sub-contracts** (vital for long chains) are supported by the language but **not yet well by the tools**. **False positives/negatives** require continuous debugging to build trust. **Humans must still decide** → human–machine interaction matters; contracts may need adapting to fit the technology. **No CSL study has addressed different jurisdictions or changes in the law.** On **open texture**, authors say not a major problem because rules are first assessed for whether they're specific enough to formalise and "data protection rules tend to be specific" — **debatable**, since standards like "**appropriate**", "**sufficient guarantees**", "**without undue delay**" plainly require judgement.
- **Distinguished from earlier work** on smart contracts and GDPR (mostly basic **consent** via fixed-type contracts): Symboleo handles any conditions (usage, security, retention), complex obligations and powers, **design-time checking and runtime monitoring.** Caution: **smart contracts are not legal contracts** (which can be implied, e.g. buying clothes in a shop); agree with **Kelbert & Pretschner** that "**sticky policies**" travelling with the data are "rather unrealistic" across firms with different technologies and jurisdictions.
- **Balanced answer:**
  - **For:** fits GDPR **accountability** (Arts 5(2), 24, 28(1)) and Opinion 22/2024's demand for chain-wide visibility and continuous verification; turns **paper compliance into operational compliance**; **empowers controllers** (EDPB recognises they're weak against powerful processors); supports auditing and liability allocation under **Art 82(4)–(5)**.
  - **Against:** the ledger records **claims, not reality**; formal rules can't capture **open-textured standards** ("appropriate", "proportionate"); **blockchain immutability sits uneasily with erasure (Art 17) and storage limitation (Art 5(1)(e))**, though the ledger stores **events rather than personal data**†; **costs and adoption barriers burden SMEs**, interoperability needs network effects, unclear **who runs the ledger**; risk of **tech-solutionism** (substituting formal compliance for substantive protection — critiques of "**compliance-ism**"); study is

exploratory, using a **simplified DPA** → scalability unproven; and the fact that the one dynamic document (the CADP) is **still an Excel file** suggests the gap stems from **organisational silos, not technology alone.**

- **India link: DPDP Act s 8(1)** (fiduciary responsible "irrespective of any agreement to the contrary") and **s 8(2)** (processors only under "a valid contract") — but **no Art 28-style mandatory contract content and no explicit sub-processor regime** → supply-chain compliance gap may be even wider.
- **Conclusions:** formalising data protection instructions in a CSL **harmonises and clarifies** instructions scattered across documents and formats. **Partial automation** warns a human of inconsistencies **within instructions, between instructions and the law, and between instructions and actual processing**, cutting monitoring time. The blockchain gives a **reliable, tamper-proof record** of how each company processed data. System serves a **preventive function** (flag violations before they materialise) and a **repressive function** (identify the party responsible for a breach — for companies and potentially regulators). Running cost "**is negligible**". **Value:** shifts attention from the data subject to **the companies behind the controller**, complementing EDPB's legal answers by showing how hard the controller's responsibility is to discharge in practice. **Core message:** data subjects' rights are only as effective as the controller's ability to **see and control its supply chain**, and **static contracts cannot provide that visibility.** A balanced answer credits this while stressing the tools **support human judgement** rather than replace it and **cannot guarantee that what is recorded is true.**

C5. THE KEY CJEU CASES + UNIT 3 CONNECTION TO THE DPDP ACT 2023

Why the Court reads the roles broadly

- Roles are **functional**: follow what the entity actually does, not what a contract calls it; allocation "**not negotiable**". GDPR **didn't change** the concepts or criteria inherited from Directive 95/46 → **Directive-era CJEU judgments still govern.** Thread: "controller" must be read "**in a sufficiently broad way**", favouring "**effective and complete protection**" and avoiding gaps/circumvention, "while at the same time not diminishing the role of the processor".

The case line (summary table)

Case	Citation / date	Facts	Holding / principle
Google Spain	**C-131/12, 13 May 2014** (Grand Chamber)	**Mr Costeja González** wanted links to old newspaper notices about his historical **debt proceedings** removed from Google search results (outdated/irrelevant). Google: merely a **passive intermediary** linking to others' content → not a controller	**Search engine finding, indexing, temporarily storing and making available** information published by third parties **is a controller** of that processing (it allows information about identifiable people to be retrieved). **Broad definition needed for "effective and complete protection"** → data subjects can ask for outdated/irrelevant results to be **de-indexed** (the "**right to be forgotten**"). **Principle: an actor cannot escape controllership by calling itself a neutral pipe if it in substance decides why and how data is processed**

Case	Citation / date	Facts	Holding / principle
Wirtschaftsakademie	**C-210/16, 5 June 2018** (Grand Chamber)	German education company ran Facebook fan page; **Facebook Insights** anonymous stats (non-negotiable terms; cookies with unique user code active 2 years used for Facebook's own targeted ads). Schleswig-Holstein ULD ordered deactivation; company said processing was Facebook's	**Joint controller with Facebook Ireland** by **choosing to create a fan page** and **defining parameters** (target audience, objectives of managing/promoting its activities). Could ask for anonymised demographic, lifestyle and geographic data. Using a platform built by someone else doesn't exempt. **(1) Joint control doesn't require access to personal data** (its choices shaped whose data was processed and why, though it only saw anonymous statistics). **(2) Joint responsibility "does not necessarily imply equal responsibility"**: "at different stages … to different degrees" → **"stage and degree" principle** (Mahieu & van Hoboken). **Small administrator's lack of bargaining power over Facebook didn't defeat joint control** (aim = complete protection)
Jehovah's Witnesses (*Jehovan todistajat*)	**C-25/17, 10 July 2018**	Finnish authority prohibited community from collecting data door-to-door; members noted names, addresses, religious beliefs, family circumstances; community made maps, recorded preachers/publications, kept list of those refusing visits; **no written instructions**	(1) **Manual processing covered** where data forms or is meant to form part of a **filing system**; no need for data sheets, specific lists or search methods. (2) **Community and preaching members = joint controllers**: organising, coordinating, encouraging; general knowledge; **no written guidance and no access needed.** AG **Mengozzi**: "excessive formalism would make it easy to circumvent". **Control can come from organisation/coordination alone; individuals can be joint controllers with an organisation**
Fashion ID	**C-40/17, 29 July 2019**	Online clothing retailer embedded Facebook **"Like" button**; visitors' data automatically transmitted to Facebook Ireland whether or not Facebook members or clicked. **Verbraucherzentrale NRW** sued; **OLG Düsseldorf** referred	**Phase split: joint controller with Facebook for collection and disclosure by transmission** ("exerted a decisive influence"; for own commercial advantage = better publicity on Facebook) but **NOT** a controller for Facebook's **subsequent** processing. **Duties** follow same line: inform at collection (identity, purposes); consent only for jointly controlled operations. EDPB generalised: preceding/subsequent operations decided alone → **sole controller**. **"Phase-oriented" approach** limits breadth of *Wirtschaftsakademie*

- **Line of development:** *Google Spain* = broad functional test aimed at complete protection → *Wirtschaftsakademie* + *Jehovah's Witnesses* = **participation in determining purposes and means is enough** (no access, no written instructions, no equal bargaining power) → *Fashion ID* **limits joint control to the stages actually co-determined** → "**joint is not equal**" scales responsibility to each party's stage and degree. **Cimina** (EDPS Legal Officer) draws the same lessons from the trilogy, adding that clear roles foster both data subjects' rights and accountability.
- **EDPB working test:** joint participation = **common decision** or **converging decisions** that complement each other, are necessary for the processing and have a tangible impact on purposes/means. **Key question:** would the processing "**not be possible without both parties' participation**" → each party's processing "**inseparable, i.e. inextricably linked**". **Brake:** "the mere existence of a mutual benefit (for ex. commercial)" doesn't create joint control; an entity "**merely being paid for services rendered**" is a processor. **Same functional logic in reverse for**

processors: under **Art 28(10)** a processor that starts deciding its own purposes and means **becomes a controller for that processing and is in breach.**

- **Later judgments (beyond readings):** ***Nacionalinis visuomenės sveikatos centras*** (**C-683/21, 2023**)† — commissioning body can be a controller **without processing data itself** (COVID-tracing app commissioned from a developer); joint control **needs no formal arrangement** (update). ***Belgian State (Official Journal)*** (**C-231/22, 2024**) — where law sets purposes and means, it can **designate the controller**. ***Proximus*** (**C-129/21**), ***Natsionalna agentsia za prihodite*** (**C-340/21**), ***MediaMarktSaturn*** (**C-687/21**) — reinforce accountability: controllers must **take appropriate steps to prevent infringements**, measures assessed **concretely**, and the controller **bears the burden of proving its security was appropriate.**

The cross-cutting debates

1. **Functional approach vs contractual labels.** *For:* prevents circumvention (nobody can contract out of controllership; "subcontractor" ≠ processor — WP29 SWIFT). *Against:* parties can't always know their role in advance; SAs can set contracts aside. **EDPB middle position: follow the contract where it reflects reality.**
2. **Expansion of joint controllership via the trilogy.** *For:* complete protection; avoids gaps where a platform and its users each disclaim responsibility; incentive for website operators to choose privacy-friendly tools. *Against:* **over-inclusion** (every fan-page admin or plug-in user becomes a co-controller); duties loaded on small parties who can't influence platform's non-negotiable terms; diffused responsibility; **burdens on SMEs**; vagueness of "converging decisions" and "inextricably linked"; **AG Bobek warned against making everyone responsible for everything.** *Mitigations:* "joint ≠ equal", *Fashion ID*'s phase limit, EDPB rule that mere commercial benefit isn't enough.
3. **Power imbalance with hyperscale processors.** EDPB: imbalance is no justification for non-compliant terms; controller that freely accepts a provider's terms assumes full responsibility; Opinion 22/2024: "practical difficulties … do not exonerate". **Critics:** ignores market reality — SMEs and public bodies **can't negotiate with AWS, Microsoft or Google** and chains are opaque. Suggested responses: **SCCs, codes of conduct and certification (Art 28(5)), coordinated enforcement, collective procurement.** Linked to **paper vs effective compliance:** "contractual clauses cannot – by themselves – demonstrate that the sufficient guarantees are effectively implemented" → supports **continuous verification through audits** rather than signed documents alone.
4. **Processor liability. Art 82(2):** processor liable only for breaching **processor-specific obligations** or acting **outside or contrary to lawful instructions**; **Art 82(4):** parties jointly and severally liable for whole damage. Cimina: processor following strict instructions isn't liable; controller remains main responsible party towards data subjects. **In India the debate is sharper (below).**

THE UNIT 3 CONNECTION: Fiduciaries and processors under the DPDP Act 2023

- **Functional mapping: Data Fiduciary — s 2(i)** = any person who, "**alone or in conjunction with other persons**", determines the **purpose and means** of processing personal data. **Data Processor — s 2(k)** = any person who processes personal data **on behalf of** a Data Fiduciary. Your Unit 1 notes stress classification is **functional not contractual** — what a party actually decides about purpose and means controls, regardless of what a commercial agreement calls it. Course notes teach *Wirtschaftsakademie* and *Google Spain* alongside these definitions, presenting search engine operators as "controllers / fiduciaries" → **the CJEU's functional reasoning is the natural guide to reading the Indian terms.**

- **Course running example: SafeShield Insurance**, deciding to collect **health data for underwriting**, = **fiduciary** (decides why and how; bears primary obligations under **s 8**; answers to the **Data Protection Board** and **data principals**). **Third-Party Administrator (TPA)** processing claims for SafeShield = **processor** (follows instructions, no independent purpose, **not directly answerable to principals**).
- **Section 8(1) — "single point of accountability":** fiduciary is responsible for compliance for processing "by it or on its behalf by a Data Processor", "**irrespective of any agreement to the contrary**", and also irrespective of a principal's own failure to perform her **s 15** duties. In the notes' phrase: "**outsourcing the processing does not outsource the liability**." An **indemnity clause** can shift money between fiduciary and processor but **cannot shift statutory responsibility** → a processor's breach = the fiduciary's breach. Other duties repeat the point: **s 8(5)** security duty covers processing by processors; **s 8(7)(b)** requires the fiduciary to **cause its processor to erase data**.
- **Section 8(2) — the contractual link:** a fiduciary may engage a processor for any activity related to offering goods or services to principals **only "under a valid contract"**. ⚠ **Slip:** the **Unit 1 slide attributes the mandatory processing agreement to s 8(6), but Unit 3 makes clear the hook is s 8(2); s 8(6) is the breach-notification duty. Striking gap:** s 8(2) says **nothing about what the contract must contain.** The **only content rule in the whole DPDP framework is Rule 6(1)(f) of the DPDP Rules 2025**, requiring "appropriate provision in the contract … for taking **reasonable security safeguards**". Everything else must be borrowed from **GDPR Art 28(3)** or sectoral rules. **Substantive fiduciary duties come into force only on 13 May 2027**, so this is **anticipatory compliance**.
- **Comparison via SafeShield:** under the **GDPR**, SafeShield = controller, TPA = processor, and **Art 28** would require a binding contract with detailed mandatory content (processing only on documented instructions, staff confidentiality, **Art 32** security, sub-processor conditions, assistance with data subject rights and **Arts 32–36**, deletion/return, information and audits). TPA would also carry **direct duties** (records **Art 30(2)**, security **Art 32**, breach notice to controller **Art 33(2)**), could be **fined and held liable under Art 82**, and under **Art 28(10)** would become a controller if it used claims data for its own purposes. **Under the DPDP Act**, the TPA has **no direct statutory duties**: everything flows through the fiduciary and the contract. **Sub-processors not expressly regulated** (the 2022 draft's **s 9(9)** had allowed them "if permitted under its contract"); **no equivalent of Art 28(10)**; **no compensation provision for principals**, only **penalties imposed by the Board**. So if SafeShield's TPA held claim files under an **unsigned contract silent on security** and attackers copied them (the Unit 3 problem question), the plea "**the TPA is responsible**" would **fail under s 8(1)**, and the contract itself would breach **s 8(2) and Rule 6(1)(f)**.
- **Joint control — wider gap:** "in conjunction with other persons" in **s 2(i)** implies there can be **joint fiduciaries**, but the Act has **nothing like Art 26**: no required **arrangement** on who does what, no duty to give data subjects its **essence**, no rule like **Art 26(3)** letting them exercise rights against each fiduciary. **India's model concentrates responsibility on the fiduciary** — simple and protective in theory — but **without the Art 28 machinery the supply-chain compliance gap is likely to be wider, especially in Indian IT and BPO outsourcing chains.**

Enforcement lessons from the GDPR (four cases) and the RBI as gap-filler

- **Source:** CMS Enforcement Tracker filtered by **Art 28** and the **employment sector** returns **225 of 3,270 fines**. | Case | Facts | Fine | Lesson | |---|---|---|---| | ***CNIL v Groupe Canal+*** (2023) | Investigation triggered by **31 complaints**; several processing agreements **didn't meet Art 28(3)** —

some **predated the GDPR and were never updated**, others **unsigned and therefore not valid** | **€600,000** (also covered marketing without consent, information and rights failures, unnotified breach) | **Outdated agreements reveal a lack of regular checks on processors** | | ***Croatian SA v B2 Kapital*** (2023) | **Debt-collection agency** concluded **no contract at all** with processor providing a "monitoring simple consumer bankruptcy" service → security of **personal identification numbers of 83,896 people** at risk (Feb 2019–Feb 2021) | **€2,265,000** overall (several violations) | "**Concluding a contract with a processor is one of the safety measures**" → missing contract is a **security failure**, not just a paperwork failure | | ***Norwegian DPA v Ferde AS*** | **Toll-road operator** sent about **12.5 million images a year** to processor **UBS**, whose employees in **China** handled them manually = **transfer to third country**; agreement **undated** and probably **not in place for a year**; **no adequate security or risk assessment** | **NOK 5 million**† | Missing contract, cross-border processing and no risk assessment **compound one another** | | ***CNIL v Dedalus Biologie*** (2022) | **Mirror image — processor's own liability.** Dedalus = processor for **medical laboratories** using its software; leak of **491,840 patients'** data; **neither its standard terms of sale nor its maintenance contracts** contained Art 28(3) content. Dedalus argued the Art 28 contract is a **joint obligation** so shouldn't bear sole responsibility; pointed to its compliance efforts since 2018 | **€1.5 million**† (also covered security failures and **processing beyond instructions during a migration**) | **CNIL rejected**: Art 28(3) binding both parties **doesn't remove the processor's own liability**, esp. where **the processor drafted the non-compliant terms itself** |

- **Indian contrast:** under the DPDP Act the Board could proceed **only against the fiduciary** (the laboratories, Ferde, B2 Kapital), and a ***Dedalus*-style fine on a processor would not be possible** because processors have **no direct duties**. **Both sides (for exam):**
  - *For direct processor liability:* cloud providers, software vendors and TPAs often **control the actual security**; *Dedalus* and the **Target breach** show incidents **start with vendors**; the Board could act where the fiduciary is small and the vendor large.
  - *Against:* a **single point of accountability** is simpler for principals; the fiduciary chooses its vendors; **contracts can allocate risk**; small Indian IT vendors are **spared compliance costs.**
  - **Whether the absence of processor liability is a gap or a deliberate design choice is a genuine question for an exam answer.**
- **RBI as gap-filler:** for regulated entities, sectoral rules already fill part of the s 8(2) gap. **RBI Master Direction on outsourcing by NBFCs** requires outsourcing agreements to be **written**, **vetted by legal counsel** for legal effect and enforceability, to address risks and mitigation, to **preserve the NBFC's control and right to intervene**, and to **state the nature of the legal relationship**. Its **twelve key provisions** include: NBFC's **access to all the provider's records**; **continuous monitoring**; **prior approval for subcontractors**; **confidentiality of customer data with the provider liable for breaches and leaks**; NBFC's **audit rights**; **RBI's own rights to access records and inspect the provider**; and **confidentiality and document preservation surviving termination.** As Unit 3 observes, this **maps closely onto GDPR Art 28(3)** (sub-processor approval, audit, confidentiality, return/retention of data) → **a strong answer can argue Indian sector regulators have already built the contract machinery the DPDP Act itself leaves out.**

UNIT 3 EXAM TOOLKIT

1. "Which role?" decision method (use in problem questions)

1. **Is there a legal designation / legal task requiring processing?** (Art 4(7) second limb; implicit competence) → that body = controller.
2. **Who decides the purpose (the "why") and the essential means (which data, whose data, how long, who gets access)?** If yes → **controller**. If it merely acts on another's **documented instructions**, deciding at most **non-essential means** (software, hardware, detailed security) → **processor**.
3. **Is there a separate entity?** (department ≠ processor; employees = Art 29; group company can be processor.)
4. **Does it have a purpose of its own** or benefit beyond payment for services? → points to **controller**. "Merely being paid for services rendered" → **processor**.
5. **Is the processing impossible without more than one party's decisive influence** (common or converging decisions; inseparable, inextricably linked)? → **joint controllers** for **those stages only**; **before/after stages decided alone = sole controller.**
6. **Does the processor go beyond instructions / use data for its own purposes? → Art 28(10) →** treated as controller for that processing (and in breach).
7. **Contract label?** Starting point only — **functional test overrides** ("not negotiable").
8. **Then apply consequences:** Art 28 contract (8 clauses) / Art 26 arrangement (essence to data subjects; rights against each); liability (Art 82(2), (4), (5)); fines (Art 83(4)(a): €10m/2%); Indian analogue: s 8(1), (2), Rule 6(1)(f).

2. Role summary table

Term	Provision	Key idea
Controller	Art 4(7)	Determines **purposes and means**; alone or jointly; law may designate
Joint controllers	Art 26(1)	**Jointly** determine purposes **and** means (common or converging decisions); arrangement; **rights against each** (26(3)); **essence available** (26(2))
Processor	Art 4(8)	Processes **on behalf of**; **separate entity**; documented instructions; **Art 28(10)** if it exceeds
Sub-processor	Art 28(2), (4)	Prior **specific or general** written authorisation; **same obligations**; **initial processor fully liable**
Third party	Art 4(10)	Not subject, controller, processor or persons under direct authority
Recipient	Art 4(9)	Any one to whom data is disclosed (except authorities in a particular inquiry — Recital 31)
EUI controller	Reg 2018/1725 Art 3(8)	DG can be controller; Art 65 compensation; Art 28 joint control
DPDP Fiduciary	s 2(i)	Purpose and means "alone or in conjunction with other persons"; **s 8(1)** single point of accountability
DPDP Processor	s 2(k)	Processes on behalf; **s 8(2)** valid contract; **no direct duties**

3. Likely essay questions — skeletons

1. **"Critically evaluate the CJEU's expansion of joint controllership (*Wirtschaftsakademie*, *Jehovah's Witnesses*, *Fashion ID*)."** Facts/holdings table; principles (no access, no instructions,

no equal responsibility, phase-limited); EDPB test (common/converging decisions; inextricably linked; mutual benefit not enough); arguments for (complete protection; avoids gaps) and against (over-inclusion; SMEs; power imbalance; Bobek); mitigations; India has no Art 26.

2. **"Distinguish controller and processor; why does it matter that the test is functional?"** Building blocks; essential vs non-essential means; worked examples (payroll/bank; accountant; market researcher); contract not decisive; Art 28(10); consequences.
3. **"Explain the Art 28 contract. How far can a controller rely on a processor?"** 2 describing + 8 clauses; sufficient guarantees; written; SCCs; sub-processors (specific vs general; silence); Art 28(4); liability; Opinion 22/2024 "reliance allowed, blind reliance not".
4. **"Does the controller need to know and verify the whole processing chain?" (Opinion 22/2024)** Q1.1 (know the whole chain; three reasons; *Österreichische Post*); verification (*Proximus*, risk-scaled; *C-340/21*); no systematic duty to ask for sub-processing contracts (sampling); transfers (Art 44 + 28(1); mapping; TIA; adequacy); criticisms.
5. **"'Unless required by law' in Art 28(3)(a): what must contracts say?"** Highly recommended not required; EU/Member State vs third-country law; Clauses 14 & 15 Transfer SCCs; European Essential Guarantees; not an instruction (*C-231/22*); CLOUD Act/FISA.
6. **"Why isn't an Art 28 contract enough? Can technology close the compliance gap?" (C4)** Front end vs back end; four defects; 11 REQs; Atos documents; Symboleo (obligations/powers; nuXmv; Hyperledger Fabric); findings; limits (garbage in, open texture, immutability vs erasure, SMEs); EDPB legal answer vs technological answer; ⚠ Art 7 slip.
7. **"Compare the GDPR and DPDP Act on controllers/processors" (SafeShield).** Definitions s 2(i), (k); s 8(1) single accountability; s 8(2) valid contract + Rule 6(1)(f); **no direct processor duties, no Art 28(10), no sub-processor regime, no Art 26, no compensation**; enforcement cases (*Dedalus*); RBI NBFC outsourcing master direction as gap-filler; gap vs design choice.
8. **"Power imbalance in the cloud: should small controllers bear full responsibility?"** EDPB stance; Opinion 22/2024 ("practical difficulties do not exonerate"); critique; solutions (SCCs, Art 28(5) codes/certification, collective procurement, coordinated enforcement); C4 technology.
9. **"Evaluate EU institutions' regime (Reg 2018/1725) vs GDPR on these concepts." (Cimina)** Mapping table; DG as controller (GDPR: organisation); DGs not processors; Art 28 joint controllers; Art 65 liability (Arts 340, 268 TFEU); wording tension on purposes/means.

4. Cheat sheet — numbers, names, quotes

- **EDPB Guidelines 07/2020:** Art 70(1)(e); draft **2 Sept 2020**; v2.0 **7 July 2021**; v2.1 **20 Sept 2022**; replaces **WP169 (Opinion 1/2010)**. **5 building blocks** of controller. **Essential means = type of data, duration, recipients, data subjects. 8 Art 28(3) clauses (a)–(h). 3 situations with no joint control.** Fines **€10m/2%** (Art 83(4)(a)).
- **Cimina:** *ERA Forum* **Oct 2020**; **EDPS Guidelines 7 Nov 2019**; **Reg 45/2001** repealed; **7 CJEU clarifications**; **Art 340/268 TFEU**; **Art 65**; **Art 28** joint controllers; **Art 29** processors.
- **Opinion 22/2024:** adopted **7 Oct 2024**; chair **Anu Talus**; request by **Danish SA on 5 July 2024** under **Art 64(2)**; **CEF report 17 Jan 2023** (8 challenges); Q1.1, 1.2, 1.3, 2, 2a, 2b; **SCCs Decisions 2021/915 (Controller–Processor) and 2021/914 (Transfer)**; **Clause 7.7(c)** and **Clause 9(c)**; **Clauses 8.1, 14(e), 14, 15**; **Recommendations 01/2020 and 02/2020**; **Guidelines 05/2021** (transfer concept).
- **CJEU cases:** *Google Spain* **C-131/12 (13 May 2014)**; *Wirtschaftsakademie* **C-210/16 (5 June 2018)**; *Jehovah's Witnesses* **C-25/17 (10 July 2018)**; *Fashion ID* **C-40/17 (29 July 2019)**; *Österreichische Post* **C-154/21 (12 Jan 2023)**; *Proximus* **C-129/21**; *Natsionalna agentsia za*

prihodite **C-340/21**; *MediaMarktSaturn* **C-687/21**; *Belgian State (Official Journal)* **C-231/22**; *Nacionalinis visuomenės sveikatos centras* **C-683/21**†; *Schrems II* **C-311/18**.

- **C4 (Compliance gap): front/back end**; **4 defects** (dispersed, static, convoluted, legalistic); **11 requirements**; Ponemon 2018; ICO 2019; **Atos**; docs: MSA, DPIA, DPA, **CADP (C/P/S)**, TOM, SCC/BCR; types **prescriptive / evaluative / evaluative-prescriptive**; **4 challenges** (audits, not transversal, interoperability, no real-time compliance); **Symboleo**: **33 axioms (13 runtime)**; obligations (conditional/unconditional/**surviving**), powers; **SymboleoPC → nuXmv; Symboleo2SC → Hyperledger Fabric**; liveness/safety; well supports **REQ2, REQ3, REQ9**; FTC **5*bn* * *;*costs* * *7.7m–$30.9m** (+45% since 2011); ⚠ **Art 7 vs Arts 5(2)/24 slip.**
- **DPDP: s 2(i)** fiduciary, **s 2(k)** processor; **s 8(1)** (irrespective of contrary agreement), **s 8(2)** (valid contract), **s 8(5)** security, **s 8(6)** breach notification, **s 8(7)(b)** processor erasure; **Rule 6(1)(f)** DPDP Rules 2025 (only content rule: security safeguards); substantive duties from **13 May 2027**; **s 15** principal duties; 2022 draft **s 9(9)** sub-processors.
- **Enforcement cases: Canal+ €600,000 (31 complaints)**; **B2 Kapital €2,265,000 (83,896 people)**; **Ferde AS NOK 5m (12.5m images/yr; UBS in China)**†; **Dedalus €1.5m (491,840 patients)**†; **225 of 3,270** fines (CMS tracker).
- **RBI NBFC outsourcing Master Direction:** written agreements, legal vetting, **12 key provisions** (access to records; continuous monitoring; subcontractor approval; confidentiality + liability; audit; RBI inspection; survival after termination).

5. Common traps

- **Cimina's "not necessary to equally determine both purposes and means"** vs EDPB "decide both" → reconcile via **essential vs non-essential means**.
- **GDPR: department ≠ controller (organisation is). EUDPR Art 3(8): a DG can be a controller.** DGs not listed as processors.
- **Joint controllers ≠ equal; no access needed; control limited to jointly determined phases.**
- **Specific authorisation: silence = denial. General authorisation: silence = authorisation.**
- **Opinion 22/2024: no duty to *systematically* ask for sub-processing contracts**; sampling; request where doubts.
- **Art 28(3)(a) "unless required by law": highly recommended, not strictly required**; third-country wording doesn't infringe per se but isn't an instruction.
- **Art 28(3): eight clauses (a)–(h).** (Guide in Unit 2 R7 lists 2 describing items + 9 bullets splitting sub-processor rules 28(2)/(4); count carefully.)
- **C4's "Article 7" attribution is wrong** (should be Arts 5(2)/24).
- **DPDP: contract hook is s 8(2) (not s 8(6)).** No Art 28 content, no direct processor duties, no Art 26, no compensation.
- **Dedalus:** processor fined despite joint obligation argument; not possible under DPDP.